

阿泽Vx: est258258

What would be an example of an organization transferring the risks associated with a data breach?

- A. Using a third-party service to process credit card transactions.
- B. Encrypting sensitive personal data during collection and storage
- C. Purchasing insurance to cover the organization in case of a breach.
- D. Applying industry standard data handling practices to the organization' practices.

Correct Answer: C

Reference:

<http://www.hpso.com/Documents/pdfs/newsletters/firm09-rehabv1.pdf>

- valneilima

9 months, 3 weeks ago

lixo mesmo

upvoted 1 times
- ProjectBS

6 months, 3 weeks ago

is this dump really no good?

upvoted 1 times
- Erepeer

1 year, 10 months ago

I doubt if the answers are right and the questions are outdated.

upvoted 2 times
- 837vq3

2 years, 1 month ago

when will this dump get updated? it has the same questions since last year

upvoted 1 times
- vicks888

2 years, 7 months ago

how was it?

upvoted 1 times
- 837vq3

2 years, 7 months ago

I recently took the exam and hardly got 10 questions from this dump. The dump is old and invalid.

upvoted 1 times
- Sbowo

2 years, 6 months ago

Yes. I already passed the exam too and got only 10-20 questions from this dump. I never believe the default answer and try to ensure it every time. This dump is good for exercising but please always question their answer.

upvoted 2 times
- 837vq3

2 years, 1 month ago

did you find a more accurate dump from somewhere else?

upvoted 2 times
- ProjectBS

6 months, 3 weeks ago

would love to hear on accurate dump else where..

upvoted 1 times
- ProjectBS

4 months, 1 week ago

Took the exam. I think I only got 10-15 questions from this dump. Passed, nonetheless. This dump needs to be updated for sure.

upvoted 2 times

Which of the following is considered a client-side IT risk?

- A. Security policies focus solely on internal corporate obligations.
- B. An organization increases the number of applications on its server.
- C. An employee stores his personal information on his company laptop.
- D. IDs used to avoid the use of personal data map to personal data in another database.

Correct Answer: C

🗨️ 👤 **Stants** 5 months, 3 weeks ago

The client-side IT risk among the options provided is:

C. An employee stores his personal information on his company laptop.

Client-side IT risks typically involve actions or issues related to end-users or individual devices. In this case, an employee storing personal information on a company laptop poses a potential risk to data security and confidentiality.

upvoted 1 times

阿泽Vx: est258258

SCENARIO -

Carol was a U.S.-based glassmaker who sold her work at art festivals. She kept things simple by only accepting cash and personal checks. As business grew, Carol couldn't keep up with demand, and traveling to festivals became burdensome. Carol opened a small boutique and hired Sam to run it while she worked in the studio. Sam was a natural salesperson, and business doubled. Carol told Sam, "I don't know what you are doing, but keep doing it!"

But months later, the gift shop was in chaos. Carol realized that Sam needed help so she hired Jane, who had business expertise and could handle the back-office tasks. Sam would continue to focus on sales. Carol gave Jane a few weeks to get acquainted with the artisan craft business, and then scheduled a meeting for the three of them to discuss Jane's first impressions.

At the meeting, Carol could not wait to hear Jane's thoughts, but she was unprepared for what Jane had to say. "Carol, I know that he doesn't realize it, but some of Sam's efforts to increase sales have put you in a vulnerable position. You are not protecting customers' personal information like you should."

Sam said, "I am protecting our information. I keep it in the safe with our bank deposit. It's only a list of customers' names, addresses and phone numbers that I get from their checks before I deposit them. I contact them when you finish a piece that I think they would like. That's the only information I have! The only other thing I do is post photos and information about your work on the photo sharing site that I use with family and friends. I provide my email address and people send me their information if they want to see more of your work. Posting online really helps sales, Carol. In fact, the only complaint I hear is about having to come into the shop to make a purchase."

Carol replied, "Jane, that doesn't sound so bad. Could you just fix things and help us to post even more online?"

"I can," said Jane. "But it's not quite that simple. I need to set up a new program to make sure that we follow the best practices in data management. And I am concerned for our customers. They should be able to manage how we use their personal information. We also should develop a social media strategy."

Sam and Jane worked hard during the following year. One of the decisions they made was to contract with an outside vendor to manage online sales. At the end of the year, Carol shared some exciting news. "Sam and Jane, you have done such a great job that one of the biggest names in the glass business wants to buy us out! And Jane, they want to talk to you about merging all of our customer and vendor information with theirs beforehand."

What type of principles would be the best guide for Jane's ideas regarding a new data management program?

- A. Collection limitation principles.
- B. Vendor management principles.
- C. Incident preparedness principles.
- D. Fair Information Practice Principles

Correct Answer: D

Reference:

<https://www.worldprivacyforum.org/2008/01/report-a-brief-introduction-to-fair-information-practices/>

SCENARIO -

Carol was a U.S.-based glassmaker who sold her work at art festivals. She kept things simple by only accepting cash and personal checks. As business grew, Carol couldn't keep up with demand, and traveling to festivals became burdensome. Carol opened a small boutique and hired Sam to run it while she worked in the studio. Sam was a natural salesperson, and business doubled. Carol told Sam, "I don't know what you are doing, but keep doing it!"

But months later, the gift shop was in chaos. Carol realized that Sam needed help so she hired Jane, who had business expertise and could handle the back-office tasks. Sam would continue to focus on sales. Carol gave Jane a few weeks to get acquainted with the artisan craft business, and then scheduled a meeting for the three of them to discuss Jane's first impressions.

At the meeting, Carol could not wait to hear Jane's thoughts, but she was unprepared for what Jane had to say. "Carol, I know that he doesn't realize it, but some of Sam's efforts to increase sales have put you in a vulnerable position. You are not protecting customers' personal information like you should."

Sam said, "I am protecting our information. I keep it in the safe with our bank deposit. It's only a list of customers' names, addresses and phone numbers that I get from their checks before I deposit them. I contact them when you finish a piece that I think they would like. That's the only information I have! The only other thing I do is post photos and information about your work on the photo sharing site that I use with family and friends. I provide my email address and people send me their information if they want to see more of your work. Posting online really helps sales, Carol. In fact, the only complaint I hear is about having to come into the shop to make a purchase."

Carol replied, "Jane, that doesn't sound so bad. Could you just fix things and help us to post even more online?"

"I can," said Jane. "But it's not quite that simple. I need to set up a new program to make sure that we follow the best practices in data management. And I am concerned for our customers. They should be able to manage how we use their personal information. We also should develop a social media strategy."

Sam and Jane worked hard during the following year. One of the decisions they made was to contract with an outside vendor to manage online sales. At the end of the year, Carol shared some exciting news. "Sam and Jane, you have done such a great job that one of the biggest names in the glass business wants to buy us out! And Jane, they want to talk to you about merging all of our customer and vendor information with theirs beforehand."

Which regulator has jurisdiction over the shop's data management practices?

- A. The Federal Trade Commission.
- B. The Department of Commerce.
- C. The Data Protection Authority.
- D. The Federal Communications Commission.

Correct Answer: A

Reference:

<https://fas.org/sgp/crs/misc/R45631.pdf>

Community vote distribution

C (100%)

- PaigeH7

4 months ago

Selected Answer: C

T Data Protection Authority is a regulatory body responsible for enforcing data protection laws and ensuring that organizations comply with their obligations to protect personal data. The Federal Trade Commission (FTC) is an independent agency of the United States government whose primary mission is to promote consumer protection and prevent anti-competitive business practices

upvoted 1 times
- JoyChada

12 months ago

Why not C? (I got the answer and ref from another source)

The Data Protection Authority is a regulatory body responsible for enforcing data protection laws and ensuring that organizations comply with their obligations to protect personal data. The Federal Trade Commission (FTC) is an independent agency of the United States government whose primary mission is to promote consumer protection and prevent anti-competitive business practices.

upvoted 1 times

SCENARIO -

Carol was a U.S.-based glassmaker who sold her work at art festivals. She kept things simple by only accepting cash and personal checks. As business grew, Carol couldn't keep up with demand, and traveling to festivals became burdensome. Carol opened a small boutique and hired Sam to run it while she worked in the studio. Sam was a natural salesperson, and business doubled. Carol told Sam, "I don't know what you are doing, but keep doing it!"

But months later, the gift shop was in chaos. Carol realized that Sam needed help so she hired Jane, who had business expertise and could handle the back-office tasks. Sam would continue to focus on sales. Carol gave Jane a few weeks to get acquainted with the artisan craft business, and then scheduled a meeting for the three of them to discuss Jane's first impressions.

At the meeting, Carol could not wait to hear Jane's thoughts, but she was unprepared for what Jane had to say. "Carol, I know that he doesn't realize it, but some of Sam's efforts to increase sales have put you in a vulnerable position. You are not protecting customers' personal information like you should."

Sam said, "I am protecting our information. I keep it in the safe with our bank deposit. It's only a list of customers' names, addresses and phone numbers that I get from their checks before I deposit them. I contact them when you finish a piece that I think they would like. That's the only information I have! The only other thing I do is post photos and information about your work on the photo sharing site that I use with family and friends. I provide my email address and people send me their information if they want to see more of your work. Posting online really helps sales, Carol. In fact, the only complaint I hear is about having to come into the shop to make a purchase."

Carol replied, "Jane, that doesn't sound so bad. Could you just fix things and help us to post even more online?"

"I can," said Jane. "But it's not quite that simple. I need to set up a new program to make sure that we follow the best practices in data management. And I am concerned for our customers. They should be able to manage how we use their personal information. We also should develop a social media strategy."

Sam and Jane worked hard during the following year. One of the decisions they made was to contract with an outside vendor to manage online sales. At the end of the year, Carol shared some exciting news. "Sam and Jane, you have done such a great job that one of the biggest names in the glass business wants to buy us out! And Jane, they want to talk to you about merging all of our customer and vendor information with theirs beforehand."

When initially collecting personal information from customers, what should Jane be guided by?

- A. Onward transfer rules.
- B. Digital rights management.
- C. Data minimization principles.
- D. Vendor management principles

Correct Answer: B

Community vote distribution

C (100%)

- pipzz

Highly Voted

2 years, 10 months ago

C. Data minimization principles is more appropriate for this scenario. Digital rights management refers to a set of access control technologies.

upvoted 6 times
- 837vq3

2 years, 9 months ago

Minimization involves limiting the amount of personal information that needs to be processed. Ideally, this should be done at the time of collection by avoiding or preventing the collection of unnecessary information, but the concept should extend throughout the information life cycle.

upvoted 1 times
- k4d4v4r

2 years, 8 months ago

Anyway DRM is not for every situation in the data life cycle

upvoted 2 times
- PaigeH7

Most Recent

4 months ago

Selected Answer: C

When initially collecting personal information from customers, Jane should be guided by data minimization

upvoted 1 times

A key principle of an effective privacy policy is that it should be?

- A. Written in enough detail to cover the majority of likely scenarios.
- B. Made general enough to maximize flexibility in its application.
- C. Presented with external parties as the intended audience.
- D. Designed primarily by the organization's lawyers.

Correct Answer: C

Community vote distribution

A (100%)

  **rajiabdmjd** 1 year, 3 months ago

Selected Answer: A

Answer is A
upvoted 1 times

  **yaw222** 1 year, 5 months ago

Organization privacy policy is an internal documents. why this answer relate to external parties as the intended audience.
upvoted 1 times

阿泽Vx: est258258

What was the first privacy framework to be developed?

- A. OECD Privacy Principles.
- B. Generally Accepted Privacy Principles.
- C. Code of Fair Information Practice Principles (FIPPs).
- D. The Asia-Pacific Economic Cooperation (APEC) Privacy Framework.

Correct Answer: A

Reference:

<http://oecdprivacy.org>

Community vote distribution

C (100%)

-   **PaigeH7** 4 months ago

Selected Answer: C

Even in the book, Introduction to Privacy for Technology, section 1.5, lists that FIPPS came out in 1977 and OECD came out in 1980

upvoted 1 times
-   **rajiabdmjd** 1 year, 3 months ago

Selected Answer: C

C. Code of Fair Information Practice Principles (FIPPs).

upvoted 1 times
-   **BTAB** 1 year, 10 months ago

Selected Answer: C

Even in the book, Introduction to Privacy for Technology, section 1.5, lists that FIPPS came out in 1977 and OECD came out in 1980.

Correct answer is C.

upvoted 2 times
-   **pipzz** 2 years, 10 months ago

The Fair Information Practice Principles (FIPPs) are a widely accepted framework that is at the core of the Privacy Act of 1974The FIPPs were first articulated in a comprehensive manner in the U.S. Department of Health, Education and Welfare's seminal 1973 report entitled Records, Computers and the Rights of Citizens (1973) (full-text) (hereinafter "HEW Report").In 1980, the international Organization of Economic Cooperation and Development (OECD) codified its Guidelines on the Protection of Privacy and Transborder Flows of Personal Data. The original five principles set forth in the HEW Report were extended in the OECD guidelines that govern "the protection of privacy and transborder data flows of personal data" and include eight principles that have come to be understood as "minimum standards . . . for the protection of privacy and individual liberties."

https://itlaw.wikia.org/wiki/Fair_Information_Practice_Principles

upvoted 4 times

Which of the following became a foundation for privacy principles and practices of countries and organizations across the globe?

- A. The Personal Data Ordinance.
- B. The EU Data Protection Directive.
- C. The Code of Fair Information Practices.
- D. The Organization for Economic Co-operation and Development (OECD) Privacy Principles.

Correct Answer: D

Reference:

<https://privacyrights.org/resources/review-fair-information-principles-foundation-privacy-public-policy>

阿泽Vx: est258258

SCENARIO -

Kyle is a new security compliance manager who will be responsible for coordinating and executing controls to ensure compliance with the company's information security policy and industry standards. Kyle is also new to the company, where collaboration is a core value. On his first day of new-hire orientation, Kyle's schedule included participating in meetings and observing work in the IT and compliance departments. Kyle spent the morning in the IT department, where the CIO welcomed him and explained that her department was responsible for IT governance. The CIO and Kyle engaged in a conversation about the importance of identifying meaningful IT governance metrics. Following their conversation, the CIO introduced Kyle to Ted and Barney. Ted is implementing a plan to encrypt data at the transportation level of the organization's wireless network. Kyle would need to get up to speed on the project and suggest ways to monitor effectiveness once the implementation was complete. Barney explained that his short-term goals are to establish rules governing where data can be placed and to minimize the use of offline data storage. Kyle spent the afternoon with Jill, a compliance specialist, and learned that she was exploring an initiative for a compliance program to follow self-regulatory privacy principles. Thanks to a recent internship, Kyle had some experience in this area and knew where Jill could find some support. Jill also shared results of the company's privacy risk assessment, noting that the secondary use of personal information was considered a high risk. By the end of the day, Kyle was very excited about his new job and his new company. In fact, he learned about an open position for someone with strong qualifications and experience with access privileges, project standards board approval processes, and application-level obligations, and couldn't wait to recommend his friend Ben who would be perfect for the job. Ted's implementation is most likely a response to what incident?

- A. Encryption keys were previously unavailable to the organization's cloud storage host.
- B. Signatureless advanced malware was detected at multiple points on the organization's networks.
- C. Cyber criminals accessed proprietary data by running automated authentication attacks on the organization's network.
- D. Confidential information discussed during a strategic teleconference was intercepted by the organization's top competitor.

Correct Answer: A

Community vote distribution

D (50%)

C (50%)

- ChaBum

2 years, 4 months ago

Selected Answer: C

C is the only answer related to local network, and encrypting data passing through the WiFi only protect the LAN.

upvoted 2 times
- ChaBum

2 years, 4 months ago

C is the only answer related to local network, and encrypting data passing through the WiFi only protect the LAN.

upvoted 1 times
- 187san

2 years, 7 months ago

Selected Answer: D

its D , rest responses does not make sense

upvoted 2 times
- ChaBum

2 years, 4 months ago

teleconferences are most likely to pass through Internet because you want to interact with people outside your premises, encrypting the wireless network will only protect the data inside you premise.

upvoted 1 times
- k4d4v4r

2 years, 8 months ago

Why A and not D? Wireless has nothing to do with cloud

upvoted 2 times

SCENARIO -

Kyle is a new security compliance manager who will be responsible for coordinating and executing controls to ensure compliance with the company's information security policy and industry standards. Kyle is also new to the company, where collaboration is a core value. On his first day of new-hire orientation, Kyle's schedule included participating in meetings and observing work in the IT and compliance departments. Kyle spent the morning in the IT department, where the CIO welcomed him and explained that her department was responsible for IT governance. The CIO and Kyle engaged in a conversation about the importance of identifying meaningful IT governance metrics. Following their conversation, the CIO introduced Kyle to Ted and Barney. Ted is implementing a plan to encrypt data at the transportation level of the organization's wireless network. Kyle would need to get up to speed on the project and suggest ways to monitor effectiveness once the implementation was complete. Barney explained that his short-term goals are to establish rules governing where data can be placed and to minimize the use of offline data storage. Kyle spent the afternoon with Jill, a compliance specialist, and learned that she was exploring an initiative for a compliance program to follow self-regulatory privacy principles. Thanks to a recent internship, Kyle had some experience in this area and knew where Jill could find some support. Jill also shared results of the company's privacy risk assessment, noting that the secondary use of personal information was considered a high risk. By the end of the day, Kyle was very excited about his new job and his new company. In fact, he learned about an open position for someone with strong qualifications and experience with access privileges, project standards board approval processes, and application-level obligations, and couldn't wait to recommend his friend Ben who would be perfect for the job. Which of the following should Kyle recommend to Jill as the best source of support for her initiative?

- A. Investors.
- B. Regulators.
- C. Industry groups.
- D. Corporate researchers.

Correct Answer: C

阿泽Vx: est258258

SCENARIO -

Kyle is a new security compliance manager who will be responsible for coordinating and executing controls to ensure compliance with the company's information security policy and industry standards. Kyle is also new to the company, where collaboration is a core value. On his first day of new-hire orientation, Kyle's schedule included participating in meetings and observing work in the IT and compliance departments. Kyle spent the morning in the IT department, where the CIO welcomed him and explained that her department was responsible for IT governance. The CIO and Kyle engaged in a conversation about the importance of identifying meaningful IT governance metrics. Following their conversation, the CIO introduced Kyle to Ted and Barney. Ted is implementing a plan to encrypt data at the transportation level of the organization's wireless network. Kyle would need to get up to speed on the project and suggest ways to monitor effectiveness once the implementation was complete. Barney explained that his short-term goals are to establish rules governing where data can be placed and to minimize the use of offline data storage. Kyle spent the afternoon with Jill, a compliance specialist, and learned that she was exploring an initiative for a compliance program to follow self-regulatory privacy principles. Thanks to a recent internship, Kyle had some experience in this area and knew where Jill could find some support. Jill also shared results of the company's privacy risk assessment, noting that the secondary use of personal information was considered a high risk. By the end of the day, Kyle was very excited about his new job and his new company. In fact, he learned about an open position for someone with strong qualifications and experience with access privileges, project standards board approval processes, and application-level obligations, and couldn't wait to recommend his friend Ben who would be perfect for the job. Which data practice is Barney most likely focused on improving?

- A. Deletion
- B. Inventory.
- C. Retention.
- D. Sharing

Correct Answer: C

-   **impchoi** 1 year ago

Chat GPT says Retention: Data retention is the practice of preserving data for a specific period of time to meet technical, business, or regulatory requirements. Any time you save data to a file, you're technically retaining it — but the term "data retention" usually refers to the deliberate, systematic ways in which you store, use, and delete data. Developing a good data retention strategy requires a solid understanding of the nature, format, sensitivity, and useful lifecycle of your data. A good place to start is to create an inventory and diagram for all your data inflows and outflows¹.

Based on this information, it seems that where data can be placed is part of retention rather than inventory.

upvoted 2 times
-   **za1q2wsx** 1 year, 4 months ago

should select B

upvoted 2 times

What is the main function of a breach response center?

- A. Detecting internal security attacks.
- B. Addressing privacy incidents.
- C. Providing training to internal constituencies.
- D. Interfacing with privacy regulators and governmental bodies.

Correct Answer: B

 **Stants** 5 months, 3 weeks ago

The main function of a breach response center is to address privacy incidents, so the answer is B. Addressing privacy incidents.

While breach response centers may have other functions, such as:

- Detecting internal security attacks (to some extent, as these can lead to privacy incidents)
 - Providing training to internal constituencies (to help prevent future incidents)
 - Interfacing with privacy regulators and governmental bodies (as part of the incident response process)
 - Their primary focus is on handling situations where sensitive data has been compromised. This includes:
 - Investigating the incident to understand its scope and impact
 - Taking steps to contain the breach and prevent further damage
 - Notifying affected individuals and regulators
 - Implementing corrective actions to improve security
- upvoted 2 times

阿泽Vx: est258258

Which is NOT a suitable action to apply to data when the retention period ends?

- A. Aggregation.
- B. De-identification.
- C. Deletion.
- D. Retagging.

Correct Answer: C

Community vote distribution

D (85%)

A (15%)

- pipzz**

Highly Voted

2 years, 10 months ago

Deletion is the main action you would take after retention periods end. The worst thing to do would be to re-tag the data.

upvoted 9 times
- 187san**

Highly Voted

2 years, 7 months ago

Selected Answer: D

D , question asked " NOT"

upvoted 6 times
- rajiabdmjd**

Most Recent

1 year, 3 months ago

Selected Answer: D

Retagging

upvoted 2 times
- z80r**

1 year, 6 months ago

Selected Answer: D

I would say D

upvoted 3 times
- 837vq3**

1 year, 10 months ago

Selected Answer: A

Aggregation

upvoted 1 times
- ChaBum**

2 years, 4 months ago

Selected Answer: A

Data aggregation is a process in which data is gathered and represented in a summary form, for purposes including statistical analysis. That would mean using the data after the retention period has been reached. and that does not make sense.

B. De-identification, could be a mean to keep the data under an anonymized format, and so under the condition of the collection it could make sense

C. Deletion, it the most common way to deal with data when they reach the end of their retention period.

D. Retagging, is in fact extending or resetting the retention period. For example because the PII of customers are kept for a defined retention period of 3 years EXCEPT if the customer had interaction if the Data controller during those 3 years, then the data is re-tag and kept.

upvoted 1 times
- k4d4v4r**

2 years, 8 months ago

C is correct. Aggregation is a common backup/retention solution. You can de-identity and you can of course retag so you can know what you can delete or what you should archive. Archive is the next step after retention.

upvoted 2 times

What is the distinguishing feature of asymmetric encryption?

- A. It has a stronger key for encryption than for decryption.
- B. It employs layered encryption using dissimilar methods.
- C. It uses distinct keys for encryption and decryption.
- D. It is designed to cross operating systems.

Correct Answer: C

Reference:

<https://www.cryptomathic.com/news-events/blog/classification-of-cryptographic-keys-functions-and-properties>

What is the most important requirement to fulfill when transferring data out of an organization?

- A. Ensuring the organization sending the data controls how the data is tagged by the receiver.
- B. Ensuring the organization receiving the data performs a privacy impact assessment.
- C. Ensuring the commitments made to the data owner are followed.
- D. Extending the data retention schedule as needed.

Correct Answer: C

Which activity would best support the principle of data quality?

- A. Providing notice to the data subject regarding any change in the purpose for collecting such data.
- B. Ensuring that the number of teams processing personal information is limited.
- C. Delivering information in a format that the data subject understands.
- D. Ensuring that information remains accurate.

Correct Answer: D

Reference:

<https://iapp.org/resources/article/fair-information-practices/>

Which Organization for Economic Co-operation and Development (OECD) privacy protection principle encourages an organization to obtain an individual's consent before transferring personal information?

- A. Individual participation.
- B. Purpose specification.
- C. Collection limitation.
- D. Accountability.

Correct Answer: C

Reference:
<http://oecdprivacy.org>

Community vote distribution

A (100%)

ofirga

5 months, 1 week ago

The right answer is C. You can see evidence here: https://www.oecd.org/sti/ieconomy/oecd_privacy_framework.pdf

7. There should be limits to the collection of personal data and any such data should be obtained by lawful and fair means and, where appropriate, with the knowledge or consent of the data subject.

upvoted 2 times

PTDT

9 months, 4 weeks ago

Selected Answer: A

It is A.

upvoted 2 times

Stants

5 months, 3 weeks ago

A. Individual participation.

The Organization for Economic Co-operation and Development (OECD) privacy protection principle that encourages an organization to obtain an individual's consent before transferring personal information is "Individual participation." This principle emphasizes the importance of allowing individuals to have a say in the use and disclosure of their personal data, including providing consent for the transfer of their information to third parties.

upvoted 1 times

rajiabdmjd

1 year, 3 months ago

Why isn't it A?

upvoted 2 times

Granting data subjects the right to have data corrected, amended, or deleted describes?

- A. Use limitation.
- B. Accountability.
- C. A security safeguard
- D. Individual participation

Correct Answer: D
Reference:
<https://www.ncbi.nlm.nih.gov/books/NBK236546/>

  **Stants** 5 months, 3 weeks ago

D. Individual participation.

Granting data subjects the right to have data corrected, amended, or deleted aligns with the principle of "Individual participation." This principle emphasizes the importance of individuals having control over their own personal data, including the ability to request corrections or deletions when necessary. It is a key aspect of privacy and data protection frameworks that prioritize giving individuals a say in how their information is managed.

upvoted 1 times

What is a mistake organizations make when establishing privacy settings during the development of applications?

- A. Providing a user with too many choices.
- B. Failing to use "Do Not Track" technology.
- C. Providing a user with too much third-party information.
- D. Failing to get explicit consent from a user on the use of cookies.

Correct Answer: D

  **steven2xx** 1 year, 1 month ago

if the application doesn't use cookie at all, why they should get the consent?

upvoted 2 times

Which of the following suggests the greatest degree of transparency?

- A. A privacy disclosure statement clearly articulates general purposes for collection
- B. The data subject has multiple opportunities to opt-out after collection has occurred.
- C. A privacy notice accommodates broadly defined future collections for new products.
- D. After reading the privacy notice, a data subject confidently infers how her information will be used.

Correct Answer: D

Which is NOT a suitable method for assuring the quality of data collected by a third-party company?

- A. Verifying the accuracy of the data by contacting users.
- B. Validating the company's data collection procedures.
- C. Introducing erroneous data to see if its detected.
- D. Tracking changes to data through auditing.

Correct Answer: A

Community vote distribution

C (100%)

-   **ofirga** 5 months, 1 week ago

The answer is C.
The method that is NOT suitable for assuring the quality of data collected by a third-party company is C. Introducing erroneous data to see if it's detected. While it might seem like a way to test the system, intentionally introducing incorrect data can lead to unintended consequences and potentially harm the accuracy and reliability of the collected information. Instead, focus on other methods like verifying accuracy, validating procedures, and tracking changes through auditing to ensure data quality.

upvoted 1 times
-   **rajiabdmjd** 1 year, 3 months ago

Selected Answer: C

C. Introducing erroneous data to see if it's detected.

Introducing erroneous data to see if it's detected is not a suitable method for assuring the quality of data collected by a third-party company. This approach is likely to introduce additional errors into the data and may not provide a reliable measure of the quality of the data. Suitable methods for assuring the quality of data collected by a third-party company include verifying the accuracy of the data by contacting users, validating the company's data collection procedures, and tracking changes to data through auditing. These methods can help to ensure that the data collected is accurate, complete, and reliable, which is important for making informed decisions based on that data.

upvoted 2 times
-   **z80r** 1 year, 6 months ago

Selected Answer: C

C guys

upvoted 2 times
-   **Sara_sw** 1 year, 8 months ago

Selected Answer: C

The question asks which is NOT the correct approach.
A is correct, C is NOT correct so the answer is C

upvoted 3 times
-   **Sbowo** 2 years, 6 months ago

C is NOT correct, see page 63 book Privacy in Technology by Cannon

upvoted 1 times
-   **k4d4v4r** 2 years, 8 months ago

A is correct then

upvoted 2 times
-   **k4d4v4r** 2 years, 8 months ago

A is absurd and would be a privacy violation

upvoted 1 times
-   **837vq3** 2 years, 9 months ago

Why not "B" " Introducing erroneous data to see if its detected."?

upvoted 2 times

A valid argument against data minimization is that it?

- A. Can limit business opportunities.
- B. Decreases the speed of data transfers.
- C. Can have an adverse effect on data quality.
- D. Increases the chance that someone can be identified from data.

Correct Answer: A

阿泽Vx: est258258

What is the main reason a company relies on implied consent instead of explicit consent from a user to process her data?

- A. The implied consent model provides the user with more detailed data collection information.
- B. To secure explicit consent, a user's website browsing would be significantly disrupted.
- C. An explicit consent model is more expensive to implement.
- D. Regulators prefer the implied consent model.

Correct Answer: A

Community vote distribution

B (100%)

- Sbowo**

Highly Voted

2 years, 6 months ago

B is the answer based on the book

upvoted 6 times
- PaigeH7**

Most Recent

4 months ago

Selected Answer: B

Explicit consent typically involves more active steps, such as clicking checkboxes or providing specific permissions, which can interrupt the user experience.

upvoted 1 times
- ofirga**

5 months, 1 week ago

The answer is B

The main reason a company relies on implied consent instead of explicit consent from a user to process their data is typically due to the concern that securing explicit consent might significantly disrupt the user's website browsing experience. Implied consent assumes that users agree to certain data processing practices by continuing to use a website or service, without requiring them to actively provide explicit consent for each specific action. While explicit consent provides more transparency and control to users, it can indeed be more cumbersome to implement and may lead to interruptions in the user experience. However, companies must strike a balance between user privacy and operational efficiency while adhering to relevant regulations. □

upvoted 1 times
- Stants**

5 months, 4 weeks ago

B. Disruption: Explicit consent typically requires users to actively opt-in or out through prompts or checkboxes, which can interrupt their browsing experience and reduce engagement. Implied consent allows for smoother user flow on websites and applications.

upvoted 1 times
- steven2xx**

1 year, 1 month ago

why is C?

upvoted 1 times
- rajiabdmjd**

1 year, 3 months ago

B should be the correct answer

upvoted 1 times
- steven222223**

1 year, 4 months ago

which part?

upvoted 2 times

What is the main benefit of using dummy data during software testing?

- A. The data comes in a format convenient for testing.
- B. Statistical disclosure controls are applied to the data.
- C. The data enables the suppression of particular values in a set.
- D. Developers do not need special privacy training to test the software.

Correct Answer: D

Community vote distribution

C (100%)

-   **PaigeH7** 4 months ago

Selected Answer: C

Dummy data allows testers to create controlled scenarios by intentionally including or excluding specific values, ensuring comprehensive test coverage without compromising sensitive information. It helps protect privacy and maintain data security during testing.

upvoted 1 times
-   **ofirga** 5 months, 1 week ago

The answer is A.

The main benefit of using dummy data during software testing is that it allows developers to create realistic scenarios without exposing real user information. Let's break down the options:

A. The data comes in a format convenient for testing.

This is true. Dummy data can be customized to simulate various scenarios, making it convenient for testing different functionalities.

upvoted 1 times

How does k-anonymity help to protect privacy in micro data sets?

- A. By ensuring that every record in a set is part of a group of "k" records having similar identifying information.
- B. By switching values between records in order to preserve most statistics while still maintaining privacy.
- C. By adding sufficient noise to the data in order to hide the impact of any one individual.
- D. By top-coding all age data above a value of "k."

Correct Answer: A

Reference:

https://www.researchgate.net/publication/284332229_k-Anonymity_A_Model_for_Protecting_Privacy

-   **837vq3** 2 years, 9 months ago

k-anonymity relies on the creation of generalized, truncated, or redacted quasi-identifiers as replacements for direct identifiers such that a given minimum number ("k") of individuals in a data set have the same identifier

upvoted 1 times

Which of the following statements describes an acceptable disclosure practice?

- A. An organization's privacy policy discloses how data will be used among groups within the organization itself.
- B. With regard to limitation of use, internal disclosure policies override contractual agreements with third parties.
- C. Intermediaries processing sensitive data on behalf of an organization require stricter disclosure oversight than vendors.
- D. When an organization discloses data to a vendor, the terms of the vendor' privacy notice prevail over the organization' privacy notice.

Correct Answer: A

  **4n0nym3** 3 months ago
Why not D? Isn't A a bit too detailed for the data subjects?
upvoted 1 times

阿泽Vx: est258258

How should the sharing of information within an organization be documented?

- A. With a binding contract.
- B. With a data flow diagram.
- C. With a disclosure statement.
- D. With a memorandum of agreement.

Correct Answer: C

Community vote distribution

B (75%)D (25%)

- PaigeH7

4 months ago

Selected Answer: D

he sharing of information within an organization is typically documented with a memorandum of agreement (MOA). An MOA outlines the terms, responsibilities, and expectations related to information sharing between parties. It serves as a formal record of the agreement and helps ensure clarity and accountability.

upvoted 1 times
- ofirga

5 months, 1 week ago

The answer is D.

The sharing of information within an organization should be documented with a memorandum of agreement (MOA). An MOA outlines the terms, responsibilities, and expectations related to information sharing between parties. It serves as a formal record of the agreement and helps ensure clarity and accountability. While other options (such as binding contracts, data flow diagrams, and disclosure statements) may play roles in specific contexts, an MOA specifically addresses the sharing of information.

upvoted 1 times
- rajiabdmjd

1 year, 3 months ago

Selected Answer: B

A data flow diagram is a graphical representation of the flow of data within a system or organization. While it can be used to document the flow of information within an organization, it may not be the most suitable or comprehensive method for documenting the sharing of information.

A data flow diagram can be useful in illustrating how information moves through a system or process, but it may not capture all the necessary details related to data sharing, such as the types of data being shared, the purpose of sharing, and the security measures in place to protect the data.

Therefore, while a data flow diagram may be part of the documentation for sharing information within an organization, it is not typically the sole or primary method used for documenting data sharing.

upvoted 3 times
- rajiabdmjd

1 year, 3 months ago

Why not B ?

upvoted 2 times

What can be used to determine the type of data in storage without exposing its contents?

- A. Collection records.
- B. Data mapping.
- C. Server logs.
- D. Metadata.

Correct Answer: D

Reference:
<https://cloud.google.com/storage/docs/goutil/addlhelp/WorkingWithObjectMetadata>

What must be done to destroy data stored on "write once read many" (WORM) media?

- A. The data must be made inaccessible by encryption.
- B. The erase function must be used to remove all data.
- C. The media must be physically destroyed.
- D. The media must be reformatted.

Correct Answer: C

Currently there are no comments in this discussion, be the first to comment!

Which of the following would best improve an organization' s system of limiting data use?

- A. Implementing digital rights management technology.
- B. Confirming implied consent for any secondary use of data.
- C. Applying audit trails to resources to monitor company personnel.
- D. Instituting a system of user authentication for company personnel.

Correct Answer: C

Community vote distribution

A (50%)

D (50%)

- PaigeH7

4 months ago

Selected Answer: A

DRM helps control access to digital content and restricts how data is used, ensuring that only authorized individuals can access and manipulate it.

upvoted 1 times
- rajiabdmjd

1 year, 3 months ago

Selected Answer: D

Instituting a system of user authentication for company personnel.

upvoted 1 times
- rajiabdmjd

1 year, 3 months ago

I think D

upvoted 1 times
- Sbowo

2 years, 6 months ago

Answer is D, based on Privacy in Technology book. All answer is correct, but base on priority, first one is explicit consent on secondary use, second is user authentication

upvoted 3 times
- k4d4v4r

2 years, 8 months ago

C is correct. DRM is more related to end users. For systems you should rely on audit logs to monitor usage of data.

upvoted 2 times
- 837vq3

2 years, 9 months ago

Digital Rights Management: This is used to ensure that digital content is only delivered to those who are authorized to receive it. It can also limit what assigned users can do with the content. For example, a person may be permitted to read a
© International Association of Privacy Professionals 10
the document, but not allowed to print it, email it to others, copy content from it or modify it.

upvoted 1 times

Which of the following is considered a records management best practice?

- A. Archiving expired data records and files.
- B. Storing decryption keys with their associated backup systems.
- C. Implementing consistent handling practices across all record types.
- D. Using classification to determine access rules and retention policy.

Correct Answer: D

Reference:

<https://www.archive-vault.co.uk/best-practice-for-records-management>

Which of the following provides a mechanism that allows an end-user to use a single sign-on (SSO) for multiple services?

- A. The Open ID Federation.
- B. PCI Data Security Standards Council
- C. International Organization for Standardization.
- D. Personal Information Protection and Electronic Documents Act.

Correct Answer: A

阿泽Vx: est258258

A user who owns a resource wants to give other individuals access to the resource. What control would apply?

- A. Mandatory access control.
- B. Role-based access controls.
- C. Discretionary access control.
- D. Context of authority controls.

Correct Answer: B

Reference:

<https://docs.microsoft.com/bs-latn-ba/azure/role-based-access-control/overview>

Community vote distribution

C (100%)

-   **rajiabdmjd** 1 year, 3 months ago

Correct answer is C

upvoted 1 times
-   **837vq3** 1 year, 10 months ago

Selected Answer: C

C is the answer

upvoted 2 times
-   **ChaBum** 2 years, 4 months ago

Selected Answer: C

Here is the definition of DAC from iapp: A type of access control that allows an owner of an object, within a given computer-based information system, to grant or deny access.

upvoted 3 times
-   **Sbowo** 2 years, 6 months ago

C is the answer

upvoted 4 times

What is the potential advantage of homomorphic encryption?

- A. Encrypted information can be analyzed without decrypting it first.
- B. Ciphertext size decreases as the security level increases.
- C. It allows greater security and faster processing times.
- D. It makes data impenetrable to attacks.

Correct Answer: C

Reference:
<https://www.sciencedirect.com/topics/computer-science/homomorphic-encryption>

Community vote distribution

A (75%)C (25%)

- 4n0nym3** 3 months ago

Definitely A.

C doesn't make sense performance wise, it'll just add computation overhead

upvoted 1 times
- z80r** 1 year, 6 months ago

Selected Answer: A

it's A for sure

upvoted 2 times
- z80r** 1 year, 6 months ago

Selected Answer: C

it's C

upvoted 2 times
- ChaBum** 2 years, 4 months ago

Selected Answer: A

Definition of Homomorphic from iapp: Allows encrypted information to be manipulated without first being decrypted.

upvoted 2 times
- Sbowo** 2 years, 6 months ago

A is the answer

upvoted 2 times
- 187san** 2 years, 7 months ago

Selected Answer: A

Homomorphic encryption is a form of encryption that permits users to perform computations on its encrypted data without first decrypting it. ... This allows data to be encrypted and out-sourced to commercial cloud environments for processing, all while encrypted.
https://en.wikipedia.org/wiki/Homomorphic_encryption#:~:text=Homomorphic%20encryption%20is%20a%20form,data%20without%20first%20decrypting%20it.&text=This%20allows%20data%20to%20be,for%20processing%2C%20all%20while%20encrypted.

upvoted 2 times
- k4d4v4r** 2 years, 8 months ago

A should be correct. "Faster processing times" is tremendously erroneous for homomorphic encryption

upvoted 2 times
- 837vq3** 2 years, 8 months ago

Homomorphic encryption allows encrypted information to be manipulated without first being decrypted. Early homomorphic encryption was too slow to be of practical use but is now fast enough to use with some applications that require high degrees of privacy and security.

upvoted 2 times

What has been found to undermine the public key infrastructure system?

- A. Man-in-the-middle attacks.
- B. Inability to track abandoned keys.
- C. Disreputable certificate authorities.
- D. Browsers missing a copy of the certificate authority's public key.

Correct Answer: D

Community vote distribution

C (100%)

-   **Sbowo**

Highly Voted 

 2 years, 6 months ago

I think C is the answer because disreputable CA will make their certificate questionable

upvoted 6 times
-   **FayBab1**

Most Recent 

 8 months, 2 weeks ago

Agree about C ... D is a local impact

upvoted 2 times
-   **pipzz** 2 years ago

Selected Answer: C

Privacy for Technology book also mentions when DigiNotar, a Dutch CA owned by VASCO Data Security International, apparently issued a certificate for the domain name *.google.com. The problem is that DigiNotar didn't issue the certificate to Google—it appears that it was issued by the government of Iran, which allegedly used the certificate to spy on Iranian citizens accessing Gmail and Google docs.

upvoted 3 times

SCENARIO -

Wesley Energy has finally made its move, acquiring the venerable oil and gas exploration firm Lancelot from its long-time owner David Wilson. As a member of the transition team, you have come to realize that Wilson's quirky nature affected even Lancelot's data practices, which are maddeningly inconsistent. `The old man hired and fired IT people like he was changing his necktie,` one of Wilson's seasoned lieutenants tells you, as you identify the traces of initiatives left half complete.

For instance, while some proprietary data and personal information on clients and employees is encrypted, other sensitive information, including health information from surveillance testing of employees for toxic exposures, remains unencrypted, particularly when included within longer records with less-sensitive data. You also find that data is scattered across applications, servers and facilities in a manner that at first glance seems almost random.

Among your preliminary findings of the condition of data at Lancelot are the following:

- ☞ Cloud technology is supplied by vendors around the world, including firms that you have not heard of. You are told by a former Lancelot employee that these vendors operate with divergent security requirements and protocols.
- ☞ The company's proprietary recovery process for shale oil is stored on servers among a variety of less-sensitive information that can be accessed not only by scientists, but by personnel of all types at most company locations.
- ☞ DES is the strongest encryption algorithm currently used for any file.
- ☞ Several company facilities lack physical security controls, beyond visitor check-in, which familiar vendors often bypass.
- ☞ Fixing all of this will take work, but first you need to grasp the scope of the mess and formulate a plan of action to address it.

Which is true regarding the type of encryption Lancelot uses?

- A. It employs the data scrambling technique known as obfuscation.
- B. Its decryption key is derived from its encryption key.
- C. It uses a single key for encryption and decryption.
- D. It is a data masking methodology.

Correct Answer: C

🗉  **rajiabdmjd** 1 year, 3 months ago

Correct

upvoted 1 times

SCENARIO -

Wesley Energy has finally made its move, acquiring the venerable oil and gas exploration firm Lancelot from its long-time owner David Wilson. As a member of the transition team, you have come to realize that Wilson's quirky nature affected even Lancelot's data practices, which are maddeningly inconsistent. `The old man hired and fired IT people like he was changing his necktie,` one of Wilson's seasoned lieutenants tells you, as you identify the traces of initiatives left half complete.

For instance, while some proprietary data and personal information on clients and employees is encrypted, other sensitive information, including health information from surveillance testing of employees for toxic exposures, remains unencrypted, particularly when included within longer records with less-sensitive data. You also find that data is scattered across applications, servers and facilities in a manner that at first glance seems almost random.

Among your preliminary findings of the condition of data at Lancelot are the following:

- ☞ Cloud technology is supplied by vendors around the world, including firms that you have not heard of. You are told by a former Lancelot employee that these vendors operate with divergent security requirements and protocols.
- ☞ The company's proprietary recovery process for shale oil is stored on servers among a variety of less-sensitive information that can be accessed not only by scientists, but by personnel of all types at most company locations.
- ☞ DES is the strongest encryption algorithm currently used for any file.
- ☞ Several company facilities lack physical security controls, beyond visitor check-in, which familiar vendors often bypass.
- ☞ Fixing all of this will take work, but first you need to grasp the scope of the mess and formulate a plan of action to address it.

Which procedure should be employed to identify the types and locations of data held by Wesley Energy?

- A. Privacy audit.
- B. Log collection
- C. Data inventory.
- D. Data classification.

Correct Answer: C

A credit card with the last few numbers visible is an example of what?

- A. Masking data
- B. Synthetic data
- C. Sighting controls.
- D. Partial encryption

Correct Answer: A
Reference:
<https://money.stackexchange.com/questions/98951/credit-card-number-masking-good-practices-rules-law-regulations>

What is an example of a just-in-time notice?

- A. A warning that a website may be unsafe.
- B. A full organizational privacy notice publicly available on a website
- C. A credit card company calling a user to verify a purchase before it is authorized
- D. Privacy information given to a user when he attempts to comment on an online article.

Correct Answer: D

Reference:

<https://www.clarip.com/data-privacy/just-time-notice/>

  **steven2xx** 1 year, 1 month ago

why A is wrong?

upvoted 1 times

A vendor has been collecting data under an old contract, not aligned with the practices of the organization.
Which is the preferred response?

- A. Destroy the data
- B. Update the contract to bring the vendor into alignment.
- C. Continue the terms of the existing contract until it expires.
- D. Terminate the contract and begin a vendor selection process.

Correct Answer: B

Currently there are no comments in this discussion, be the first to comment!

SCENARIO -

It should be the most secure location housing data in all of Europe, if not the world. The Global Finance Data Collective (GFDC) stores financial information and other types of client data from large banks, insurance companies, multinational corporations and governmental agencies. After a long climb on a mountain road that leads only to the facility, you arrive at the security booth. Your credentials are checked and checked again by the guard to visually verify that you are the person pictured on your passport and national identification card. You are led down a long corridor with server rooms on each side, secured by combination locks built into the doors. You climb a flight of stairs and are led into an office that is lighted brilliantly by skylights where the GFDC Director of Security, Dr. Monique Batch, greets you. On the far wall you notice a bank of video screens showing different rooms in the facility. At the far end, several screens show different sections of the road up the mountain

Dr. Batch explains once again your mission. As a data security auditor and consultant, it is a dream assignment: The GFDC does not want simply adequate controls, but the best and most effective security that current technologies allow.

`We were hacked twice last year,` Dr. Batch says, `and although only a small number of records were stolen, the bad press impacted our business. Our clients count on us to provide security that is nothing short of impenetrable and to do so quietly. We hope to never make the news again.` She notes that it is also essential that the facility is in compliance with all relevant security regulations and standards.

You have been asked to verify compliance as well as to evaluate all current security controls and security measures, including data encryption methods, authentication controls and the safest methods for transferring data into and out of the facility. As you prepare to begin your analysis, you find yourself considering an intriguing question: Can these people be sure that I am who I say I am?

You are shown to the office made available to you and are provided with system login information, including the name of the wireless network and a wireless key.

Still pondering, you attempt to pull up the facility's wireless network, but no networks appear in the wireless list. When you search for the wireless network by name, however it is readily found.

Why would you recommend that GFC use record encryption rather than disk, file or table encryption?

- A. Record encryption is asymmetric, a stronger control measure.
- B. Record encryption is granular, limiting the damage of potential breaches.
- C. Record encryption involves tag masking, so its metadata cannot be decrypted
- D. Record encryption allows for encryption of personal data only.

Correct Answer: B

🗨️ 👤 **837vq3** 2 years, 9 months ago

In record encryption, records are encrypted one record at a time.

This provides enhanced protection because the protection is more granular; however, record encryption may cause performance issues because encrypting and decrypting data can be time-consuming.

upvoted 2 times

SCENARIO -

It should be the most secure location housing data in all of Europe, if not the world. The Global Finance Data Collective (GFDC) stores financial information and other types of client data from large banks, insurance companies, multinational corporations and governmental agencies. After a long climb on a mountain road that leads only to the facility, you arrive at the security booth. Your credentials are checked and checked again by the guard to visually verify that you are the person pictured on your passport and national identification card. You are led down a long corridor with server rooms on each side, secured by combination locks built into the doors. You climb a flight of stairs and are led into an office that is lighted brilliantly by skylights where the GFDC Director of Security, Dr. Monique Batch, greets you. On the far wall you notice a bank of video screens showing different rooms in the facility. At the far end, several screens show different sections of the road up the mountain

Dr. Batch explains once again your mission. As a data security auditor and consultant, it is a dream assignment: The GFDC does not want simply adequate controls, but the best and most effective security that current technologies allow.

`We were hacked twice last year,` Dr. Batch says, `and although only a small number of records were stolen, the bad press impacted our business. Our clients count on us to provide security that is nothing short of impenetrable and to do so quietly. We hope to never make the news again.` She notes that it is also essential that the facility is in compliance with all relevant security regulations and standards.

You have been asked to verify compliance as well as to evaluate all current security controls and security measures, including data encryption methods, authentication controls and the safest methods for transferring data into and out of the facility. As you prepare to begin your analysis, you find yourself considering an intriguing question: Can these people be sure that I am who I say I am?

You are shown to the office made available to you and are provided with system login information, including the name of the wireless network and a wireless key.

Still pondering, you attempt to pull up the facility's wireless network, but no networks appear in the wireless list. When you search for the wireless network by name, however it is readily found.

What measures can protect client information stored at GFDC?

- A. De-linking of data into client-specific packets.
- B. Cloud-based applications.
- C. Server-side controls.
- D. Data pruning

Correct Answer: A

  **steven2xx** 1 year, 1 month ago
why not C?
upvoted 1 times

SCENARIO -

It should be the most secure location housing data in all of Europe, if not the world. The Global Finance Data Collective (GFDC) stores financial information and other types of client data from large banks, insurance companies, multinational corporations and governmental agencies. After a long climb on a mountain road that leads only to the facility, you arrive at the security booth. Your credentials are checked and checked again by the guard to visually verify that you are the person pictured on your passport and national identification card. You are led down a long corridor with server rooms on each side, secured by combination locks built into the doors. You climb a flight of stairs and are led into an office that is lighted brilliantly by skylights where the GFDC Director of Security, Dr. Monique Batch, greets you. On the far wall you notice a bank of video screens showing different rooms in the facility. At the far end, several screens show different sections of the road up the mountain

Dr. Batch explains once again your mission. As a data security auditor and consultant, it is a dream assignment: The GFDC does not want simply adequate controls, but the best and most effective security that current technologies allow.

`We were hacked twice last year,` Dr. Batch says, `and although only a small number of records were stolen, the bad press impacted our business. Our clients count on us to provide security that is nothing short of impenetrable and to do so quietly. We hope to never make the news again.` She notes that it is also essential that the facility is in compliance with all relevant security regulations and standards.

You have been asked to verify compliance as well as to evaluate all current security controls and security measures, including data encryption methods, authentication controls and the safest methods for transferring data into and out of the facility. As you prepare to begin your analysis, you find yourself considering an intriguing question: Can these people be sure that I am who I say I am?

You are shown to the office made available to you and are provided with system login information, including the name of the wireless network and a wireless key.

Still pondering, you attempt to pull up the facility's wireless network, but no networks appear in the wireless list. When you search for the wireless network by name, however it is readily found.

What type of wireless network does GFDC seem to employ?

- A. A hidden network.
- B. A reluctant network.
- C. A user verified network.
- D. A wireless mesh network.

Correct Answer: A

Reference:

<https://help.gnome.org/users/gnome-help/stable/net-wireless-hidden.html.en>

What must be used in conjunction with disk encryption?

- A. Increased CPU speed.
- B. A strong password.
- C. A digital signature.
- D. Export controls.

Correct Answer: C

Community vote distribution

B (100%)

- SMHcalicut

11 months ago

You can use digital signatures to authenticate data stored on an encrypted disk. For example, you could digitally sign important files or system configurations stored on an encrypted disk. This helps ensure that even if an attacker gains access to the encrypted data, they cannot modify the data without detection.

upvoted 1 times
- rajiabdmjd

1 year, 3 months ago

Strong password

upvoted 1 times
- z80r

1 year, 6 months ago

Selected Answer: B

I confirm, B is the answer

upvoted 3 times
- 837vq3

1 year, 10 months ago

Selected Answer: B

disk encryption would need password

upvoted 3 times
- Sbowo

2 years, 6 months ago

B is the answer because disc encryption is useless without strong password

upvoted 2 times
- ChaBum

2 years, 4 months ago

(full) disk encryption is based on digital certificate and not password

upvoted 1 times
- SamPhil

1 year, 11 months ago

That is incorrect, disk encryption is based on symmetric encryption and not public key cryptography. Digital certificate is a technology that uses public key cryptography.

upvoted 2 times

Which is NOT a way to validate a person's identity?

- A. Swiping a smartcard into an electronic reader.
- B. Using a program that creates random passwords.
- C. Answering a question about "something you know".
- D. Selecting a picture and tracing a unique pattern on it

Correct Answer: B

- Ame123456789

1 year, 4 months ago

I dont really understand D. How can you identify a person by getting him to select a person and do tracing?

upvoted 1 times
- jrhdf84

3 months, 1 week ago

Because the pattern is created by the user. This was the security used on most android smart phones not too long ago.

upvoted 1 times
- rajiabdmjd

1 year, 3 months ago

This is used by Microsoft on Windows device to verify users.

upvoted 1 times

阿泽Vx: est258258

Revocation and reissuing of compromised credentials is impossible for which of the following authentication techniques?

- A. Biometric data.
- B. Picture passwords.
- C. Personal identification number.
- D. Radio frequency identification.

Correct Answer: D

Community vote distribution

A (100%)

  **MutantHeadcase** 1 year ago

Selected Answer: A

Some of the answers on this site are very odd, including this one. Biometric data can be but not radio frequency????
upvoted 1 times

  **ChaBum** 2 years, 4 months ago

Selected Answer: A

Except Biometric data which are part of an individual, it's fully possible to discard and re-issue Picture passwords, PIN or RFID badge
upvoted 4 times

  **187san** 2 years, 7 months ago

A its A
upvoted 4 times

  **837vq3** 2 years, 7 months ago

Selected Answer: A

It is "A". You can't revoke biometric data.
<https://www.ciodive.com/news/you-cant-revoke-your-fingerprint/449088/>
<https://www.pentestpartners.com/security-blog/biometric-revocation-not-an-option/>
upvoted 4 times

  **837vq3** 2 years, 8 months ago

why not "A"?
upvoted 2 times

What is the main function of the Amnesic Incognito Live System or TAILS device?

- A. It allows the user to run a self-contained computer from a USB device.
- B. It accesses systems with a credential that leaves no discernable tracks.
- C. It encrypts data stored on any computer on a network.
- D. It causes a system to suspend its security protocols.

Correct Answer: A

Reference:

<https://www.wired.co.uk/article/tails-operating-software>

Community vote distribution

B (100%)

  **PaigeH7** 4 months ago

Selected Answer: B

The correct answer is B. It accesses systems with a credential that leaves no discernable tracks. TAILS is designed to provide anonymous and private internet usage by running from a USB device without leaving traces on the host system. It routes internet traffic through the Tor network, ensuring privacy and security for users who need to browse or communicate without revealing their identity or leaving digital footprints. TAILS does not suspend security protocols; instead, it enhances security by minimizing exposure and maintaining anonymity.

upvoted 1 times

阿泽Vx: est258258

Which is NOT a drawback to using a biometric recognition system?

- A. It can require more maintenance and support.
- B. It can be more expensive than other systems
- C. It has limited compatibility across systems.
- D. It is difficult for people to use.

Correct Answer: A

Community vote distribution

D (100%)

Ame123456789 1 year, 4 months ago
Should be D. "not a drawback" = not a difficult task, imo.
upvoted 1 times

z80r 1 year, 6 months ago
Selected Answer: D
D it's the right one imho
upvoted 1 times

Sbowo 2 years, 6 months ago
D it is easy to use
upvoted 2 times

187san 2 years, 7 months ago
C
Its not difficult to use
upvoted 2 times

k4d4v4r 2 years, 7 months ago
Selected Answer: D
D is better
upvoted 3 times

阿泽Vx: est258258

What is a main benefit of data aggregation?

- A. It is a good way to perform analysis without needing a statistician.
- B. It applies two or more layers of protection to a single data record.
- C. It allows one to draw valid conclusions from small data samples.
- D. It is a good way to achieve de-identification and unlinkability.

Correct Answer: C

Community vote distribution

D (80%)

C (20%)

- PaigeH7** 4 months ago

Selected Answer: C

he correct answer is C. It allows one to draw valid conclusions from small data samples. Data aggregation simplifies the complexity of large datasets, making it easier to analyze and interpret. By summarizing data, organizations can identify trends and patterns, leading to informed decision-making. While it doesn't directly eliminate the need for statisticians, it enhances efficiency and provides meaningful insights from aggregated data

upvoted 1 times
- z80r** 1 year, 6 months ago

Selected Answer: D

I think D is the correct answer

upvoted 2 times
- 837vq3** 1 year, 10 months ago

When data is aggregated, information is expressed in a summary form that reduces the value and quality of the data as well as the connection between the data and the individual it belongs to. While using aggregation may reduce privacy concerns, it is often still possible to determine individual values from aggregated statistics.

upvoted 1 times
- Magim1920** 2 years ago

Selected Answer: D

Aggregation is applied to make data less identifiable

upvoted 1 times
- 187san** 2 years, 7 months ago

Selected Answer: D

D is the answer

upvoted 1 times
- ChaBum** 2 years, 4 months ago

Data aggregation is a process in which data is gathered and represented in a summary form, for purposes including statistical analysis.

upvoted 1 times

Under the Family Educational Rights and Privacy Act (FERPA), releasing personally identifiable information from a student's educational record requires written permission from the parent or eligible student in order for information to be?

- A. Released to a prospective employer.
- B. Released to schools to which a student is transferring.
- C. Released to specific individuals for audit or evaluation purposes.
- D. Released in response to a judicial order or lawfully ordered subpoena.

Correct Answer: C

Reference:

<https://www2.ed.gov/policy/gen/guid/fpco/ferpa/index.html>

Community vote distribution

A (100%)

- rajiabdmjd

1 year, 3 months ago

Selected Answer: A

A. Released to a prospective employer.

upvoted 1 times
- rajiabdmjd

1 year, 3 months ago

Selected Answer: A

The answer is A

upvoted 1 times
- rajiabdmjd

1 year, 3 months ago

Generally, schools must have written permission from the parent or eligible student in order to release any information from a student's educational record. However, FERPA allows schools to disclose those records, without consent, to the following parties or under the following conditions (34 CFR § 99.31):

School officials with legitimate educational interest;

Other schools to which a student is transferring;

Specified officials for audit or evaluation purposes;

Appropriate parties in connection with financial aid to a student;

Organizations conducting certain studies for or on behalf of the school;

Accrediting organizations;

To comply with a judicial order or lawfully issued subpoena;

Appropriate officials in cases of health and safety emergencies; and

State and local authorities, within a juvenile justice system, pursuant to specific State law.

upvoted 1 times
- Sara_sw

1 year, 8 months ago

Selected Answer: A

A is correct since all other options are listed in the reference as NOT requiring consent

upvoted 1 times
- 187san

2 years, 7 months ago

A is the answer

upvoted 2 times
- 187san

2 years, 7 months ago

D , To comply with a judicial order or lawfully issued subpoena;

Check reference link

upvoted 1 times
- k4d4v4r

2 years, 8 months ago

Generally, schools must have written permission from the parent or eligible student in order to release any information from a student's educational record. However, FERPA allows schools to disclose those records, without consent, to the following parties or under the following conditions (34 CFR § 99.31):

School officials with legitimate educational interest;

Other schools to which a student is transferring;

Specified officials for audit or evaluation purposes;

Appropriate parties in connection with financial aid to a student;

Organizations conducting certain studies for or on behalf of the school;

Accrediting organizations;

To comply with a judicial order or lawfully issued subpoena;

Appropriate officials in cases of health and safety emergencies; and

State and local authorities, within a juvenile justice system, pursuant to specific State law.

阿泽Vx：est258258

After committing to a Privacy by Design program, which activity should take place first?

- A. Create a privacy standard that applies to all projects and services.
- B. Establish a retention policy for all data being collected.
- C. Implement easy to use privacy settings for users.
- D. Perform privacy reviews on new projects.

Correct Answer: B

Community vote distribution

A (83%)D (17%)

- rajiabdmjd** 1 year, 3 months ago

Selected Answer: A

A is correct
upvoted 1 times
- rajiabdmjd** 1 year, 3 months ago

A is correct
upvoted 1 times
- z80r** 1 year, 6 months ago

Selected Answer: A

I think A
upvoted 1 times
- Magim1920** 2 years ago

Selected Answer: D

Performing privacy reviews on new projects constitutes performing DPIAs on new projects, which is a critical element of privacy by design - identifying privacy risks and their impact is the only way to implement safeguards in an early stadium.
upvoted 1 times
- Sbowo** 2 years, 6 months ago

Create a privacy standard, page 130 book Privacy in Technology
upvoted 2 times
- 187san** 2 years, 7 months ago

A
is the answer
upvoted 1 times
- k4d4v4r** 2 years, 7 months ago

The problem with A is the word "standard" which are commonly related to ISO stuff.
You won't want to implement the same standard for everything as you should consider the aspects of the projects from their conception.
upvoted 2 times
- k4d4v4r** 2 years, 7 months ago

I agree with A.
B is factible but not the first thing you would do.
upvoted 1 times
- 837vq3** 2 years, 7 months ago

Selected Answer: A

Perhaps "A"?
Privacy by Design principle includes:
1.Proactive, not reactive – preventative, not remedial
2.Privacy as the default setting
3.Privacy embedded into design
4.Fully functionality
5.End-to-end security – full life cycle protection
6.Visibility and transparency
7.Respect for user privacy
upvoted 3 times
- k4d4v4r** 2 years, 8 months ago

Why B ?

upvoted 2 times

Question #52

Topic 1

When releasing aggregates, what must be performed to magnitude data to ensure privacy?

- A. Value swapping.
- B. Noise addition.
- C. Basic rounding.
- D. Top coding.

Correct Answer: *B*

Reference:

<https://academic.oup.com/idpl/article/8/1/29/4930711>



837vq3 2 years, 9 months ago

One way to prevent reverse engineering is to “blur” the data points by using noise addition through differential privacy. The goal is to ensure that the aggregated data is still useful, while also making it nonspecific enough to avoid revealing the underlying identifiers.

upvoted 1 times

阿泽Vx: est258258

What term describes two re-identifiable data sets that both come from the same unidentified individual?

- A. Pseudonymous data.
- B. Anonymous data.
- C. Aggregated data.
- D. Imprecise data.

Correct Answer: B

Reference:
<https://ico.org.uk/media/1061/anonymisation-code.pdf>

Community vote distribution

A (86%)14%

forest_gump33 9 months, 2 weeks ago

Selected Answer: C

If it is re-identifiable, it is not anonymous.
upvoted 1 times

z80r 1 year, 6 months ago

Selected Answer: A

A is correct
upvoted 1 times

Magim1920 2 years ago

Selected Answer: A

Anonymity is the polar opposite of re-identifiability
upvoted 1 times

187san 2 years, 7 months ago

Selected Answer: A

A is the answer
upvoted 2 times

187san 2 years, 7 months ago

Selected Answer: A

A for sure required by GDPR also
upvoted 1 times

k4d4v4r 2 years, 7 months ago

There this example for A also:

HIPAA also provides a specific example of pseudonymity. A de-identified dataset may include:

A code or other means of record identification to allow information de-identified under this section to be re-identified by the covered entity, provided that: (1) the code or other means of record identification is not derived from or related to information about the individual and is not otherwise capable of being translated so as to identify the individual; and (2) the covered entity does not use or disclose the code or other means of record identification for any other purpose, and does not disclose the mechanism for re-identification.
upvoted 1 times

k4d4v4r 2 years, 7 months ago

Selected Answer: A

<https://en.wikipedia.org/wiki/Pseudonymization>
upvoted 1 times

837vq3 2 years, 7 months ago

But the wiki says "GDPR Data Protection by Design and by Default principles as embodied in pseudonymization require protection of both direct and indirect identifiers so that personal data is NOT cross-referenceable (or re-identifiable) via the "Mosaic Effect"
upvoted 1 times

837vq3 2 years, 9 months ago

I think its "d". "Labels: Labels are characteristics that point to an individual. These can be precise, as in a name, or imprecise, such as with an attribute, depending on the context. Labeling people based on an attribute, instead of by name, may make them easier to identify in context. For instance, a man in a business suit may not be identifiable within a large

corporate office, but the same man in a business suit may be easily identifiable among sunbathers on a beach."
upvoted 1 times

Question #54

Topic 1

Which of the following most embodies the principle of Data Protection by Default?

- A. A messaging app for high school students that uses HTTPS to communicate with the server.
- B. An electronic teddy bear with built-in voice recognition that only responds to its owner's voice.
- C. An internet forum for victims of domestic violence that allows anonymous posts without registration.
- D. A website that has an opt-in form for marketing emails when registering to download a whitepaper.

Correct Answer: D

Community vote distribution
C (67%)

A (33%)

Stants 4 months, 3 weeks ago

You've provided a detailed and thoughtful analysis. I agree with your conclusion that the principle of Data Protection by Default is most embodied by Option B: An electronic teddy bear with built-in voice recognition that only responds to its owner's voice.

This option minimizes data collection and processing to the bare minimum needed for its intended function, demonstrating a stronger alignment with Data Protection by Default compared to the other options. It aligns with the purpose of the product and ensures that only necessary data (the owner's voice) is collected and processed.

Your explanations of the other options are also accurate. Allowing anonymous posts (Option C), using HTTPS in a messaging app (Option A), and having an opt-in for marketing emails (Option D) are all important components of data protection, but they do not directly embody the principle of Data Protection by Default.

upvoted 1 times

rajiabdmjd 1 year, 3 months ago

Selected Answer: C

Answer is c. Data mitigation by allowing anonymous post
upvoted 1 times

z80r 1 year, 6 months ago

Selected Answer: C

Imho is C
upvoted 1 times

Magim1920 2 years ago

Selected Answer: A

D is privacy by default, not data protection, and so is C. B is vague, but between B and A, A seems the stronger answer and clearly constitutes data protection by default, by opting to use the more secure HTTPS over HTTP

upvoted 1 times

Aadhaar is a unique-identity number of 12 digits issued to all Indian residents based on their biometric and demographic data. The data is collected by the Unique Identification Authority of India. The Aadhaar database contains the Aadhaar number, name, date of birth, gender and address of over 1 billion individuals.

Which of the following datasets derived from that data would be considered the most de-identified?

- A. A count of the years of birth and hash of the person's gender.
- B. A count of the month of birth and hash of the person's first name.
- C. A count of the day of birth and hash of the person's first initial of their first name.
- D. Account of the century of birth and hash of the last 3 digits of the person's Aadhaar number.

Correct Answer: C

Community vote distribution

A (100%)

  **Stants** 5 months ago

The correct answer is D. A count of the century of birth and hash of the last 3 digits of the person's Aadhaar number. This option provides the least amount of identifiable information. The century of birth is a very broad category, and hashing the last 3 digits of the Aadhaar number does not reveal much information about the individual. The other options provide more specific information, such as the year, month, or day of birth, and more identifiable aspects of the person's name or gender, which could potentially be used to re-identify the individual. Therefore, option D is the most de-identified dataset.

upvoted 1 times

  **haha2345** 1 year, 3 months ago

Selected Answer: A

I think is A.
Gender and count of year most de-identified.

upvoted 1 times

What has been identified as a significant privacy concern with chatbots?

- A. Most chatbot providers do not agree to code audits
- B. Chatbots can easily verify the identity of the contact.
- C. Users' conversations with chatbots are not encrypted in transit.
- D. Chatbot technology providers may be able to read chatbot conversations with users.

Correct Answer: D

Reference:
<https://resources.infosecinstitute.com/privacy-concerns-emotional-chatbots/>

What is the term for information provided to a social network by a member?

- A. Profile data.
- B. Declared data.
- C. Personal choice data.
- D. Identifier information.

Correct Answer: A

Community vote distribution

B (100%)

-   **Magim1920** 2 years ago

Selected Answer: B

Definitely B, declared data.

upvoted 1 times
-   **ChaBum** 2 years, 4 months ago

Selected Answer: B

Here is the definition of Declared Data from iapp: Personal information that is directly given to a social network or other website by a user.

Associated term(s): Consent

upvoted 4 times
-   **Sbowo** 2 years, 6 months ago

Declared data is the answer

upvoted 2 times

阿泽Vx: est258258

What tactic does pharming use to achieve its goal?

- A. It modifies the user's Hosts file.
- B. It encrypts files on a user's computer.
- C. It creates a false display advertisement.
- D. It generates a malicious instant message.

Correct Answer: C

Reference:
<https://inspiredelearning.com/blog/phishing-vs-pharming-whats-difference/>

Community vote distribution

A (100%)

- [Removed]** 10 months, 3 weeks ago

Selected Answer: A

Should be A
upvoted 1 times
- k4d4v4r** 2 years, 7 months ago

A and C are both correct
upvoted 1 times
- 837vq3** 2 years, 7 months ago

Yes, but the question is more focused on how it is achieved - which is "A". The "C" is the outcome.
upvoted 1 times
- ChaBum** 2 years, 4 months ago

A is not necessary correct, pharming is action of redirecting to a website controlled by the hacker. The mean to achieve that goal can be tampering with the host file of the victime computer, but it can also be DNS poisoning, or much more easier URL hijacking in a phising email
upvoted 1 times
- sirpuzee** 2 years, 9 months ago

The correct answer is A. Pharming redirects a valid internet request to a malicious site by modifying a hosts file and there is not much individuals can do about it except try to use up to date browsers. IAPP - Privacy in Technology, page 150 of the 2014 official publication
upvoted 3 times
- Stants** 5 months ago

The correct answer is A. It modifies the user's Hosts file. Pharming is a cyber attack intended to redirect a website's traffic to another, fake site. In order to achieve this, attackers often modify the user's Hosts file, which is used to look up hostnames of sites on the internet. By changing the Hosts file, the attacker can control which site the user ends up at when they type in a particular URL, leading them to a malicious site instead of the one they intended to visit.
upvoted 1 times
- 837vq3** 2 years, 9 months ago

I think the correct answer is "A". "Pharming is the redirection of a Web site's actual or intended traffic to a malicious site. Redirection is often accomplished in one of two ways: modification of host files or by taking advantage of weaknesses in DNS services.
<https://www.techrepublic.com/blog/it-security/hosts-file-pharming-and-other-botnet-recruiting-methods/>
upvoted 3 times

All of the following can be indications of a ransomware attack EXCEPT?

- A. The inability to access certain files.
- B. An increased amount of spam email in an individual's inbox.
- C. An increase in activity of the CPU of a computer for no apparent reason.
- D. The detection of suspicious network communications between the ransomware and the attacker's command and control servers.

Correct Answer: B

You are a wine collector who uses the web to do research about your hobby. You navigate to a news site and an ad for wine pops up. What kind of advertising is this?

- A. Remnant.
- B. Behavioral.
- C. Contextual.
- D. Demographic.

Correct Answer: B

Reference:

<https://neilpatel.com/blog/behavioral-advertising/>

Community vote distribution

B (67%)

C (33%)

-   **rajiabdmjd** 1 year, 3 months ago

Selected Answer: B

The type of advertising in this scenario is Behavioral advertising.

Behavioral advertising is a type of online advertising that targets users based on their online behavior, such as their browsing history, search queries, and other actions taken online. It involves the use of cookies and other tracking technologies to collect data on users' behavior and interests, and then deliver targeted ads to them.

In this scenario, the ad for wine that popped up on the news site was likely delivered based on the user's browsing history and search queries related to wine collecting, indicating that the advertising was behaviorally targeted to the user's interests and online behavior.

upvoted 1 times
-   **rajiabdmjd** 1 year, 3 months ago

Selected Answer: B

behaioural sorry not c

upvoted 1 times
-   **rajiabdmjd** 1 year, 3 months ago

Selected Answer: C

Contextual advertising is a type of online advertising that displays ads that are relevant to the content of the web page being viewed. In this scenario, the news site content is likely related to wine, which triggers the display of a wine ad. The ad is not based on the user's browsing history or demographic information, but rather on the context of the web page being viewed

upvoted 1 times
-   **rajiabdmjd** 1 year, 3 months ago

Contextual

upvoted 1 times

What is the main reason the Do Not Track (DNT) header is not acknowledged by more companies?

- A. Most web browsers incorporate the DNT feature.
- B. The financial penalties for violating DNT guidelines are too high.
- C. There is a lack of consensus about what the DNT header should mean.
- D. It has been difficult to solve the technological challenges surrounding DNT.

Correct Answer: C

Reference:

https://en.wikipedia.org/wiki/Do_Not_Track

Why is first-party web tracking very difficult to prevent?

- A. The available tools to block tracking would break most sites' functionality.
- B. Consumers enjoy the many benefits they receive from targeted advertising.
- C. Regulatory frameworks are not concerned with web tracking.
- D. Most browsers do not support automatic blocking.

Correct Answer: D

Reference:

<https://www.opentracker.net/article/third-party-cookies-vs-first-party-cookies>

Community vote distribution

A (100%)

  **k4d4v4r**

Highly Voted 

 2 years, 7 months ago

Selected Answer: A

You basically can't login without the 1st party ones

upvoted 6 times

  **Magim1920**

Most Recent 

 2 years ago

Selected Answer: A

Most browsers DO support autimatic blocking. They also include options to add exceptions, because doing so ever so often breaks site functionality. Answer should be A.

upvoted 3 times

  **Sbowo** 2 years, 6 months ago

I think the answer is C

upvoted 1 times

During a transport layer security (TLS) session, what happens immediately after the web browser creates a random PreMasterSecret?

- A. The server decrypts the PremasterSecret.
- B. The web browser opens a TLS connection to the PremasterSecret.
- C. The web browser encrypts the PremasterSecret with the server's public key.
- D. The server and client use the same algorithm to convert the PremasterSecret into an encryption key.

Correct Answer: C

Reference:

[https://books.google.com.pk/books?id=OaXise4B-p8C&pg=PA175&lpg=PA175&dq=iapp+During+a+transport+layer+security+\(TLS\)+session,+what+happens+immediately+after+the+web+browser+creates+a+random+PreMasterSecret&source=bl&ots=zR0RCfnx3c&sig=ACfU3U0bTOeOfPfcoq_Y95SZs6imKKilug&hl=en&sa=X&ved=2ahUKEwjscDHpcbnAhUJuRoKHU5iC9cQ6AEwCnoECAkQAQ#v=onepage&q=iapp%20During%20a%20transport%20layer%20security%20\(TLS\)%20session%2C%20what%20happens%20immediately%20after%20the%20web%20browser%20creates%20a%20random%20PreMasterSecret&f=false](https://books.google.com.pk/books?id=OaXise4B-p8C&pg=PA175&lpg=PA175&dq=iapp+During+a+transport+layer+security+(TLS)+session,+what+happens+immediately+after+the+web+browser+creates+a+random+PreMasterSecret&source=bl&ots=zR0RCfnx3c&sig=ACfU3U0bTOeOfPfcoq_Y95SZs6imKKilug&hl=en&sa=X&ved=2ahUKEwjscDHpcbnAhUJuRoKHU5iC9cQ6AEwCnoECAkQAQ#v=onepage&q=iapp%20During%20a%20transport%20layer%20security%20(TLS)%20session%2C%20what%20happens%20immediately%20after%20the%20web%20browser%20creates%20a%20random%20PreMasterSecret&f=false)

What is the main benefit of using a private cloud?

- A. The ability to use a backup system for personal files.
- B. The ability to outsource data support to a third party.
- C. The ability to restrict data access to employees and contractors.
- D. The ability to cut costs for storing, maintaining, and accessing data.

Correct Answer: C

SCENARIO -

You have just been hired by Ancillary.com, a seller of accessories for everything under the sun, including waterproof stickers for pool floats and decorative bands and cases for sunglasses. The company sells cell phone cases, e-cigarette cases, wine spouts, hanging air fresheners for homes and automobiles, book ends, kitchen implements, visors and shields for computer screens, passport holders, gardening tools and lawn ornaments, and catalogs full of health and beauty products. The list seems endless. As the CEO likes to say, Ancillary offers, without doubt, the widest assortment of low-price consumer products from a single company anywhere.

Ancillary's operations are similarly diverse. The company originated with a team of sales consultants selling home and beauty products at small parties in the homes of customers, and this base business is still thriving. However, the company now sells online through retail sites designated for industries and demographics, sites such as `My Cool Ride` for automobile-related products or `Zoomer` for gear aimed toward young adults. The company organization includes a plethora of divisions, units and outrigger operations, as Ancillary has been built along a decentered model rewarding individual initiative and flexibility, while also acquiring key assets. The retail sites seem to all function differently, and you wonder about their compliance with regulations and industry standards. Providing tech support to these sites is also a challenge, partly due to a variety of logins and authentication protocols.

You have been asked to lead three important new projects at Ancillary:

The first is the personal data management and security component of a multi-faceted initiative to unify the company's culture. For this project, you are considering using a series of third- party servers to provide company data and approved applications to employees.

The second project involves providing point of sales technology for the home sales force, allowing them to move beyond paper checks and manual credit card imprinting.

Finally, you are charged with developing privacy protections for a single web store housing all the company's product lines as well as products from affiliates. This new omnibus site will be known, aptly, as `Under the Sun.` The Director of Marketing wants the site not only to sell Ancillary's products, but to link to additional products from other retailers through paid advertisements. You need to brief the executive team of security concerns posed by this approach.

If you are asked to advise on privacy concerns regarding paid advertisements, which is the most important aspect to cover?

- A. Unseen web beacons that combine information on multiple users.
- B. Latent keys that trigger malware when an advertisement is selected.
- C. Personal information collected by cookies linked to the advertising network.
- D. Sensitive information from Structured Query Language (SQL) commands that may be exposed.

Correct Answer: C

SCENARIO -

You have just been hired by Ancillary.com, a seller of accessories for everything under the sun, including waterproof stickers for pool floats and decorative bands and cases for sunglasses. The company sells cell phone cases, e-cigarette cases, wine spouts, hanging air fresheners for homes and automobiles, book ends, kitchen implements, visors and shields for computer screens, passport holders, gardening tools and lawn ornaments, and catalogs full of health and beauty products. The list seems endless. As the CEO likes to say, Ancillary offers, without doubt, the widest assortment of low-price consumer products from a single company anywhere.

Ancillary's operations are similarly diverse. The company originated with a team of sales consultants selling home and beauty products at small parties in the homes of customers, and this base business is still thriving. However, the company now sells online through retail sites designated for industries and demographics, sites such as `My Cool Ride` for automobile-related products or `Zoomer` for gear aimed toward young adults. The company organization includes a plethora of divisions, units and outrigger operations, as Ancillary has been built along a decentered model rewarding individual initiative and flexibility, while also acquiring key assets. The retail sites seem to all function differently, and you wonder about their compliance with regulations and industry standards. Providing tech support to these sites is also a challenge, partly due to a variety of logins and authentication protocols.

You have been asked to lead three important new projects at Ancillary:

The first is the personal data management and security component of a multi-faceted initiative to unify the company's culture. For this project, you are considering using a series of third- party servers to provide company data and approved applications to employees.

The second project involves providing point of sales technology for the home sales force, allowing them to move beyond paper checks and manual credit card imprinting.

Finally, you are charged with developing privacy protections for a single web store housing all the company's product lines as well as products from affiliates. This new omnibus site will be known, aptly, as `Under the Sun.` The Director of Marketing wants the site not only to sell Ancillary's products, but to link to additional products from other retailers through paid advertisements. You need to brief the executive team of security concerns posed by this approach.

What technology is under consideration in the first project in this scenario?

- A. Server driven controls.
- B. Cloud computing
- C. Data on demand
- D. MAC filtering

Correct Answer: A

Community vote distribution

B (100%)

- 👤 steven2xx 1 year, 1 month ago

Selected Answer: B

我也觉得是B

upvoted 1 times

👤 rajiabdmjd 1 year, 3 months ago

Selected Answer: B

B.. Cloud computing

upvoted 2 times

👤 Ame123456789 1 year, 4 months ago

I would agree its cloud computing too.

upvoted 2 times

👤 187san 2 years, 7 months ago

B is the answer

upvoted 3 times

👤 k4d4v4r 2 years, 8 months ago

Why not B?

upvoted 3 times

题库来源阿泽Vx：est258258

SCENARIO -

You have just been hired by Ancillary.com, a seller of accessories for everything under the sun, including waterproof stickers for pool floats and decorative bands and cases for sunglasses. The company sells cell phone cases, e-cigarette cases, wine spouts, hanging air fresheners for homes and automobiles, book ends, kitchen implements, visors and shields for computer screens, passport holders, gardening tools and lawn ornaments, and catalogs full of health and beauty products. The list seems endless. As the CEO likes to say, Ancillary offers, without doubt, the widest assortment of low-price consumer products from a single company anywhere.

Ancillary's operations are similarly diverse. The company originated with a team of sales consultants selling home and beauty products at small parties in the homes of customers, and this base business is still thriving. However, the company now sells online through retail sites designated for industries and demographics, sites such as `My Cool Ride" for automobile-related products or `Zoomer` for gear aimed toward young adults. The company organization includes a plethora of divisions, units and outrigger operations, as Ancillary has been built along a decentered model rewarding individual initiative and flexibility, while also acquiring key assets. The retail sites seem to all function differently, and you wonder about their compliance with regulations and industry standards. Providing tech support to these sites is also a challenge, partly due to a variety of logins and authentication protocols.

You have been asked to lead three important new projects at Ancillary:

The first is the personal data management and security component of a multi-faceted initiative to unify the company's culture. For this project, you are considering using a series of third- party servers to provide company data and approved applications to employees.

The second project involves providing point of sales technology for the home sales force, allowing them to move beyond paper checks and manual credit card imprinting.

Finally, you are charged with developing privacy protections for a single web store housing all the company's product lines as well as products from affiliates. This new omnibus site will be known, aptly, as `Under the Sun.` The Director of Marketing wants the site not only to sell Ancillary's products, but to link to additional products from other retailers through paid advertisements. You need to brief the executive team of security concerns posed by this approach.

Which should be used to allow the home sales force to accept payments using smartphones?

- A. Field transfer protocol.
- B. Cross-current translation.
- C. Near-field communication
- D. Radio Frequency Identification

Correct Answer: C

What is the best way to protect privacy on a geographic information system?

- A. Limiting the data provided to the system.
- B. Using a wireless encryption protocol.
- C. Scrambling location information.
- D. Using a firewall.

Correct Answer: A

Reference:
https://www.researchgate.net/publication/2873114_Protecting_Personal_Privacy_in_Using_Geographic_Information_Systems

Community vote distribution

C (100%)

 **PaigeH7** 4 months ago

Selected Answer: C

This method involves obfuscating or altering location data to prevent easy identification. Techniques include adding noise, aggregating data, or using differential privacy. Scrambling enhances privacy while maintaining data utility.

upvoted 1 times

 **Stants** 5 months ago

The correct answer is C. Scrambling location information. Geographic Information Systems (GIS) often deal with sensitive location data. Scrambling, or obfuscating, this data can help protect individual privacy. This could involve techniques like "geo-masking" or "geo-hashing" which alter the precise location data to protect privacy while still providing useful information for spatial analysis. Other options like limiting data, using encryption, or firewalls can also contribute to security, but they do not directly address the privacy concerns associated with the specific nature of geographic data.

upvoted 1 times

In the realm of artificial intelligence, how has deep learning enabled greater implementation of machine learning?

- A. By using hand-coded classifiers like edge detection filters so that a program can identify where an object starts and stops.
- B. By increasing the size of neural networks and running massive amounts of data through the network to train it.
- C. By using algorithmic approaches such as decision tree learning and inductive logic programming.
- D. By hand coding software routines with a specific set of instructions to accomplish a task.

Correct Answer: B

Reference:
<https://towardsdatascience.com/notes-on-artificial-intelligence-ai-machine-learning-ml-and-deep-learning-dl-for-56e51a2071c2>

Which of the following is an example of the privacy risks associated with the Internet of Things (IoT)?

- A. A group of hackers infiltrate a power grid and cause a major blackout.
- B. An insurance company raises a person's rates based on driving habits gathered from a connected car.
- C. A website stores a cookie on a user's hard drive so the website can recognize the user on subsequent visits.
- D. A water district fines an individual after a meter reading reveals excess water use during drought conditions.

Correct Answer: B

- Ame123456789

1 year, 4 months ago

if B is correct, so is D. Both are cases whereby the original intent (B - safety, and D - water consumption monitoring) have been abused.

upvoted 1 times
- z80r

1 year, 6 months ago

I think B is correct (privacy implications)

upvoted 1 times
- vicks888

2 years, 7 months ago

2. is Vehicular Automation.

upvoted 1 times
- k4d4v4r

2 years, 7 months ago

Power grid is OT (Operational technology)
Connected cars are IoT (Internet of things or things connected to the internet)

upvoted 2 times
- 837vq3

2 years, 9 months ago

infiltrating a power grid is causing a major blackout - there is no risk to privacy mentioned. This is affecting the availability of the system. What ar the privacy implication?

upvoted 1 times
- sirpuzee

2 years, 9 months ago

The correct answer is A. Anything that is connected to the Internet or the cellular phone network can possibly be hacked by an intruder. IAPP Privacy in Technology publication, page 202.

upvoted 1 times
- 837vq3

2 years, 8 months ago

Isn't the same true for a sensor in the car?

upvoted 1 times
- pipzz

2 years, 10 months ago

The answer is A.

upvoted 2 times

How can a hacker gain control of a smartphone to perform remote audio and video surveillance?

- A. By performing cross-site scripting.
- B. By installing a roving bug on the phone.
- C. By manipulating geographic information systems.
- D. By accessing a phone's global positioning system satellite signal.

Correct Answer: B

🗨️ 👤 **rajiabdmjd** 1 year, 3 months ago

A hacker can gain control of a smartphone to perform remote audio and video surveillance by installing a roving bug on the phone. A roving bug is a software application that can be installed on a mobile device without the user's knowledge, which allows an attacker to activate the phone's microphone and camera and listen in on conversations and capture video footage. The attacker can remotely control the bug, turning it on and off, and even adjust the audio and video settings. This type of attack can be very difficult to detect and can compromise a user's privacy and security.

upvoted 1 times

🗨️ 👤 **Ame123456789** 1 year, 4 months ago

Ive done many google searches - roving bug does not activate video recording, only voice recording .

upvoted 1 times

🗨️ 👤 **rajiabdmjd** 1 year, 3 months ago

If it can access audio then what's stopping it from accessing video ?

upvoted 1 times

🗨️ 👤 **Magim1920** 2 years ago

Theoretically, this could be achieved by cross site scripting, because that is just the method of delivering the payload.

upvoted 1 times

阿泽Vx: est258258

SCENARIO -

Clean-Q is a company that offers house-hold and office cleaning services. The company receives requests from consumers via their website and telephone, to book cleaning services. Based on the type and size of service, Clean-Q then contracts individuals that are registered on its resource database - currently managed in-house by Clean-Q IT Support. Because of Clean-Q's business model, resources are contracted as needed instead of permanently employed.

The table below indicates some of the personal information Clean-Q requires as part of its business operations:

Category	Types of Personal Information
Customers	Name, address (location), contact information, billing information
Resources (contracted)	Name, contact information, banking details, address

Clean-Q has an internal employee base of about 30 people. A recent privacy compliance exercise has been conducted to align employee data management and human resource functions with applicable data protection regulation. Therefore, the Clean-Q permanent employee base is not included as part of this scenario.

With an increase in construction work and housing developments, Clean-Q has had an influx of requests for cleaning services. The demand has overwhelmed

Clean-Q's traditional supply and demand system that has caused some overlapping bookings.

In a business strategy session held by senior management recently, Clear-Q invited vendors to present potential solutions to their current operational issues.

These vendors included Application developers and cloud solution providers, presenting their proposed solutions and platforms.

The Managing Director opted to initiate the process to integrate Clean-Q's operations with a cloud solution (LeadOps) that will provide the following solution one single online platform: A web interface that Clean-Q accesses for the purposes of resource and customer management. This would entail uploading resource and customer information.

- ⇒ A customer facing web interface that enables customers to register, manage and submit cleaning service requests online.
- ⇒ A resource facing web interface that enables resources to apply and manage their assigned jobs.
- ⇒ An online payment facility for customers to pay for services.

If Clean-Q were to utilize LeadOps' services, what is a contract clause that may be included in the agreement entered into with LeadOps?

- A. A provision that holds LeadOps liable for a data breach involving Clean-Q's information.
- B. A provision prescribing technical and organizational controls that LeadOps must implement.
- C. A provision that requires LeadOps to notify Clean-Q of any suspected breaches of information that involves customer or resource information managed on behalf of Clean-Q.
- D. A provision that allows Clean-Q to conduct audits of LeadOps' information processing and information security environment, at LeadOps' cost and at any time that Clean-Q requires.

Correct Answer: D

Community vote distribution

C (71%)

B (29%)

- PaigeH7

4 months ago

Selected Answer: C

Clean Q is the Controller , Lead OPS operator

upvoted 1 times

Ame123456789

1 year, 4 months ago

Poor question scribing, I feel.

A. A provision that holds LeadOps liable for a data breach involving Clean-Q's information.
is probably true. Contracts is about liability and indemities. So "liable" word is used with a different meaning.

B. A provision prescribing technical and organizational controls that LeadOps must implement.
not right - DC may not be in the position to scribe.

C. A provision that requires LeadOps to notify Clean-Q of any suspected breaches of information that involves customer or resource information managed on behalf of Clean-Q.
maybe right - the "on behalf of Clean Q" is just saying that LeadOps is managing the data on behalf. not reporting to regulator on behalf.
- 题库来源阿泽Vx：est258258

D. A provision that allows Clean-Q to conduct audits of LeadOps' information processing and information security environment, at LeadOps' cost and at any time that Clean-Q requires.
in reality, this clause is common, but "not any time that Clean Q requires" - impractical.

So C is likely to be the right answer
upvoted 1 times

  **pipzz** 2 years ago

Selected Answer: C

Best answer. The GDPR requires a processor to notify a controller if it becomes aware of a breach of personal data it is processing on behalf of the controller. The governing legal document may provide for a stricter notification requirement, including notification if the processor even merely "suspects" a breach has occurred.
upvoted 1 times

  **Magim1920** 2 years ago

It's almost as if the question is wrong and should read "What is NOT a contractual clause.. .." All of these are commonly found in SSCs in European Union countries, except A - you cannot outsource your liability as data controller to a processor.
upvoted 2 times

  **ChaBum** 2 years, 4 months ago

Selected Answer: B

B, the TOMs Technical and Organisational Measures (GDPR Art 32 & Recital 78),
upvoted 2 times

  **k4d4v4r** 2 years, 7 months ago

Selected Answer: C

C is the best answer.
Never saw a D situation in real life scenarios.
upvoted 3 times

  **ChaBum** 2 years, 4 months ago

There is no reason to inform an external party about a SUSPECTED breach
upvoted 1 times

  **837vq3** 2 years, 9 months ago

The part that I do not like in "D" is this: "at LeadOps' cost and at any time that Clean-Q requires". As far as I know, audits are not performed at the expense of the vendor. If the client wants to audit a vendor, the client pays for it, correct?
upvoted 2 times

  **ChaBum** 2 years, 4 months ago

It could be part of the contract to have the vendor pass through audits on regular basis. But those audits are conducted by third party companies and not the client. If a client wants to audit a vendor, the vendor will normally charge the client for the resources provided to conduct the audit. What I find non-realistic is the "at any time that Clean-Q requires", the audit should happen at a time which is convenient for both parties.
upvoted 1 times

SCENARIO -

Clean-Q is a company that offers house-hold and office cleaning services. The company receives requests from consumers via their website and telephone, to book cleaning services. Based on the type and size of service, Clean-Q then contracts individuals that are registered on its resource database - currently managed in-house by Clean-Q IT Support. Because of Clean-Q's business model, resources are contracted as needed instead of permanently employed.

The table below indicates some of the personal information Clean-Q requires as part of its business operations:

Category	Types of Personal Information
Customers	Name, address (location), contact information, billing information
Resources (contracted)	Name, contact information, banking details, address

Clean-Q has an internal employee base of about 30 people. A recent privacy compliance exercise has been conducted to align employee data management and human resource functions with applicable data protection regulation. Therefore, the Clean-Q permanent employee base is not included as part of this scenario.

With an increase in construction work and housing developments, Clean-Q has had an influx of requests for cleaning services. The demand has overwhelmed

Clean-Q's traditional supply and demand system that has caused some overlapping bookings.

In a business strategy session held by senior management recently, Clear-Q invited vendors to present potential solutions to their current operational issues.

These vendors included Application developers and cloud solution providers, presenting their proposed solutions and platforms.

The Managing Director opted to initiate the process to integrate Clean-Q's operations with a cloud solution (LeadOps) that will provide the following solution one single online platform: A web interface that Clean-Q accesses for the purposes of resource and customer management. This would entail uploading resource and customer information.

- ⇒ A customer facing web interface that enables customers to register, manage and submit cleaning service requests online.
- ⇒ A resource facing web interface that enables resources to apply and manage their assigned jobs.
- ⇒ An online payment facility for customers to pay for services.

Considering that LeadOps will host/process personal information on behalf of Clean-Q remotely, what is an appropriate next step for Clean-Q senior management to assess LeadOps' appropriateness?

- A. Nothing at this stage as the Managing Director has made a decision.
- B. Determine if any Clean-Q competitors currently use LeadOps as a solution.
- C. Obtain a legal opinion from an external law firm on contracts management.
- D. Involve the Information Security team to understand in more detail the types of services and solutions LeadOps is proposing.

Correct Answer: D

SCENARIO -

Clean-Q is a company that offers house-hold and office cleaning services. The company receives requests from consumers via their website and telephone, to book cleaning services. Based on the type and size of service, Clean-Q then contracts individuals that are registered on its resource database - currently managed in-house by Clean-Q IT Support. Because of Clean-Q's business model, resources are contracted as needed instead of permanently employed.

The table below indicates some of the personal information Clean-Q requires as part of its business operations:

Category	Types of Personal Information
Customers	Name, address (location), contact information, billing information
Resources (contracted)	Name, contact information, banking details, address

Clean-Q has an internal employee base of about 30 people. A recent privacy compliance exercise has been conducted to align employee data management and human resource functions with applicable data protection regulation. Therefore, the Clean-Q permanent employee base is not included as part of this scenario.

With an increase in construction work and housing developments, Clean-Q has had an influx of requests for cleaning services. The demand has overwhelmed

Clean-Q's traditional supply and demand system that has caused some overlapping bookings.

In a business strategy session held by senior management recently, Clear-Q invited vendors to present potential solutions to their current operational issues.

These vendors included Application developers and cloud solution providers, presenting their proposed solutions and platforms.

The Managing Director opted to initiate the process to integrate Clean-Q's operations with a cloud solution (LeadOps) that will provide the following solution one single online platform: A web interface that Clean-Q accesses for the purposes of resource and customer management. This would entail uploading resource and customer information.

- ⇒ A customer facing web interface that enables customers to register, manage and submit cleaning service requests online.
- ⇒ A resource facing web interface that enables resources to apply and manage their assigned jobs.
- ⇒ An online payment facility for customers to pay for services.

Which question would you most likely ask to gain more insight about LeadOps and provide practical privacy recommendations?

- A. What is LeadOps' annual turnover?
- B. How big is LeadOps' employee base?
- C. Where are LeadOps' operations and hosting services located?
- D. Does LeadOps practice agile development and maintenance of their system?

Correct Answer: D

Community vote distribution

C (100%)

-  **pipzz** 2 years ago

Selected Answer: C

Location is crucial to know. There are legal requirements with transfers of personal data to third countries or international organisations, which would need to be built into the agreement.

upvoted 2 times
-  **187san** 2 years, 7 months ago

C is the answer

upvoted 3 times
-  **837vq3** 2 years, 9 months ago

"C" is a better choice. What does agile development have to do with privacy?

upvoted 4 times

SCENARIO -

Clean-Q is a company that offers house-hold and office cleaning services. The company receives requests from consumers via their website and telephone, to book cleaning services. Based on the type and size of service, Clean-Q then contracts individuals that are registered on its resource database - currently managed in-house by Clean-Q IT Support. Because of Clean-Q's business model, resources are contracted as needed instead of permanently employed.

The table below indicates some of the personal information Clean-Q requires as part of its business operations:

Category	Types of Personal Information
Customers	Name, address (location), contact information, billing information
Resources (contracted)	Name, contact information, banking details, address

Clean-Q has an internal employee base of about 30 people. A recent privacy compliance exercise has been conducted to align employee data management and human resource functions with applicable data protection regulation. Therefore, the Clean-Q permanent employee base is not included as part of this scenario.

With an increase in construction work and housing developments, Clean-Q has had an influx of requests for cleaning services. The demand has overwhelmed

Clean-Q's traditional supply and demand system that has caused some overlapping bookings.

In a business strategy session held by senior management recently, Clear-Q invited vendors to present potential solutions to their current operational issues.

These vendors included Application developers and cloud solution providers, presenting their proposed solutions and platforms.

The Managing Director opted to initiate the process to integrate Clean-Q's operations with a cloud solution (LeadOps) that will provide the following solution one single online platform: A web interface that Clean-Q accesses for the purposes of resource and customer management. This would entail uploading resource and customer information.

- ⇒ A customer facing web interface that enables customers to register, manage and submit cleaning service requests online.
- ⇒ A resource facing web interface that enables resources to apply and manage their assigned jobs.
- ⇒ An online payment facility for customers to pay for services.

What is a key consideration for assessing external service providers like LeadOps, which will conduct personal information processing operations on Clean-Q's behalf?

- A. Understanding LeadOps' costing model.
- B. Establishing a relationship with the Managing Director of LeadOps.
- C. Recognizing the value of LeadOps' website holding a verified security certificate.
- D. Obtaining knowledge of LeadOps' information handling practices and information security environment.

Correct Answer: D

Which of the following is NOT a workplace surveillance best practice?

- A. Check local privacy laws before putting surveillance in place.
- B. Ensure surveillance is discreet so employees do not alter their behavior.
- C. Once surveillance data has been gathered, limit exposure of the content.
- D. Ensure the minimal amount of surveillance is performed to meet the objective.

Correct Answer: B

A sensitive biometrics authentication system is particularly susceptible to?

- A. False positives.
- B. False negatives.
- C. Slow recognition speeds.
- D. Theft of finely individualized personal data.

Correct Answer: B

Reference:

<https://link.springer.com/article/10.1007/s41403-017-0026-8>

Which is the most accurate type of biometrics?

- A. DNA
- B. Voiceprint.
- C. Fingerprint.
- D. Facial recognition.

Correct Answer: B

Reference:

<https://www.bayometric.com/biometrics-face-finger-iris-palm-voice/>

Community vote distribution

A (100%)

- z80r** 1 year, 6 months ago

Selected Answer: A

I think it's A

upvoted 1 times
- samaja** 2 years, 3 months ago

Selected Answer: A

DNA is the most accurate biometric

upvoted 1 times
- 187san** 2 years, 7 months ago

Selected Answer: A

A

ITS A

upvoted 1 times
- k4d4v4r** 2 years, 8 months ago

DNA might be the best answer

upvoted 3 times
- 837vq3** 2 years, 9 months ago

Not sure how correct the voiceprint is. The provided link does not mention voiceprint as being the most accurate. Any suggestions?

upvoted 1 times

What is true of providers of wireless technology?

- A. They have the legal right in most countries to control and use any data on their systems.
- B. They can see all unencrypted data that crosses the system.
- C. They are typically exempt from data security regulations.
- D. They routinely backup data that crosses their system.

Correct Answer: B

What distinguishes a "smart" device?

- A. It can perform multiple data functions simultaneously.
- B. It is programmable by a user without specialized training.
- C. It can reapply access controls stored in its internal memory.
- D. It augments its intelligence with information from the internet.

Correct Answer: D

Reference:

<https://towardsdatascience.com/what-is-a-smart-device-the-key-concept-of-the-internet-of-things-52da69f6f91b>

What is the goal of privacy enhancing technologies (PETs) like multiparty computation and differential privacy?

- A. To facilitate audits of third party vendors.
- B. To protect sensitive data while maintaining its utility.
- C. To standardize privacy activities across organizational groups.
- D. To protect the security perimeter and the data items themselves.

Correct Answer: B

Reference:

<https://royalsociety.org/-/media/policy/projects/privacy-enhancing-technologies/privacy-report-summary.pdf>

🗨️ 👤 837vq3 2 years, 8 months ago

(PET) are technologies that embody fundamental data protection principles by minimizing personal data use, maximizing data security, and empowering individuals. PETs allow online users to protect the privacy of their personally identifiable information (PII) provided to and handled by services or applications. PETs use techniques to minimize possession of personal data without losing the functionality of an information system. Generally speaking, PETs can be categorized as hard and soft privacy technologies.

upvoted 1 times

To comply with the Sarbanes-Oxley Act (SOX), public companies in the United States are required to annually report on the effectiveness of the auditing controls of their financial reporting systems. These controls must be implemented to prevent unauthorized use, disclosure, modification, and damage or loss of financial data.

Why do these controls ensure both the privacy and security of data?

- A. Modification of data is an aspect of privacy; unauthorized use, disclosure, and damage or loss of data are aspects of security.
- B. Unauthorized use of data is an aspect of privacy; disclosure, modification, and damage or loss of data are aspects of security.
- C. Disclosure of data is an aspect of privacy; unauthorized use, modification, and damage or loss of data are aspects of security.
- D. Damage or loss of data are aspects of privacy; disclosure, unauthorized use, and modification of data are aspects of privacy.

Correct Answer: C

Which of the following entities would most likely be exempt from complying with the General Data Protection Regulation (GDPR)?

- A. A South American company that regularly collects European customers' personal data.
- B. A company that stores all customer data in Australia and is headquartered in a European Union (EU) member state.
- C. A Chinese company that has opened a satellite office in a European Union (EU) member state to service European customers.
- D. A North American company servicing customers in South Africa that uses a cloud storage system made by a European company.

Correct Answer: C

Community vote distribution

D (100%)

-   **z80r** 1 year, 6 months ago
Selected Answer: D
D is the right answer
upvoted 2 times
-   **187san** 2 years, 7 months ago
D
same question is there in CIPP EU
upvoted 3 times
-   **flyingrain777** 2 years, 7 months ago
I concur.
upvoted 4 times
-   **k4d4v4r** 2 years, 8 months ago
D. is correct. No way it's C as it servers european people
upvoted 4 times

SCENARIO -

WebTracker Limited is a cloud-based online marketing service located in London. Last year, WebTracker migrated its IT infrastructure to the cloud provider

AmaZure, which provides SQL Databases and Artificial Intelligence services to WebTracker. The roles and responsibilities between the two companies have been formalized in a standard contract, which includes allocating the role of data controller to WebTracker.

The CEO of WebTracker, Mr. Bond, would like to assess the effectiveness of AmaZure's privacy controls, and he recently decided to hire you as an independent auditor. The scope of the engagement is limited only to the marketing services provided by WebTracker, you will not be evaluating any internal data processing activity, such as HR or Payroll.

This ad-hoc audit was triggered due to a future partnership between WebTracker and SmartHome ``" a partnership that will not require any data sharing.

SmartHome is based in the USA, and most recently has dedicated substantial resources to developing smart refrigerators that can suggest the recommended daily calorie intake based on DNA information. This and other personal data is collected by WebTracker.

To get an idea of the scope of work involved, you have decided to start reviewing the company's documentation and interviewing key staff to understand potential privacy risks.

The results of this initial work include the following notes:

☞ There are several typos in the current privacy notice of WebTracker, and you were not able to find the privacy notice for SmartHome.

☞ You were unable to identify all the sub-processors working for SmartHome. No subcontractor is indicated in the cloud agreement with AmaZure, which is responsible for the support and maintenance of the cloud infrastructure.

☞ There are data flows representing personal data being collected from the internal employees of WebTracker, including an interface from the HR system.

☞ Part of the DNA data collected by WebTracker was from employees, as this was a prototype approved by the CEO of WebTracker.

☞ All the WebTracker and SmartHome customers are based in USA and Canada.

Based on the initial assessment and review of the available data flows, which of the following would be the most important privacy risk you should investigate first?

A. Verify that WebTracker's HR and Payroll systems implement the current privacy notice (after the typos are fixed).

B. Review the list of subcontractors employed by AmaZure and ensure these are included in the formal agreement with WebTracker.

C. Evaluate and review the basis for processing employees' personal data in the context of the prototype created by WebTracker and approved by the CEO.

D. Confirm whether the data transfer from London to the USA has been fully approved by AmaZure and the appropriate institutions in the USA and the European Union.

Correct Answer: C

SCENARIO -

WebTracker Limited is a cloud-based online marketing service located in London. Last year, WebTracker migrated its IT infrastructure to the cloud provider

AmaZure, which provides SQL Databases and Artificial Intelligence services to WebTracker. The roles and responsibilities between the two companies have been formalized in a standard contract, which includes allocating the role of data controller to WebTracker.

The CEO of WebTracker, Mr. Bond, would like to assess the effectiveness of AmaZure's privacy controls, and he recently decided to hire you as an independent auditor. The scope of the engagement is limited only to the marketing services provided by WebTracker, you will not be evaluating any internal data processing activity, such as HR or Payroll.

This ad-hoc audit was triggered due to a future partnership between WebTracker and SmartHome `` a partnership that will not require any data sharing.

SmartHome is based in the USA, and most recently has dedicated substantial resources to developing smart refrigerators that can suggest the recommended daily calorie intake based on DNA information. This and other personal data is collected by WebTracker.

To get an idea of the scope of work involved, you have decided to start reviewing the company's documentation and interviewing key staff to understand potential privacy risks.

The results of this initial work include the following notes:

- ☞ There are several typos in the current privacy notice of WebTracker, and you were not able to find the privacy notice for SmartHome.
- ☞ You were unable to identify all the sub-processors working for SmartHome. No subcontractor is indicated in the cloud agreement with AmaZure, which is responsible for the support and maintenance of the cloud infrastructure.
- ☞ There are data flows representing personal data being collected from the internal employees of WebTracker, including an interface from the HR system.
- ☞ Part of the DNA data collected by WebTracker was from employees, as this was a prototype approved by the CEO of WebTracker.
- ☞ All the WebTracker and SmartHome customers are based in USA and Canada.

Which of the following issues is most likely to require an investigation by the Chief Privacy Officer (CPO) of WebTracker?

- A. Data flows use encryption for data at rest, as defined by the IT manager.
- B. AmaZure sends newsletter to WebTracker customers, as approved by the Marketing Manager.
- C. Employees' personal data are being stored in a cloud HR system, as approved by the HR Manager.
- D. File Integrity Monitoring is being deployed in SQL servers, as indicated by the IT Architect Manager.

Correct Answer: B

SCENARIO -

Tom looked forward to starting his new position with a U.S.-based automobile leasing company (New Company), now operating in 32 states. New Company was recently formed through the merger of two prominent players, one from the eastern region (East Company) and one from the western region (West Company).

Tom, a Certified Information Privacy Technologist (CIPT), is New Company's first Information Privacy and Security Officer. He met today with Dick from East

Company, and Harry, from West Company. Dick and Harry are veteran senior information privacy and security professionals at their respective companies, and continue to lead the east and west divisions of New Company. The purpose of the meeting was to conduct a SWOT (strengths/weaknesses/opportunities/threats) analysis for New Company. Their SWOT analysis conclusions are summarized below.

Dick was enthusiastic about an opportunity for the New Company to reduce costs and increase computing power and flexibility through cloud services. East

Company had been contemplating moving to the cloud, but West Company already had a vendor that was providing it with software-as-a-service (SaaS). Dick was looking forward to extending this service to the eastern region. Harry noted that this was a threat as well, because West Company had to rely on the third party to protect its data.

Tom mentioned that neither of the legacy companies had sufficient data storage space to meet the projected growth of New Company, which he saw as a weakness. Tom stated that one of the team's first projects would be to construct a consolidated New Company data warehouse. Tom would personally lead this project and would be held accountable if information was modified during transmission to or during storage in the new data warehouse.

Tom, Dick and Harry agreed that employee network access could be considered both a strength and a weakness. East Company and West Company had strong performance records in this regard; both had robust network access controls that were working as designed. However, during a projected year-long transition period, New Company employees would need to be able to connect to a New Company network while retaining access to the East Company and West Company networks.

Which statement is correct about addressing New Company stakeholders' expectations for privacy?

- A. New Company should expect consumers to read the company's privacy policy.
- B. New Company should manage stakeholder expectations for privacy even when the stakeholders' data is not held by New Company.
- C. New Company would best meet consumer expectations for privacy by adhering to legal requirements.
- D. New Company's commitment to stakeholders ends when the stakeholders' data leaves New Company.

Correct Answer: D

Community vote distribution

C (100%)

- Sharon2000

1 month, 3 weeks ago

I think it is B

upvoted 1 times
- Sbowo

2 years, 6 months ago

Selected Answer: C

I think C is the saver answer adhering legal compliance

upvoted 1 times
- 187san

2 years, 7 months ago

B is the answer

upvoted 3 times
- 837vq3

2 years, 8 months ago

I think the correct answer is "B". The New Company is due to the merger of the other two companies and should be responsible for all of the data regardless of which subsidiary it belong to

upvoted 4 times

SCENARIO -

Tom looked forward to starting his new position with a U.S.-based automobile leasing company (New Company), now operating in 32 states. New Company was recently formed through the merger of two prominent players, one from the eastern region (East Company) and one from the western region (West Company).

Tom, a Certified Information Privacy Technologist (CIPT), is New Company's first Information Privacy and Security Officer. He met today with Dick from East

Company, and Harry, from West Company. Dick and Harry are veteran senior information privacy and security professionals at their respective companies, and continue to lead the east and west divisions of New Company. The purpose of the meeting was to conduct a SWOT (strengths/weaknesses/opportunities/threats) analysis for New Company. Their SWOT analysis conclusions are summarized below.

Dick was enthusiastic about an opportunity for the New Company to reduce costs and increase computing power and flexibility through cloud services. East

Company had been contemplating moving to the cloud, but West Company already had a vendor that was providing it with software-as-a-service (SaaS). Dick was looking forward to extending this service to the eastern region. Harry noted that this was a threat as well, because West Company had to rely on the third party to protect its data.

Tom mentioned that neither of the legacy companies had sufficient data storage space to meet the projected growth of New Company, which he saw as a weakness. Tom stated that one of the team's first projects would be to construct a consolidated New Company data warehouse. Tom would personally lead this project and would be held accountable if information was modified during transmission to or during storage in the new data warehouse.

Tom, Dick and Harry agreed that employee network access could be considered both a strength and a weakness. East Company and West Company had strong performance records in this regard; both had robust network access controls that were working as designed. However, during a projected year-long transition period, New Company employees would need to be able to connect to a New Company network while retaining access to the East Company and West Company networks.

When employees are working remotely, they usually connect to a Wi-Fi network. What should Harry advise for maintaining company security in this situation?

- A. Hiding wireless service set identifiers (SSID).
- B. Retaining the password assigned by the network.
- C. Employing Wired Equivalent Privacy (WEP) encryption.
- D. Using tokens sent through HTTP sites to verify user identity.

Correct Answer: A

Community vote distribution

D (100%)

- Sharon2000** 1 month, 3 weeks ago

Not D, as it is HTTP and not HTTPS ?

upvoted 1 times
- ME79** 1 year, 3 months ago

Selected Answer: D

If the employee is working remotely, they are typically not the administrator of the wireless network (unless it is their home network). Therefore hiding the SSID can not be an option.

The most correct option would be to use a VPN, however that is not listed as an option. Therefore, choice D, using tokens implies MFA, which is something that a company can set up to validate the identity of an employee that is trying to connect.

upvoted 2 times

SCENARIO -

Looking back at your first two years as the Director of Personal Information Protection and Compliance for the Berry Country Regional Medical Center in Thorn

Bay, Ontario, Canada, you see a parade of accomplishments, from developing state-of-the-art simulation based training for employees on privacy protection to establishing an interactive medical records system that is accessible by patients as well as by the medical personnel. Now, however, a question you have put off looms large: how do we manage all the data-not only records produced recently, but those still on hand from years ago? A data flow diagram generated last year shows multiple servers, databases, and work stations, many of which hold files that have not yet been incorporated into the new records system. While most of this data is encrypted, its persistence may pose security and compliance concerns. The situation is further complicated by several long-term studies being conducted by the medical staff using patient information. Having recently reviewed the major Canadian privacy regulations, you want to make certain that the medical center is observing them.

You also recall a recent visit to the Records Storage Section, often termed `The Dungeon` in the basement of the old hospital next to the modern facility, where you noticed a multitude of paper records. Some of these were in crates marked by years, medical condition or alphabetically by patient name, while others were in undifferentiated bundles on shelves and on the floor. The back shelves of the section housed data tapes and old hard drives that were often unlabeled but appeared to be years old. On your way out of the dungeon, you noticed just ahead of you a small man in a lab coat who you did not recognize. He carried a batch of folders under his arm, apparently records he had removed from storage.

Which regulation most likely applies to the data stored by Berry Country Regional Medical Center?

- A. Personal Information Protection and Electronic Documents Act
- B. Health Insurance Portability and Accountability Act
- C. The Health Records Act 2001
- D. The European Union Directive 95/46/EC

Correct Answer: A

-   **837vq3** 2 years, 8 months ago
Update: The correct answer is "A" . "PIPEDA" is in Canada and the company in the question is in Canada.
upvoted 1 times
-   **837vq3** 2 years, 9 months ago
Why not "B" " Health Insurance Portability and Accountability Act"?
upvoted 1 times
-   **ChaBum** 2 years, 4 months ago
Berry Country Regional Medical Center is located in Canada
upvoted 1 times

SCENARIO -

Looking back at your first two years as the Director of Personal Information Protection and Compliance for the Berry Country Regional Medical Center in Thorn

Bay, Ontario, Canada, you see a parade of accomplishments, from developing state-of-the-art simulation based training for employees on privacy protection to establishing an interactive medical records system that is accessible by patients as well as by the medical personnel.

Now, however, a question you have put off looms large: how do we manage all the data-not only records produced recently, but those still on hand from years ago? A data flow diagram generated last year shows multiple servers, databases, and work stations, many of which hold files that have not yet been incorporated into the new records system. While most of this data is encrypted, its persistence may pose security and compliance concerns. The situation is further complicated by several long-term studies being conducted by the medical staff using patient information. Having recently reviewed the major Canadian privacy regulations, you want to make certain that the medical center is observing them.

You also recall a recent visit to the Records Storage Section, often termed `The Dungeon` in the basement of the old hospital next to the modern facility, where you noticed a multitude of paper records. Some of these were in crates marked by years, medical condition or alphabetically by patient name, while others were in undifferentiated bundles on shelves and on the floor. The back shelves of the section housed data tapes and old hard drives that were often unlabeled but appeared to be years old. On your way out of the dungeon, you noticed just ahead of you a small man in a lab coat who you did not recognize. He carried a batch of folders under his arm, apparently records he had removed from storage.

Which data lifecycle phase needs the most attention at this Ontario medical center?

- A. Retention
- B. Disclosure
- C. Collection
- D. Use

Correct Answer: A

阿泽Vx: est258258

SCENARIO -

Looking back at your first two years as the Director of Personal Information Protection and Compliance for the Berry Country Regional Medical Center in Thorn

Bay, Ontario, Canada, you see a parade of accomplishments, from developing state-of-the-art simulation based training for employees on privacy protection to establishing an interactive medical records system that is accessible by patients as well as by the medical personnel. Now, however, a question you have put off looms large: how do we manage all the data-not only records produced recently, but those still on hand from years ago? A data flow diagram generated last year shows multiple servers, databases, and work stations, many of which hold files that have not yet been incorporated into the new records system. While most of this data is encrypted, its persistence may pose security and compliance concerns. The situation is further complicated by several long-term studies being conducted by the medical staff using patient information. Having recently reviewed the major Canadian privacy regulations, you want to make certain that the medical center is observing them.

You also recall a recent visit to the Records Storage Section, often termed `The Dungeon` in the basement of the old hospital next to the modern facility, where you noticed a multitude of paper records. Some of these were in crates marked by years, medical condition or alphabetically by patient name, while others were in undifferentiated bundles on shelves and on the floor. The back shelves of the section housed data tapes and old hard drives that were often unlabeled but appeared to be years old. On your way out of the dungeon, you noticed just ahead of you a small man in a lab coat who you did not recognize. He carried a batch of folders under his arm, apparently records he had removed from storage.

Which cryptographic standard would be most appropriate for protecting patient credit card information in the records system?

- A. Asymmetric Encryption
- B. Symmetric Encryption
- C. Obfuscation
- D. Hashing

Correct Answer: A

Community vote distribution

B (100%)

k4d4v4r

2 years, 7 months ago

Selected Answer: B

Use this as reference:

<https://security.stackexchange.com/questions/229044/symmetric-vs-asymmetric-encryption-for-backup-files-uploaded-to-cloud-storage>

upvoted 3 times

Users of a web-based email service have their accounts breached through compromised login credentials. Which possible consequences of the breach illustrate the two categories of Calo's Harm Dimensions?

- A. Financial loss and blackmail.
- B. Financial loss and solicitation.
- C. Identity theft and embarrassment.
- D. Identity theft and the leaking of information.

Correct Answer: D

Community vote distribution

C (100%)

- Trepanij 1 year, 8 months ago

Selected Answer: C

Answer is C.
Extracts from The boundaries of privacy harms: "Objective harms can also occur when such information is used to commit a crime, such as identity theft or murder."; "The subjective category of privacy harm is the perception of unwanted observation. This category describes unwelcome mental states—anxiety, for instance, or embarrassment—that accompany the belief that one is or will be watched or monitored."
upvoted 3 times
- 187san 2 years, 7 months ago

C is the answer
upvoted 3 times
- k4d4v4r 2 years, 7 months ago

Selected Answer: C

Every other option has something that you can count, as "the amount of blackmails, solicitations and data leaked". If you can count than it's objective harm.
upvoted 3 times
- 837vq3 2 years, 9 months ago

I think correct answer is "C". Its the only option that has both "objective" and "subjective" harm elements
upvoted 3 times

Implementation of privacy controls for compliance with the requirements of the Children's Online Privacy Protection Act (COPPA) is necessary for all the following situations EXCEPT?

- A. A virtual jigsaw puzzle game marketed for ages 5-9 displays pieces of the puzzle on a handheld screen. Once the child completes a certain level, it flashes a message about new themes released that day.
- B. An interactive toy copies a child's behavior through gestures and kid-friendly sounds. It runs on battery power and automatically connects to a base station at home to charge itself.
- C. A math tutoring service commissioned an advertisement on a bulletin board inside a charter school. The service makes it simple to reach out to tutors through a QR-code shaped like a cartoon character.
- D. A note-taking application converts hard copies of kids' class notes into audio books in seconds. It does so by using the processing power of idle server farms.

Correct Answer: A

Community vote distribution

B (100%)

- Stants

4 months, 3 weeks ago

Option C: A math tutoring service commissioned an advertisement on a bulletin board inside a charter school. The service makes it simple to reach out to tutors through a QR-code shaped like a cartoon character.

This option describes an offline advertising method that does not involve online data collection or interaction. It simply promotes a service and provides contact information, which does not fall under the purview of COPPA.

Your explanations of the other options are also accurate. Options A, B, and D all involve online activities or services that collect or use children's data, and thus would require compliance with COPPA. Always remember that the specific requirements of COPPA can vary depending on the context and the specific needs of the users.

upvoted 1 times

pipzz

2 years ago

Selected Answer: B

B is the only one with no online connection so no data is being shared.

upvoted 2 times
- 题库来源阿泽Vx：est258258

Which of the following does NOT illustrate the 'respect to user privacy' principle?

- A. Implementing privacy elements within the user interface that facilitate the use of technology by any visually-challenged users.
- B. Enabling Data Subject Access Request (DSARs) that provide rights for correction, deletion, amendment and rectification of personal information.
- C. Developing a consent management self-service portal that enables the data subjects to review the details of consent provided to an organization.
- D. Filing breach notification paperwork with data protection authorities which detail the impact to data subjects.

Correct Answer: D

 **Stants** 4 months, 3 weeks ago

The option that does NOT illustrate the 'respect to user privacy' principle is Option A: Implementing privacy elements within the user interface that facilitate the use of technology by any visually-challenged users.

While this option is important for accessibility and inclusivity, it doesn't directly relate to privacy. It's more about making the technology usable for all individuals, regardless of their visual abilities.

The other options (B, C, and D) are all directly related to respecting user privacy. They involve giving users control over their personal data (Options B and C) and ensuring transparency about data breaches (Option D), which are key aspects of privacy. Always remember that the specific implementation of privacy protections can vary depending on the context and the specific needs of the users.

upvoted 1 times

阿泽Vx: est258258

Value Sensitive Design (VSD) focuses on which of the following?

- A. Quality and benefit.
- B. Ethics and morality.
- C. Principles and standards.
- D. Privacy and human rights.

Correct Answer: C

Reference:

<https://searchcio.techtarget.com/definition/value-sensitive-design-VSD>

Community vote distribution

B (100%)

- 837vq3** Highly Voted

2 years, 9 months ago

"B" because "Value-sensitive design is a design approach that accounts for moral and ethical values and should be considered when assessing the overall value of a design."

upvoted 8 times
- fvo** Most Recent

6 months, 1 week ago

B

Value-sensitive design is a design approach that accounts for moral and ethical values and should be considered when assessing the overall "value" of a design.

upvoted 1 times
- dmi_air**

1 year, 1 month ago

Selected Answer: B

B is correct

upvoted 1 times

SCENARIO -

Please use the following to answer the next question:

Looking back at your first two years as the Director of Personal Information Protection and Compliance for the St. Anne's Regional Medical Center in Thorn Bay, Ontario, Canada, you see a parade of accomplishments, from developing state-of-the-art simulation based training for employees on privacy protection to establishing an interactive medical records system that is accessible by patients as well as by the medical personnel. Now, however, a question you have put off looms large: how do we manage all the data-not only records produced recently, but those still on-hand from years ago? A data flow diagram generated last year shows multiple servers, databases, and work stations, many of which hold files that have not yet been incorporated into the new records system. While most of this data is encrypted, its persistence may pose security and compliance concerns. The situation is further complicated by several long-term studies being conducted by the medical staff using patient information. Having recently reviewed the major Canadian privacy regulations, you want to make certain that the medical center is observing them.

You recall a recent visit to the Records Storage Section in the basement of the old hospital next to the modern facility, where you noticed paper records sitting in crates labeled by years, medical condition or alphabetically by patient name, while others were in undifferentiated bundles on shelves and on the floor. On the back shelves of the section sat data tapes and old hard drives that were often unlabeled but appeared to be years old. On your way out of the records storage section, you noticed a man leaving whom you did not recognize. He carried a batch of folders under his arm, apparently records he had removed from storage.

You quickly realize that you need a plan of action on the maintenance, secure storage and disposal of data.

Which cryptographic standard would be most appropriate for protecting patient credit card information in the records system at St. Anne's Regional Medical Center?

- A. Symmetric Encryption
- B. Tokenization
- C. Obfuscation
- D. Certificates

Correct Answer: B

Community vote distribution

A (43%)	B (43%)	14%
---------	---------	-----

- PaigeH7** 4 months ago

Selected Answer: C

tokenization ensures that credit card information remains protected while allowing authorized users to perform necessary tasks within the medical records system

upvoted 1 times
- pipzz** 2 years ago

Selected Answer: A

They are referring to data at rest here and in this case symmetric encryption can be used as per PCI DSS Guide. If the data was in motion it must be encrypted with asymmetric encryption.

<https://www.pcidssguide.com/encryption-key-management-essentials/>

upvoted 1 times
- chariot** 2 years, 2 months ago

Both are cryptographic data security methods and they essentially have the same function, however they do so with differing processes and have different effects on the data they are protecting.

upvoted 1 times
- nchzhang** 2 years, 3 months ago

Selected Answer: B

B is the answer. Tokenization is a form of encryption.

upvoted 3 times
- Stants** 4 months, 3 weeks ago

The most appropriate cryptographic standard for protecting patient credit card information in the records system at St. Anne's Regional Medical Center would be B. Tokenization.

Tokenization is a process that replaces sensitive data with unique identification symbols (or "tokens") that retain all the essential information about the data without compromising its security. In the context of credit card information, tokenization can provide a high level of security because even if a token were to be intercepted or stolen, it would be useless to the thief without the original data it represents. This makes tokenization particularly suitable for protecting sensitive data like credit card numbers. It is widely used in the payment industry to reduce the scope of compliance with the Payment Card Industry Data Security Standard (PCI DSS).

upvoted 1 times

  **k4d4v4r** 2 years, 7 months ago

Found this article... <https://www.tokenex.com/blog/tokenization-vs-encryption-which-one-is-best-for-your-business>

Maybe the question is poorly written

upvoted 2 times

  **k4d4v4r** 2 years, 7 months ago

Selected Answer: A

Tokenization is a technique, not a standard.
Standards are DES, 3DES, RSA... The only "standard" being mentioned is symmetric encryption

upvoted 2 times

阿泽Vx: est258258

A privacy engineer has been asked to review an online account login page. He finds there is no limitation on the number of invalid login attempts a user can make when logging into their online account.

What would be the best recommendation to minimize the potential privacy risk from this weakness?

- A. Implement a CAPTCHA system.
- B. Develop server-side input validation checks.
- C. Enforce strong password and account credentials.
- D. Implement strong Transport Layer Security (TLS) to ensure an encrypted link.

Correct Answer: B

Reference:

<https://www.packetlabs.net/input-validation/>

Community vote distribution

A (100%)

z80r

1 year, 6 months ago

Selected Answer: A

A is the right answer

upvoted 2 times

Stants

4 months, 3 weeks ago

The best recommendation to minimize the potential privacy risk from this weakness would be A. Implement a CAPTCHA system.

A CAPTCHA system can help prevent automated attacks, such as brute force or password spraying attacks, by requiring users to prove they are human before they can proceed. This would effectively limit the number of invalid login attempts because an attacker would need to solve a CAPTCHA challenge for each attempt, which is computationally expensive and time-consuming. This makes automated attacks much less feasible. Please note that this should be used in conjunction with other security measures like account lockouts after a certain number of failed attempts, strong password policies, and encryption to provide a comprehensive security solution.

upvoted 1 times

chariot

2 years, 2 months ago

B is the answer, Captcha system helps prove you are not a robot but doesnt help with authentication

upvoted 2 times

187san

2 years, 7 months ago

A is the answer

upvoted 2 times

k4d4v4r

2 years, 8 months ago

A is correct

upvoted 2 times

837vq3

2 years, 9 months ago

why not "A"?

upvoted 1 times

Which of these actions is NOT generally part of the responsibility of an IT or software engineer?

- A. Providing feedback on privacy policies.
- B. Implementing multi-factor authentication.
- C. Certifying compliance with security and privacy law.
- D. Building privacy controls into the organization's IT systems or software.

Correct Answer: A

Community vote distribution

C (100%)

- z80r** 1 year, 6 months ago

Selected Answer: C

C is the right answer

upvoted 3 times
- Sbowo** 2 years, 6 months ago

IT professional is not responsible for a privacy program but laying a good technical foundation for it (page 19 book Privacy in Technology). A is a correct answer

upvoted 1 times
- k4d4v4r** 2 years, 7 months ago

If he can't provide feedback on privacy policies, the least he can do is to certificate compliance with privacy laws.

upvoted 1 times
- k4d4v4r** 2 years, 7 months ago

Selected Answer: C

Can someone give an opinion?

upvoted 1 times
- 题库来源阿泽Vx：est258258

Which of the following are the mandatory pieces of information to be included in the documentation of records of processing activities for an organization that processes personal data on behalf of another organization?

- A. Copies of the consent forms from each data subject.
- B. Time limits for erasure of different categories of data.
- C. Contact details of the processor and Data Protection Offer (DPO).
- D. Descriptions of the processing activities and relevant data subjects.

Correct Answer: B

Reference:

<https://www.iubenda.com/en/help/5428-gdpr-guidema>

Community vote distribution

D (50%)	B (25%)	C (25%)
---------	---------	---------

- z80r

1 year, 6 months ago

Selected Answer: D

I think it's D . This is not a GDPR based exam nor this question in particular mention it. So D is probably the right one.

upvoted 1 times
- Sara_sw

1 year, 8 months ago

Selected Answer: D

Records of processing activities must include significant information about data processing, including data categories, the group of data subjects the purpose of the processing and the data recipients. This must be completely made available to authorities upon request.
<https://gdpr-info.eu/issues/records-of-processing-activities/#:~:text=GDPR%20Records%20of%20Processing%20Activities&text=Records%20of%20processing%20activities%20must,available%20to%20authorities%20upon%20request>.

upvoted 1 times
- pipzz

2 years ago

Selected Answer: C

Meant to select C in my below comment (not B)

upvoted 1 times
- pipzz

2 years ago

Selected Answer: B

As per Art. 30 GDPR Records of processing activities, it's mandatory to provide name/contact details of the controller/DPO. Providing time limits is only "where possible". <https://gdpr-info.eu/art-30-gdpr/>

upvoted 1 times
- 187san

2 years, 7 months ago

C is the answer

upvoted 1 times

After downloading and loading a mobile app, the user is presented with an account registration page requesting the user to provide certain personal details. Two statements are also displayed on the same page along with a box for the user to check to indicate their confirmation: Statement 1 reads: `Please check this box to confirm you have read and accept the terms and conditions of the end user license agreement` and includes a

- hyperlink to the terms and conditions.

☞ Statement 2 reads: `Please check this box to confirm you have read and understood the privacy notice` and includes a hyperlink to the privacy notice.

Under the General Data Protection Regulation (GDPR), what lawful basis would you primarily expect the privacy notice to refer to?

- A. Consent.
- B. Vital interests.
- C. Legal obligation.
- D. Legitimate interests.

Correct Answer: A

Which of the following is the best method to minimize tracking through the use of cookies?

- A. Use 'private browsing' mode and delete checked files, clear cookies and cache once a day.
- B. Install a commercially available third-party application on top of the browser that is already installed.
- C. Install and use a web browser that is advertised as 'built specifically to safeguard user privacy'.
- D. Manage settings in the browser to limit the use of cookies and remove them once the session completes.

Correct Answer: D

Reference:

<https://privacy.net/stop-cookies-tracking/>

Which of the following is NOT relevant to a user exercising their data portability rights?

- A. Notice and consent for the downloading of data.
- B. Detection of phishing attacks against the portability interface.
- C. Re-authentication of an account, including two-factor authentication as appropriate.
- D. Validation of users with unauthenticated identifiers (e.g. IP address, physical address).

Correct Answer: D

Community vote distribution

B (100%)

- Stants** 4 months, 3 weeks ago

The option that is NOT relevant to a user exercising their data portability rights is D. Validation of users with unauthenticated identifiers (e.g. IP address, physical address).

Data portability rights, as defined by regulations like the General Data Protection Regulation (GDPR), allow individuals to obtain and reuse their personal data across different services. This involves securely transferring, copying, or moving data without hindrance to its usability.

While notice and consent for downloading data (A), detection of phishing attacks against the portability interface (B), and re-authentication of an account, including two-factor authentication as appropriate ©, are all relevant to ensuring the secure and compliant exercise of data portability rights, validating users with unauthenticated identifiers like IP or physical addresses (D) is not directly relevant

upvoted 1 times
- 187san** 2 years, 7 months ago

B

its B

upvoted 1 times
- 187san** 2 years, 7 months ago

Selected Answer: B

B , something related to SD

Portability, in relation to software, is a measure of how easily an application can be transferred from one computer environment to another. A computer software application is considered portable to a new environment if the effort required to adapt it to the new environment is within reasonable limits. The meaning of the abstract term 'reasonable' depends upon the nature of the application and is often difficult to express in quantifiable units.

upvoted 4 times
- k4d4v4r** 2 years, 7 months ago

It should be B and D in case of a multiple choice situation.

D is only plausible on a "no-login" strategy. It requires more technology to validate but it is possible to implement.

B is just bizarre. No user would ever ask for a report like that to exercise their rights.

upvoted 1 times
- 837vq3** 2 years, 7 months ago

I am between "B" and "D". I think the question is asking for a user that is interested in "data portability" which is basically the ability to move data to somewhere else, which would NOT be useful/relevant to this user. I this "B" is NOT useful to the end-user since it should affect the company more so than the user?

upvoted 1 times
- k4d4v4r** 2 years, 7 months ago

Can someone explain?

upvoted 1 times

In order to prevent others from identifying an individual within a data set, privacy engineers use a cryptographically-secure hashing algorithm. Use of hashes in this way illustrates the privacy tactic known as what?

- A. Isolation.
- B. Obfuscation.
- C. Perturbation.
- D. Stripping.

Correct Answer: B

  **837vq3** 2 years, 8 months ago
Obfuscation obstructs the ability to read or understand personal information. This is most commonly done with encryption or hashing but could also be done simply by using a code or little-known language.
upvoted 2 times

An organization based in California, USA is implementing a new online helpdesk solution for recording customer call information. The organization considers the capture of personal data on the online helpdesk solution to be in the interest of the company in best servicing customer calls.
Before implementation, a privacy technologist should conduct which of the following?

- A. A Data Protection Impact Assessment (DPIA) and consultation with the appropriate regulator to ensure legal compliance.
- B. A privacy risk and impact assessment to evaluate potential risks from the proposed processing operations.
- C. A Legitimate Interest Assessment (LIA) to ensure that the processing is proportionate and does not override the privacy, rights and freedoms of the customers.
- D. A security assessment of the help desk solution and provider to assess if the technology was developed with a security by design approach.

Correct Answer: C
Reference:
<https://ico.org.uk/for-organisations/guide-to-data-protection/guide-to-the-general-data-protection-regulation-gdpr/lawful-basis-for-processing/legitimate-interests/>

  **Ahpl** 2 years, 4 months ago
why not B? Privacy and Data Protection Impact Assessments - Assessments evaluating privacy harms and issues for major activities undertaken by an organization.
upvoted 2 times

  **837vq3** 2 years, 8 months ago
<https://dataprivacymanager.net/what-is-lia-legitimate-interests-assessment-and-how-to-conduct-it/>
upvoted 1 times

Which technique is most likely to facilitate the deletion of every instance of data associated with a deleted user account from every data store held by an organization?

- A. Auditing the code which deletes user accounts.
- B. Building a standardized and documented retention program for user data deletion.
- C. Monitoring each data store for presence of data associated with the deleted user account.
- D. Training engineering teams on the importance of deleting user accounts their associated data from all data stores when requested.

Correct Answer: C

-   **837vq3** 2 years, 8 months ago
why not 'B'?
upvoted 1 times
-   **z80r** 1 year, 6 months ago
because writing a policy is formal not substantial compliance, does not assure its implementation
upvoted 1 times
-   **Trepanij** 1 year, 8 months ago
Even with a good deletion program in place, how do you expect results if you dont know where is the data..
upvoted 1 times

Which of the following CANNOT be effectively determined during a code audit?

- A. Whether access control logic is recommended in all cases.
- B. Whether data is being incorrectly shared with a third-party.
- C. Whether consent is durably recorded in the case of a server crash.
- D. Whether the differential privacy implementation correctly anonymizes data.

Correct Answer: D

-   **Stants** 4 months, 3 weeks ago
The option that CANNOT be effectively determined during a code audit is C. Whether consent is durably recorded in the case of a server crash.

A code audit can review the code to check for access control logic (A), data sharing practices (B), and the implementation of differential privacy (D). However, whether consent is durably recorded in the case of a server crash © is more of a system resilience and data durability issue, which typically involves infrastructure and system design rather than just the code itself. This would be better evaluated through system testing and review of infrastructure design rather than a code audit. It's also worth noting that the durability of consent recording in the event of a server crash would also depend on factors like backup and recovery strategies, which are outside the scope of a code audit.
upvoted 1 times

An EU marketing company is planning to make use of personal data captured to make automated decisions based on profiling. In some cases, processing and automated decisions may have a legal effect on individuals, such as credit worthiness. When evaluating the implementation of systems making automated decisions, in which situation would the company have to accommodate an individual's right NOT to be subject to such processing to ensure compliance under the General Data Protection Regulation (GDPR)?

- A. When an individual's legal status or rights are not affected by the decision.
- B. When there is no human intervention or influence in the decision-making process.
- C. When the individual has given explicit consent to such processing and suitable safeguards exist.
- D. When the decision is necessary for entering into a contract and the individual can contest the decision.

Correct Answer: B

Community vote distribution

D (100%)

  **PaigeH7** 4 months ago

Selected Answer: D

When the decision is necessary for entering into a contract and the individual can contest the decision: Here, the GDPR recognizes the right to object. If the decision affects contract terms, individuals can contest it.

upvoted 1 times

阿泽Vx: est258258

SCENARIO -

Please use the following to answer next question:

EnsureClaim is developing a mobile app platform for managing data used for assessing car accident insurance claims. Individuals use the app to take pictures at the crash site, eliminating the need for a built-in vehicle camera. EnsureClaim uses a third-party hosting provider to store data collected by the app. EnsureClaim customer service employees also receive and review app data before sharing with insurance claim adjusters.

The app collects the following information:

- ☞ First and last name
- ☞ Date of birth (DOB)
- ☞ Mailing address
- ☞ Email address
- ☞ Car VIN number
- ☞ Car model
- ☞ License plate
- ☞ Insurance card number
- ☞ Photo
- ☞ Vehicle diagnostics
- ☞ Geolocation

The app is designed to collect and transmit geolocation data. How can data collection best be limited to the necessary minimum?

- A. Allow user to opt-out geolocation data collection at any time.
- B. Allow access and sharing of geolocation data only after an accident occurs.
- C. Present a clear and explicit explanation about need for the geolocation data.
- D. Obtain consent and capture geolocation data at all times after consent is received.

Correct Answer: D

Community vote distribution

B (86%)

14%

- PaigeH74 months ago

Selected Answer: A

To limit data collection to the necessary minimum while ensuring transparency and user control, the best approach would be option A: Allow users to opt-out of geolocation data collection at any time. By giving users the choice to enable or disable geolocation tracking, you respect their privacy preferences and allow them to make an informed decision about sharing their location data. This approach strikes a balance between functionality and privacy, empowering users to manage their own data usage

upvoted 1 times
- z80r1 year, 6 months ago

Selected Answer: B

it's B

upvoted 1 times
- Sara_sw1 year, 8 months ago

Selected Answer: B

definitely not D!!

upvoted 1 times
- 187san2 years, 7 months ago

Selected Answer: B

B is the answer

upvoted 4 times

SCENARIO -

Please use the following to answer next question:

EnsureClaim is developing a mobile app platform for managing data used for assessing car accident insurance claims. Individuals use the app to take pictures at the crash site, eliminating the need for a built-in vehicle camera. EnsureClaim uses a third-party hosting provider to store data collected by the app. EnsureClaim customer service employees also receive and review app data before sharing with insurance claim adjusters.

The app collects the following information:

- ☞ First and last name
- ☞ Date of birth (DOB)
- ☞ Mailing address
- ☞ Email address
- ☞ Car VIN number
- ☞ Car model
- ☞ License plate
- ☞ Insurance card number
- ☞ Photo
- ☞ Vehicle diagnostics
- ☞ Geolocation

All of the following technical measures can be implemented by EnsureClaim to protect personal information that is accessible by third-parties EXCEPT?

- A. Encryption.
- B. Access Controls.
- C. De-identification.
- D. Multi-factor authentication.

Correct Answer: B

Community vote distribution

C (100%)

- Sara_sw

1 year, 8 months ago

Selected Answer: C

C is correct, since the insurance needs to know the identity of the issuer. Acces control should at all cost be implemented

upvoted 2 times
- 187san

2 years, 7 months ago

D

you can't enforce MFA on 3rd parties

upvoted 2 times
- Scynor

1 year, 9 months ago

Incorrect. The statement says data that 3rd parties have access to. It does not state data that they control. This means if you control the data, you control the authentication method including MFA. The reason that Access Control is the correct answer is because the question states "tha they have access to". This means they already have access, ergo Access Control is not a factor at all.

upvoted 1 times
- Stants

5 months, 3 weeks ago

All of the options listed - Encryption, Access Controls, De-identification, and Multi-factor authentication - are technical measures that can be implemented by EnsureClaim to protect personal information that is accessible by third-parties.

However, Option D: Multi-factor authentication is typically used to verify the identity of a user accessing the system, rather than to protect the data that is being transmitted or stored. While it adds a layer of security, it doesn't directly protect the data itself from being accessed or misused once it's been collected by the app. Therefore, in the context of the question, the answer is Option D.

upvoted 1 times

SCENARIO -

Please use the following to answer next question:

EnsureClaim is developing a mobile app platform for managing data used for assessing car accident insurance claims. Individuals use the app to take pictures at the crash site, eliminating the need for a built-in vehicle camera. EnsureClaim uses a third-party hosting provider to store data collected by the app. EnsureClaim customer service employees also receive and review app data before sharing with insurance claim adjusters.

The app collects the following information:

- ☞ First and last name
- ☞ Date of birth (DOB)
- ☞ Mailing address
- ☞ Email address
- ☞ Car VIN number
- ☞ Car model
- ☞ License plate
- ☞ Insurance card number
- ☞ Photo
- ☞ Vehicle diagnostics
- ☞ Geolocation

What IT architecture would be most appropriate for this mobile platform?

- A. Peer-to-peer architecture.
- B. Client-server architecture.
- C. Plug-in-based architecture.
- D. Service-oriented architecture.

Correct Answer: D

  **Stants** 5 months, 3 weeks ago

The most appropriate IT architecture for this mobile platform would be Option B: Client-server architecture.

In a client-server architecture, the server hosts, delivers, and manages most of the resources and services to be consumed by the client. This model would allow the mobile app (the client) to communicate with the third-party hosting provider (the server) to store and retrieve data. It would also enable EnsureClaim’s customer service employees to access and review the app data from the server.

This architecture is commonly used in web applications and is well-suited to scenarios where multiple clients need to access shared data, which aligns with the needs of the EnsureClaim app. So, the answer is Option B.
upvoted 1 times

  **Sbowo** 2 years, 6 months ago

Mobile app platform usually using plug-in based architecture because it use market place of IOS and Android to be installed on mobile
upvoted 1 times

  **837vq3** 2 years, 8 months ago

Service-oriented architecture is similar to client-server architecture in that it decouples services from large-scale servers. It allows designers to replicate services across multiple machines.
upvoted 1 times

SCENARIO -

Please use the following to answer next question:

EnsureClaim is developing a mobile app platform for managing data used for assessing car accident insurance claims. Individuals use the app to take pictures at the crash site, eliminating the need for a built-in vehicle camera. EnsureClaim uses a third-party hosting provider to store data collected by the app. EnsureClaim customer service employees also receive and review app data before sharing with insurance claim adjusters.

The app collects the following information:

- ☞ First and last name
- ☞ Date of birth (DOB)
- ☞ Mailing address
- ☞ Email address
- ☞ Car VIN number
- ☞ Car model
- ☞ License plate
- ☞ Insurance card number
- ☞ Photo
- ☞ Vehicle diagnostics
- ☞ Geolocation

What would be the best way to supervise the third-party systems the EnsureClaim App will share data with?

- A. Review the privacy notices for each third-party that the app will share personal data with to determine adequate privacy and data protection controls are in place.
- B. Conduct a security and privacy review before onboarding new vendors that collect personal data from the app.
- C. Anonymize all personal data collected by the app before sharing any data with third-parties.
- D. Develop policies and procedures that outline how data is shared with third-party apps.

Correct Answer: C

**Stants** 5 months, 3 weeks ago

The best way to supervise the third-party systems that the EnsureClaim App will share data with is Option B: Conduct a security and privacy review before onboarding new vendors that collect personal data from the app.

This approach ensures that any third-party systems have adequate security and privacy measures in place before any data is shared with them. It allows for potential issues to be identified and addressed before any personal data is put at risk.

While all the options listed are important aspects of data management and security, conducting a security and privacy review before onboarding new vendors provides a proactive approach to data protection. So, the answer is Option

upvoted 1 times

What is the best way to protect privacy on a Geographic Information System (GIS)?

- A. Limiting the data provided to the system.
- B. Using a Wireless Encryption Protocol (WEP).
- C. Scrambling location information.
- D. Using a firewall.

Correct Answer: A

Community vote distribution

A (100%)

ME79 1 year, 3 months ago

Selected Answer: A

This is a repeat of Question 68.
upvoted 1 times

What is the main privacy threat posed by Radio Frequency Identification (RFID)?

- A. An individual with an RFID receiver can track people or consumer products.
- B. An individual can scramble computer transmissions in weapons systems.
- C. An individual can use an RFID receiver to engage in video surveillance.
- D. An individual can tap mobile phone communications.

Correct Answer: D

Community vote distribution

A (100%)

z80r 1 year, 6 months ago

Selected Answer: A

A is correct
upvoted 1 times

187san 2 years, 7 months ago

A is the answer
upvoted 2 times

sirpuzee 2 years, 9 months ago

The correct answer is A. RFID tags can be tracked by hidden RFID receivers and this is a real privacy threat. IAPP Privacy in technology, page 193.
upvoted 1 times

SCENARIO -

Please use the following to answer the next question:

Chuck, a compliance auditor for a consulting firm focusing on healthcare clients, was required to travel to the client's office to perform an onsite review of the client's operations. He rented a car from Finley Motors upon arrival at the airport as so he could commute to and from the client's office. The car rental agreement was electronically signed by Chuck and included his name, address, driver's license, make/model of the car, billing rate, and additional details describing the rental transaction. On the second night, Chuck was caught by a red light camera not stopping at an intersection on his way to dinner. Chuck returned the car back to the car rental agency at the end week without mentioning the infraction and Finley Motors emailed a copy of the final receipt to the address on file.

Local law enforcement later reviewed the red light camera footage. As Finley Motors is the registered owner of the car, a notice was sent to them indicating the infraction and fine incurred. This notice included the license plate number, occurrence date and time, a photograph of the driver, and a web portal link to a video clip of the violation for further review. Finley Motors, however, was not responsible for the violation as they were not driving the car at the time and transferred the incident to AMP Payment Resources for further review. AMP Payment Resources identified Chuck as the driver based on the rental agreement he signed when picking up the car and then contacted Chuck directly through a written letter regarding the infraction to collect the fine.

After reviewing the incident through the AMP Payment Resources' web portal, Chuck paid the fine using his personal credit card. Two weeks later, Finley Motors sent Chuck an email promotion offering 10% off a future rental.

What should Finley Motors have done to incorporate the transparency principle of Privacy by Design (PbD)?

- A. Signed a data sharing agreement with AMP Payment Resources.
- B. Documented that Finley Motors has a legitimate interest to share Chuck's information.
- C. Obtained verbal consent from Chuck and recorded it within internal systems.
- D. Provided notice of data sharing practices within the electronically signed rental agreement.

Correct Answer: D

阿泽Vx: est258258

SCENARIO -

Please use the following to answer the next question:

Chuck, a compliance auditor for a consulting firm focusing on healthcare clients, was required to travel to the client's office to perform an onsite review of the client's operations. He rented a car from Finley Motors upon arrival at the airport as so he could commute to and from the client's office. The car rental agreement was electronically signed by Chuck and included his name, address, driver's license, make/model of the car, billing rate, and additional details describing the rental transaction. On the second night, Chuck was caught by a red light camera not stopping at an intersection on his way to dinner. Chuck returned the car back to the car rental agency at the end week without mentioning the infraction and Finley Motors emailed a copy of the final receipt to the address on file.

Local law enforcement later reviewed the red light camera footage. As Finley Motors is the registered owner of the car, a notice was sent to them indicating the infraction and fine incurred. This notice included the license plate number, occurrence date and time, a photograph of the driver, and a web portal link to a video clip of the violation for further review. Finley Motors, however, was not responsible for the violation as they were not driving the car at the time and transferred the incident to AMP Payment Resources for further review. AMP Payment Resources identified Chuck as the driver based on the rental agreement he signed when picking up the car and then contacted Chuck directly through a written letter regarding the infraction to collect the fine.

After reviewing the incident through the AMP Payment Resources' web portal, Chuck paid the fine using his personal credit card. Two weeks later, Finley Motors sent Chuck an email promotion offering 10% off a future rental.

What is the most secure method Finley Motors should use to transmit Chuck's information to AMP Payment Resources?

- A. Cloud file transfer services.
- B. Certificate Authority (CA).
- C. HyperText Transfer Protocol (HTTP).
- D. Transport Layer Security (TLS).

Correct Answer: D

阿泽Vx: est258258

SCENARIO -

Please use the following to answer the next question:

Chuck, a compliance auditor for a consulting firm focusing on healthcare clients, was required to travel to the client's office to perform an onsite review of the client's operations. He rented a car from Finley Motors upon arrival at the airport as so he could commute to and from the client's office. The car rental agreement was electronically signed by Chuck and included his name, address, driver's license, make/model of the car, billing rate, and additional details describing the rental transaction. On the second night, Chuck was caught by a red light camera not stopping at an intersection on his way to dinner. Chuck returned the car back to the car rental agency at the end week without mentioning the infraction and Finley Motors emailed a copy of the final receipt to the address on file.

Local law enforcement later reviewed the red light camera footage. As Finley Motors is the registered owner of the car, a notice was sent to them indicating the infraction and fine incurred. This notice included the license plate number, occurrence date and time, a photograph of the driver, and a web portal link to a video clip of the violation for further review. Finley Motors, however, was not responsible for the violation as they were not driving the car at the time and transferred the incident to AMP Payment Resources for further review. AMP Payment Resources identified Chuck as the driver based on the rental agreement he signed when picking up the car and then contacted Chuck directly through a written letter regarding the infraction to collect the fine.

After reviewing the incident through the AMP Payment Resources' web portal, Chuck paid the fine using his personal credit card. Two weeks later, Finley Motors sent Chuck an email promotion offering 10% off a future rental.

How can Finley Motors reduce the risk associated with transferring Chuck's personal information to AMP Payment Resources?

- A. By providing only the minimum necessary data to process the violation notice and masking all other information prior to transfer.
- B. By requesting AMP Payment Resources delete unnecessary datasets and only utilize what is necessary to process the violation notice.
- C. By obfuscating the minimum necessary data to process the violation notice and require AMP Payment Resources to secure store the personal information.
- D. By transferring all information to separate datafiles and requiring AMP Payment Resources to combine the datasets during processing of the violation notice.

Correct Answer: A

SCENARIO -

Please use the following to answer the next question:

Chuck, a compliance auditor for a consulting firm focusing on healthcare clients, was required to travel to the client's office to perform an onsite review of the client's operations. He rented a car from Finley Motors upon arrival at the airport as so he could commute to and from the client's office. The car rental agreement was electronically signed by Chuck and included his name, address, driver's license, make/model of the car, billing rate, and additional details describing the rental transaction. On the second night, Chuck was caught by a red light camera not stopping at an intersection on his way to dinner. Chuck returned the car back to the car rental agency at the end week without mentioning the infraction and Finley Motors emailed a copy of the final receipt to the address on file.

Local law enforcement later reviewed the red light camera footage. As Finley Motors is the registered owner of the car, a notice was sent to them indicating the infraction and fine incurred. This notice included the license plate number, occurrence date and time, a photograph of the driver, and a web portal link to a video clip of the violation for further review. Finley Motors, however, was not responsible for the violation as they were not driving the car at the time and transferred the incident to AMP Payment Resources for further review. AMP Payment Resources identified Chuck as the driver based on the rental agreement he signed when picking up the car and then contacted Chuck directly through a written letter regarding the infraction to collect the fine.

After reviewing the incident through the AMP Payment Resources' web portal, Chuck paid the fine using his personal credit card. Two weeks later, Finley Motors sent Chuck an email promotion offering 10% off a future rental.

What is the strongest method for authenticating Chuck's identity prior to allowing access to his violation information through the AMP Payment Resources web portal?

- A. By requiring Chuck use the last 4 digits of his driver's license number in combination with a unique PIN provided within the violation notice.
- B. By requiring Chuck use his credit card number in combination with the last 4 digits of his driver's license.
- C. By requiring Chuck use the rental agreement number in combination with his email address.
- D. By requiring Chuck to call AMP Payment Resources directly and provide his date of birth and home address.

Correct Answer: D

Community vote distribution

A (100%)

- z80r

1 year, 6 months ago

Selected Answer: A

I think it's A

upvoted 1 times
- Ahpl

2 years, 4 months ago

A is the better answer - last 4 ID number + unique PIN

upvoted 2 times
- Sbowo

2 years, 6 months ago

I think B is the answer. 2 factor authentication: driver license number and credit card information that contain name and address will be matched with data collected by Finley Motor on renting agreement

upvoted 1 times
- 187san

2 years, 7 months ago

A

its not D,

D option is not leagal

upvoted 1 times

Which of the following statements best describes the relationship between privacy and security?

- A. Security systems can be used to enforce compliance with privacy policies.
- B. Privacy and security are independent; organizations must decide which should be emphasized.
- C. Privacy restricts access to personal information; security regulates how information should be used.
- D. Privacy protects data from being viewed during collection and security governs how collected data should be shared.

Correct Answer: C

Reference:
<https://us.norton.com/internetsecurity-privacy-privacy-vs-security-whats-the-difference.html>

Community vote distribution

C (67%)	A (33%)
---------	---------

- PaigeH7** 4 months ago

Selected Answer: C

privacy focuses on limiting access to personal data, while security ensures the proper handling and protection of that data. Together, they create a robust framework for safeguarding information and respecting individuals' rights. 🗝️🔒

upvoted 1 times
- z80r** 1 year, 6 months ago

Selected Answer: C

I think C is a good answer

upvoted 1 times
- Sbowo** 2 years, 6 months ago

A not C. Security restricts access to personal information; privacy regulates how information should be used.

upvoted 2 times
- 187san** 2 years, 7 months ago

A

Its a straight forward answer

upvoted 2 times
- k4d4v4r** 2 years, 7 months ago

Selected Answer: A

This is so weird.. but I would stick with "A"

upvoted 1 times

SCENARIO -

Please use the following to answer the next question:

Jordan just joined a fitness-tracker start-up based in California, USA, as its first Information Privacy and Security Officer. The company is quickly growing its business but does not sell any of the fitness trackers itself. Instead, it relies on a distribution network of third-party retailers in all major countries. Despite not having any stores, the company has a 78% market share in the EU. It has a website presenting the company and products, and a member section where customers can access their information. Only the email address and physical address need to be provided as part of the registration process in order to customize the site to the user's region and country. There is also a newsletter sent every month to all members featuring fitness tips, nutrition advice, product spotlights from partner companies based on user behavior and preferences.

Jordan says the General Data Protection Regulation (GDPR) does not apply to the company. He says the company is not established in the EU, nor does it have a processor in the region. Furthermore, it does not do any `offering goods or services` in the EU since it does not do any marketing there, nor sell to consumers directly. Jordan argues that it is the customers who chose to buy the products on their own initiative and there is no `offering` from the company.

The fitness trackers incorporate advanced features such as sleep tracking, GPS tracking, heart rate monitoring. wireless syncing, calorie-counting and step- tracking. The watch must be paired with either a smartphone or a computer in order to collect data on sleep levels, heart rates, etc. All information from the device must be sent to the company's servers in order to be processed, and then the results are sent to the smartphone or computer. Jordan argues that there is no personal information involved since the company does not collect banking or social security information.

Why is Jordan's claim that the company does not collect personal information as identified by the GDPR inaccurate?

- A. The potential customers must browse for products online.
- B. The fitness trackers capture sleep and heart rate data to monitor an individual's behavior.
- C. The website collects the customers' and users' region and country information.
- D. The customers must pair their fitness trackers to either smartphones or computers.

Correct Answer: A

Community vote distribution

B (100%)

- Sara_sw

1 year, 8 months ago

Selected Answer: B

behaviour monitoring

upvoted 1 times
- 187san

2 years, 7 months ago

B is the right answer

upvoted 3 times

SCENARIO -

Please use the following to answer the next question:

Jordan just joined a fitness-tracker start-up based in California, USA, as its first Information Privacy and Security Officer. The company is quickly growing its business but does not sell any of the fitness trackers itself. Instead, it relies on a distribution network of third-party retailers in all major countries. Despite not having any stores, the company has a 78% market share in the EU. It has a website presenting the company and products, and a member section where customers can access their information. Only the email address and physical address need to be provided as part of the registration process in order to customize the site to the user's region and country. There is also a newsletter sent every month to all members featuring fitness tips, nutrition advice, product spotlights from partner companies based on user behavior and preferences.

Jordan says the General Data Protection Regulation (GDPR) does not apply to the company. He says the company is not established in the EU, nor does it have a processor in the region. Furthermore, it does not do any `offering goods or services` in the EU since it does not do any marketing there, nor sell to consumers directly. Jordan argues that it is the customers who chose to buy the products on their own initiative and there is no `offering` from the company.

The fitness trackers incorporate advanced features such as sleep tracking, GPS tracking, heart rate monitoring. wireless syncing, calorie-counting and step- tracking. The watch must be paired with either a smartphone or a computer in order to collect data on sleep levels, heart rates, etc. All information from the device must be sent to the company's servers in order to be processed, and then the results are sent to the smartphone or computer. Jordan argues that there is no personal information involved since the company does not collect banking or social security information.

Based on the current features of the fitness watch, what would you recommend be implemented into each device in order to most effectively ensure privacy?

- A. Hashing.
- B. A2DP Bluetooth profile.
- C. Persistent unique identifier.
- D. Randomized MAC address.

Correct Answer: C

 **Sharon2000** 1 month, 3 weeks ago
Chat GPT says D
upvoted 1 times

Which of the following statements is true regarding software notifications and agreements?

- A. Website visitors must view the site's privacy statement before downloading software.
- B. Software agreements are designed to be brief, while notifications provide more details.
- C. It is a good practice to provide users with information about privacy prior to software installation.
- D. Just in time software agreement notifications provide users with a final opportunity to modify the agreement.

Correct Answer: C

What is typically NOT performed by sophisticated Access Management (AM) techniques?

- A. Restricting access to data based on location.
- B. Restricting access to data based on user role.
- C. Preventing certain types of devices from accessing data.
- D. Preventing data from being placed in unprotected storage.

Correct Answer: B

Community vote distribution

D (100%)

- z80r** 1 year, 6 months ago

Selected Answer: D

D is the correct one
upvoted 1 times
- Ahpl** 2 years, 4 months ago

Pg 109 of PG - Sophisticated access management techniques can restrict access to data based on the type of data being accessed, the role of the person accessing the data, the location of the user, the time of day, or the type of device being used to access the data
upvoted 1 times
- Ahpl** 2 years, 4 months ago

Answer is D...
upvoted 1 times
- Sbowo** 2 years, 6 months ago

A, B, C answer is on chapter 4.2 book Privacy in Technology
upvoted 1 times
- k4d4v4r** 2 years, 7 months ago

Selected Answer: D

Every other type is possible within IAM
upvoted 1 times
- 837vq3** 2 years, 7 months ago

I think "B" might be correct. The question is asking for what is "NOT" provided by a "sophisticated" IAM solution. Option "B" seems to be the only solution that should be standard for even the basic IAM solution.
upvoted 1 times
- flyingrain777** 2 years, 7 months ago

Selected Answer: D

why not "D"?
upvoted 1 times
- 837vq3** 2 years, 8 months ago

why not "D"?
upvoted 1 times

Properly configured databases and well-written website codes are the best protection against what online threat?

- A. Pharming.
- B. SQL injection.
- C. Malware execution.
- D. System modification.

Correct Answer: B

Reference:

https://www.netwrix.com/sql_server_security_best_practices.html

阿泽Vx: est258258

A privacy engineer reviews a newly developed on-line registration page on a company's website. The purpose of the page is to enable corporate customers to submit a returns / refund request for physical goods. The page displays the following data capture fields: company name, account reference, company address, contact name, email address, contact phone number, product name, quantity, issue description and company bank account details.

After her review, the privacy engineer recommends setting certain capture fields as `non-mandatory`. Setting which of the following fields as `non-mandatory` would be the best example of the principle of data minimization?

- A. The contact phone number field.
- B. The company address and name.
- C. The contact name and email address.
- D. The company bank account detail field.

Correct Answer: B

Community vote distribution

A (50%)

C (50%)

- PaigeH7

4 months ago

Selected Answer: A

You don't necessarily have to have the contact number for a refund

upvoted 1 times
- Stants

4 months, 3 weeks ago

The best example of applying the principle of data minimization in this scenario would be:

A. The contact phone number field.

Here's why:

The contact phone number may not always be necessary for processing return/refund requests. While it can be useful for communication purposes, it may not be essential for every transaction.
By making the contact phone number field non-mandatory, the company can reduce the amount of data collected from users, aligning with the principle of data minimization.
Other fields like company name, account reference, and product details are likely essential for processing the request and may need to be mandatory to ensure the request is valid and can be efficiently handled.
Therefore, making the contact phone number field non-mandatory strikes a balance between collecting necessary information for processing requests and minimizing the collection of potentially unnecessary data.

upvoted 2 times
- pipzz

2 years ago

If account reference is provided then they should not need to provide company name and address because that will be linked to account reference on the customer database.

upvoted 1 times
- ChaChaMcGraw

2 years, 2 months ago

Selected Answer: C

This makes no sense to me. Why is the NAME and ADDRESS of the company who wants the refund not mandatory?

upvoted 1 times
- JPB11

2 years, 3 months ago

This is Privacy right...i.e. individuals....A is not the right answer

upvoted 2 times
- Ahpl

2 years, 4 months ago

A is a better answer

upvoted 3 times
- 187san

2 years, 7 months ago

A is the answer

upvoted 4 times

What Privacy by Design (PbD) element should include a de-identification or deletion plan?

- A. Categorization.
- B. Remediation.
- C. Retention.
- D. Security

Correct Answer: C

Which of the following would be the best method of ensuring that Information Technology projects follow Privacy by Design (PbD) principles?

- A. Develop a technical privacy framework that integrates with the development lifecycle.
- B. Utilize Privacy Enhancing Technologies (PETs) as a part of product risk assessment and management.
- C. Identify the privacy requirements as a part of the Privacy Impact Assessment (PIA) process during development and evaluation stages.
- D. Develop training programs that aid the developers in understanding how to turn privacy requirements into actionable code and design level specifications.

Correct Answer: D

Community vote distribution

C (50%)	A (50%)
---------	---------

- pipzz 2 years ago

Selected Answer: A

A framework would be the foundation on which operations and development teams can determine privacy requirements and build privacy into design at the start of all projects.

upvoted 2 times
- Sbowo 2 years, 6 months ago

I think it is C, both book stated Privacy review or PIA as the next step after PbD commitment

upvoted 2 times
- k4d4v4r 2 years, 7 months ago

PIA is only required for high risk projects and stuff like that

upvoted 1 times
- 837vq3 2 years, 7 months ago

Selected Answer: C

Isn't "C" more appropriate?

upvoted 2 times

SCENARIO -

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis.

LBH also implements

Privacy by Design (PbD) into the application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent.

What is the best way to ensure that the application only collects personal data that is needed to fulfill its primary purpose of providing potential medical and healthcare recommendations?

- A. Obtain consent before using personal health information for data analytics purposes.
- B. Provide the user with an option to select which personal data the application may collect.
- C. Disclose what personal data the application the collecting in the company Privacy Policy posted online.
- D. Document each personal category collected by the app and ensure it maps to an app function or feature.

Correct Answer: C

Community vote distribution

D (100%)

[Removed]

10 months, 3 weeks ago

Selected Answer: D

Should be D

upvoted 1 times

Ahpl

2 years, 4 months ago

A, B and C deal with transparency and choice principles. D deals with data minimization. Therefore, D is a better answer.

upvoted 2 times

187san

2 years, 7 months ago

Selected Answer: D

D

For sure , its a straight forward question

upvoted 3 times

837vq3

2 years, 8 months ago

I think "D" is a better choice.

upvoted 2 times

k4d4v4r

2 years, 8 months ago

Did you already take the exam? How did it go?

upvoted 1 times

837vq3

2 years, 7 months ago

no, not yet.

upvoted 1 times

SCENARIO -

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis.

LBH also implements

Privacy by Design (PbD) into the application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) for the new Light Blue Health application currently in development. Which of the following best describes a risk that is likely to result in a privacy breach?

- A. Limiting access to the app to authorized personnel.
- B. Including non-transparent policies, terms and conditions in the app.
- C. Insufficiently deleting personal data after an account reaches its retention period.
- D. Not encrypting the health record when it is transferred to the Light Blue Health servers.

Correct Answer: A

Community vote distribution

D (50%)

C (50%)

- PaigeH7 4 months ago

Selected Answer: D

encrypting health records

upvoted 1 times

z80r 1 year, 6 months ago

Selected Answer: D

D my friends

upvoted 1 times

64wlg_CBD 2 years, 5 months ago

B. If it's a paid app it will only be accessible to paid users.

upvoted 1 times

Sbowo 2 years, 6 months ago

D, the risk of privacy breach is much more higher if the data is not encrypted during transport

upvoted 3 times

187san 2 years, 7 months ago

D

If you don't encrypt , PHI its breach of HIPAA security rule

upvoted 2 times

837vq3 2 years, 7 months ago

Selected Answer: C

i think its C

upvoted 2 times

k4d4v4r 2 years, 8 months ago

I think it's B and C.
upvoted 1 times

  **837vq3** 2 years, 8 months ago

A privacy impact assessment (PIA) is an analysis of how personal information is handled throughout the data life cycle within an organization. A PIA ensures that organizations apply legal, regulatory and policy requirements regarding privacy, assesses privacy risks, and methods of risk mitigation. A significant goal of performing a PIA is to compel an organization to think about the choices it makes for its processes and how those choices will impact privacy. Privacy technologists can utilize the findings of a PIA to determine whether privacy risk is appropriately addressed using the privacy policies and procedure
upvoted 2 times

  **837vq3** 2 years, 8 months ago

I think it should be "C"
upvoted 1 times

阿泽Vx: est258258

SCENARIO -

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis.

LBH also implements

Privacy by Design (PbD) into the application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent.

Regarding the app, which action is an example of a decisional interference violation?

- A. The app asks income level to determine the treatment of care.
- B. The app sells aggregated data to an advertising company without prior consent.
- C. The app has a pop-up ad requesting sign-up for a pharmaceutical company newsletter.
- D. The app asks questions during account set-up to disclose family medical history that is not necessary for the treatment of the individual's symptoms.

Correct Answer: D

Community vote distribution

A (100%)

- Ahpl 2 years, 4 months ago

A is the right answer

upvoted 1 times
- nabomi13 2 years, 5 months ago

Thanks to RealExamDumps for giving me pleasure by helping me out with CIPM Exam Questions. I was not sure when I downloaded this compact pdf file. Certified Information Privacy Manager (CIPM) PDF Questions proved to be very fruitful.

upvoted 1 times
- 64wlg_CBD 2 years, 5 months ago

There is no decision to make in scenario D. A is the right answer.

upvoted 1 times
- 187san 2 years, 7 months ago

A

No one asks for income level ,

upvoted 1 times
- k4d4v4r 2 years, 7 months ago

Selected Answer: A

Should be "A"

upvoted 1 times
- 837vq3 2 years, 7 months ago

Selected Answer: A

Income should not interference with the level of care

upvoted 1 times
- 837vq3 2 years, 8 months ago

Decisional interference is an action by an external party, such as a government or the commercial entity, that interferes with an individual's decision-making regarding their personal affairs. Inaccurate data can lead to decisional interference. Including cross-checks for accuracy when information is transferred from a manual form into an electronic form, ensuring that backup storage mechanisms allow for updating information and including individuals in the review of their information are all crucial steps privacy technologists can take to ensure information is accurate and current, thus minimizing the risk of privacy harm.

upvoted 1 times

  **k4d4v4r** 2 years, 8 months ago

So do you think it's "A"?

upvoted 1 times

阿泽Vx: est258258

SCENARIO -

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis.

LBH also implements

Privacy by Design (PbD) into the application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent.

What is the best way to minimize the risk of an exposure violation through the use of the app?

- A. Prevent the downloading of photos stored in the app.
- B. Dissociate the patient health data from the personal data.
- C. Exclude the collection of personal information from the health record.
- D. Create a policy to prevent combining data with external data sources.

Correct Answer: D

Community vote distribution

B (100%)

- ch19

11 months ago

D is the correct answer, as "exposure" violate means exposing an individual's data from external resources, whcih can be addressed by D

upvoted 1 times
- frikkylanky

1 year ago

Who provides these answers and how do we tell what is correct. Based on studying dissociation seems like the correct answer.

upvoted 1 times
- z80r

1 year, 6 months ago

Selected Answer: B

B for me

upvoted 1 times
- 187san

2 years, 7 months ago

B it is

upvoted 1 times
- k4d4v4r

2 years, 7 months ago

Selected Answer: B

If you disassociate, you won't be able to determine which one has which illness... then limits the risk of exposure ("oh that guy is sick...gross")

upvoted 1 times
- k4d4v4r

2 years, 7 months ago

Can someone comment?

upvoted 1 times

Not updating software for a system that processes human resources data with the latest security patches may create what?

- A. Authentication issues.
- B. Privacy vulnerabilities.
- C. Privacy threat vectors.
- D. Reportable privacy violations.

Correct Answer: B

When should code audits be concluded?

- A. At code check-in time.
- B. At engineering design time.
- C. While code is being sent to production.
- D. Before launch after all code for a feature is complete.

Correct Answer: D

Reference:

<https://softwarehut.com/blog/business/code-audit>

Community vote distribution

A (100%)

- ofirga 5 months ago

The correct answer id D.
When to Conduct Code Audits:
Before Launch: Audits should be concluded before launching a feature or releasing the software.
Throughout Development: Regular audits during development catch issues early.

upvoted 2 times
- ME79 1 year, 9 months ago

Selected Answer: A

Checking-in code means to upload code to main branch repository so that its administrator can review the code and finally update the project version

upvoted 1 times
- 187san 2 years, 7 months ago

A is the answer

upvoted 1 times
- 837vq3 2 years, 8 months ago

should it be 'B'? Isn't it too late when you do an audit at "d" stage?

upvoted 1 times
- k4d4v4r 2 years, 8 months ago

Code audits are also known as SAST and should be done after a feature is completed, so the code can be reviewed and then you run a DAST (dynamic auditing on the compiled code) before completing the development

upvoted 3 times
- am2005 2 years, 3 months ago

which one is correct ?

upvoted 1 times

A company configures their information system to have the following capabilities:

☞ Allow for selective disclosure of attributes to certain parties, but not to others.

Permit the sharing of attribute references instead of attribute values - such as `I am over 21` instead of birthday date.

▪

☞ Allow for information to be altered or deleted as needed.

These capabilities help to achieve which privacy engineering objective?

- A. Predictability.
- B. Manageability.
- C. Disassociability.
- D. Integrity.

Correct Answer: C

Community vote distribution

B (50%)	C (50%)
---------	---------

- Doraaaaaaaaa** 6 months, 2 weeks ago

Selected Answer: B

Manageability refers to the ability to granularly administer personal information, including modification, disclosure and deletion. Disassociability is the minimization of connections between data and individuals to the extent compatible with system operational requirements. .is minimization can take many forms, from maximally disassociated data in the form of high-level aggregated data, for example, to de-identified records pertaining to distinct individuals. Disassociability can also take the form of architectural data separation, in which identifiable.

upvoted 2 times
- 3444** 11 months ago

Selected Answer: C

C is correct

upvoted 1 times
- z80r** 1 year, 6 months ago

Selected Answer: C

C is correct

upvoted 1 times
- Ahpl** 2 years, 4 months ago

*it should be B - Manageability

upvoted 4 times
- 837vq3** 2 years, 8 months ago

NIST's Privacy Engineering Program has proposed three privacy engineering objectives: predictability, manageability and disassociability.

Disassociability is the minimization of connections between data and individuals to the extent compatible with system operational requirements. This minimization can take many forms, from maximally disassociated data in the form of high-level aggregated data, to de-identified records pertaining to distinct individuals. Disassociability can also take the form of architectural data separation, in which identifiable personal information is kept segregated from, but still linkable to, transactional data

upvoted 2 times

Which of the following functionalities can meet some of the General Data Protection Regulation's (GDPR's) Data Portability requirements for a social networking app designed for users in the EU?

- A. Allow users to modify the data they provided the app.
- B. Allow users to delete the content they provided the app.
- C. Allow users to download the content they have provided the app.
- D. Allow users to get a time-stamped list of what they have provided the app.

Correct Answer: C

Which of the following is the least effective privacy preserving practice in the Systems Development Life Cycle (SDLC)?

- A. Conducting privacy threat modeling for the use-case.
- B. Following secure and privacy coding standards in the development.
- C. Developing data flow modeling to identify sources and destinations of sensitive data.
- D. Reviewing the code against Open Web Application Security Project (OWASP) Top 10 Security Risks.

Correct Answer: C

Community vote distribution

D (100%)

-   **ofirga** 5 months ago
Selected Answer: D
I think it's D. It focuses on security more than privacy.
upvoted 2 times
-   **ofirga** 5 months ago
I think it's D. It focuses on security more than privacy.
upvoted 1 times

Which of the following is a vulnerability of a sensitive biometrics authentication system?

- A. Theft of finely individualized personal data.
- B. Slow recognition speeds.
- C. False negatives.
- D. False positives.

Correct Answer: *thB*

Community vote distribution

C (100%)

- z80r** 1 year, 6 months ago

Selected Answer: C

it's C guys

upvoted 1 times
- Scynor** 1 year, 9 months ago

Selected Answer: C

The answer is C biometrics are more often prone to false negatives than anything else.

upvoted 1 times
- 187san** 2 years, 7 months ago

i think its A

upvoted 2 times
- sirpuzee** 2 years, 9 months ago

The correct answer is C. The more sensitive a biometric system is, the more prone it is to false negatives. IAPP Privacy in Technology publication page 119.

upvoted 2 times

阿泽Vx: est258258

nd

Between November 30 -
and December 2
, 2013, cybercriminals successfully infected the credit card payment systems and bypassed security controls of a
United States-based retailer with malware that exfiltrated 40 million credit card numbers. Six months prior, the retailer had malware detection
software installed to prevent against such an attack.
Which of the following would best explain why the retailer's consumer data was still exfiltrated?

- A. The detection software alerted the retailer's security operations center per protocol, but the information security personnel failed to act upon the alerts.
- B. The U.S Department of Justice informed the retailer of the security breach on Dec. 12th, but the retailer took three days to confirm the breach and eradicate the malware.
- C. The IT systems and security measures utilized by the retailer's third-party vendors were in compliance with industry standards, but their credentials were stolen by black hat hackers who then entered the retailer's system.
- D. The retailer's network that transferred personal data and customer payments was separate from the rest of the corporate network, but the malware code was disguised with the name of software that is supposed to protect this information.

Correct Answer: B

Community vote distribution

A (100%)

- ofirga** 5 months ago

Selected Answer: A

A is the answer!

upvoted 2 times
- ChaChaMcGraw** 2 years, 2 months ago

How sure are we on these answers?

upvoted 1 times
- Ahpl** 2 years, 4 months ago

A is the answer because data is "still" leaked.

upvoted 1 times
- 187san** 2 years, 7 months ago

A is the answer

upvoted 1 times
- flyingrain777** 2 years, 7 months ago

Agree A is a better answer.

upvoted 1 times
- k4d4v4r** 2 years, 8 months ago

B was definately not written in the question. A is better.

upvoted 1 times
- pipzz** 2 years, 8 months ago

A is the correct answer. This case study relates to the well known Target Data Breach. It is reported in many sources that their security operations did not respond to alerts that had picked up the suspicious activity. See <https://arxiv.org/pdf/1701.04940.pdf>

Although B is true about what happened in the case, that Department of Justice notification was after the exfiltration and does not explain best why the retailer's consumer data was still exfiltrated.

upvoted 2 times
- k4d4v4r** 2 years, 8 months ago

Did you take the exam? How did it go?

upvoted 1 times
- 837vq3** 2 years, 8 months ago

This one is confusing. All of the options are feasible in an incident situation.

upvoted 1 times

Question #137

Topic 1

When analyzing user data, how is differential privacy applied?

- A. By injecting noise into aggregated datasets.
- B. By assessing differences between datasets.
- C. By applying asymmetric encryption to datasets.
- D. By removing personal identifiers from datasets.

Correct Answer: A

🗨️ 👤 **837vq3** 2 years, 8 months ago

One way to prevent reverse engineering is to “blur” the data points by using noise addition through differential privacy. The goal is to ensure that the aggregated data is still useful, while also making it nonspecific enough to avoid revealing the underlying identifiers. This is done by using an algorithm to generate values that remain meaningful and yet are nonspecific.

upvoted 1 times

Question #138

Topic 1

What privacy risk is NOT mitigated by the use of encrypted computation to target and serve online ads?

- A. The ad being served to the user may not be relevant.
- B. The user's sensitive personal information is used to display targeted ads.
- C. The personal information used to target ads can be discerned by the server.
- D. The user's information can be leaked to an advertiser through weak de-identification techniques.

Correct Answer: D

A company seeking to hire engineers in Silicon Valley ran an ad campaign targeting women in a specific age range who live in the San Francisco Bay Area.

Which Calo objective privacy harm is likely to result from this campaign?

- A. Lost opportunity.
- B. Economic loss.
- C. Loss of liberty.
- D. Social detriment.

Correct Answer: D

Community vote distribution

A (100%)

-   **ofirga** 5 months ago

Selected Answer: A

Lost of business opportunity is Objective Harm.

upvoted 1 times
-   **ChaChaMcGraw** 2 years, 2 months ago

"The objective category of privacy harm is the unanticipated or coerced use of information concerning a person against that person. These are negative, external actions justified by reference to personal information." The definition seems to turn on the idea of unanticipated or coerced use of information against the person. In that light, it could only be social detriment, because the only data subjects are the female programmers. It is not a good answer, by the way. A - Lost opportunity is not applicable to women applying for a job - although it could apply to men who want the job. But in Calo's privacy harm formulation, it is the use of personal data against the person who is providing it, not others in the population.

upvoted 1 times
-   **Ahpl** 2 years, 4 months ago

A is the correct answer. Refer to pg 211 of PbD book

upvoted 4 times

Which of the following modes of interaction often target both people who personally know and are strangers to the attacker?

- A. Spam.
- B. Phishing.
- C. Unsolicited sexual imagery.
- D. Consensually-shared sexual imagery.

Correct Answer: B

Community vote distribution

B (100%)

-   **ofirga** 5 months ago

Selected Answer: B

B. Phishing is a mode of interaction that often targets both people who personally know the attacker and strangers. Phishing attempts involve tricking individuals into revealing sensitive information (such as login credentials or financial details) by posing as a trustworthy entity. These deceptive messages can be sent to a wide range of recipients, including acquaintances and unknown individuals. It's essential to stay vigilant and verify the legitimacy of any requests for personal information to avoid falling victim to phishing attacks.

upvoted 1 times
-   **Sbowo** 2 years, 6 months ago

Spam. Sometimes email from friends labeled as spam even it doesn't

upvoted 1 times
-   **k4d4v4r** 2 years, 8 months ago

Phishing: When you don't know
Spear Phishing: Directed to someone you know

upvoted 2 times

What logs should an application server retain in order to prevent phishing attacks while minimizing data retention?

- A. Limited-retention, de-identified logs including only metadata.
- B. Limited-retention, de-identified logs including the links clicked in messages as well as metadata.
- C. Limited-retention logs including the identity of parties sending and receiving messages as well as metadata.
- D. Limited-retention logs including the links clicked in messages, the identity of parties sending and receiving them, as well as metadata.

Correct Answer: B

Which of the following would be the most appropriate solution for preventing privacy violations related to information exposure through an error message?

- A. Configuring the environment to use shorter error messages.
- B. Handling exceptions internally and not displaying errors to the user.
- C. Creating default error pages or error messages which do not include variable data.
- D. Logging the session name and necessary parameters once the error occurs to enable trouble shooting.

Correct Answer: C

In day to day interactions with technology, consumers are presented with privacy choices. Which of the following best represents the Privacy by Design (PbD) methodology of letting the user choose a non-zero-sum choice?

- A. Using images, words, and contexts to elicit positive feelings that result in proactive behavior, thus eliminating negativity and biases.
- B. Providing plain-language design choices that elicit privacy-related responses, helping users avoid errors and minimize the negative consequences of errors when they do occur.
- C. Displaying the percentage of users that chose a particular option, thus enabling the user to choose the most preferred option.
- D. Using contexts, antecedent events, and other priming concepts to assist the user in making a better privacy choice.

Correct Answer: B

What risk is mitigated when routing video traffic through a company's application servers, rather than sending the video traffic directly from one user to another?

- A. The user is protected against phishing attacks.
- B. The user's identity is protected from the other user.
- C. The user's approximate physical location is hidden from the other user.
- D. The user is assured that stronger authentication methods have been used.

Correct Answer: B

  **Stants** 4 months, 3 weeks ago
It should be C
upvoted 2 times

  **Stants** 4 months, 3 weeks ago
C. The user's approximate physical location is hidden from the other user.

When routing video traffic through a company's application servers, rather than sending it directly from one user to another (a peer-to-peer approach), one of the risks mitigated is that the user's approximate physical location is hidden from the other user. This is because the traffic is routed through intermediary servers, which can obscure the originating user's IP address or location information, providing an additional layer of privacy protection. This approach helps enhance user privacy by preventing direct visibility of each user's location by other participants in the communication.

upvoted 2 times

阿泽Vx: est258258

Organizations understand there are aggregation risks associated with the way the process their customer's data. They typically include the details of this aggregation risk in a privacy notice and ask that all customers acknowledge they understand these risks and consent to the processing.

What type of risk response does this notice and consent represent?

- A. Risk transfer.
- B. Risk mitigation.
- C. Risk avoidance.
- D. Risk acceptance.

Correct Answer: A

Community vote distribution

D (75%)B (25%)

- perryhan** 4 months, 1 week ago

Selected Answer: B

B. Risk mitigation
the NIST Privacy Control IP-1 on consent requires the system to provide individuals a mechanism to authorize the collection of their personal information, where feasible. This control may address a class of adverse privacy events, such as exclusion, which occurs when the individual does not have knowledge of, or participate in, the use of their personal information. If this use is made overt and the individual is permitted to authorize the use of their information for this purpose, then this risk to the individual is mitigated

upvoted 1 times
- ChaChaMcGraw** 2 years, 2 months ago

The question is looking at it from the organization's point of view. The user is accepting the risk, the organization is transferring the risk to the user.

upvoted 2 times
- zlzl** 2 years, 2 months ago

Selected Answer: D

Still accepted this risk

upvoted 3 times
- am2005** 2 years, 2 months ago

logical

upvoted 1 times
- bonitapat** 2 years, 4 months ago

why A Risk Transfer ???

upvoted 1 times

Which is likely to reduce the types of access controls needed within an organization?

- A. Decentralization of data.
- B. Regular data inventories.
- C. Standardization of technology.
- D. Increased number of remote employees.

Correct Answer: C

What is an Access Control List?

- A. A list of steps necessary for an individual to access a resource.
- B. A list that indicates the type of permission granted to each individual.
- C. A list showing the resources that an individual has permission to access.
- D. A list of individuals who have had their access privileges to a resource revoked.

Correct Answer: C

Reference:
<https://searchsoftwarequality.techtarget.com/definition/access-control-list>

Community vote distribution

B (75%)

C (25%)

- Doraaaaaaaaa** 6 months, 2 weeks ago

Selected Answer: C

an access-control list (ACL) is a list of permissions[a] associated with a system resource (object or facility). An ACL specifies which users or system processes are granted access to resources, as well as what operations are allowed on given resources.

upvoted 1 times
- Doraaaaaaaaa** 6 months, 2 weeks ago

One approach for specifying access-control policy is using access-control lists (ACLs). In this approach, every object is annotated with a list of the subjects who are allowed to access it, as well as the type of access that they are allowed.

upvoted 1 times
- z80r** 1 year, 6 months ago

Selected Answer: B

b guys

upvoted 1 times
- Sara_sw** 1 year, 8 months ago

Selected Answer: B

An access control list (ACL) is a list of rules that specifies which users or systems are granted or denied access to a particular object or system resource.

upvoted 1 times
- pipzz** 2 years ago

Selected Answer: B

A list showing who has access to a resource and at what level, NOT a list of the resources a user has access to. Even the article makes it clear.

upvoted 1 times

Which of the following is an example of drone `swarming`?

- A. A drone filming a cyclist from above as he rides.
- B. A drone flying over a building site to gather data.
- C. Drones delivering retailers' packages to private homes.
- D. Drones communicating with each other to perform a search and rescue.

Correct Answer: D

An individual drives to the grocery store for dinner. When she arrives at the store, she receives several unsolicited notifications on her phone about discounts on items at the grocery store she is about to shop at. Which type of privacy problem does this represent?

- A. Intrusion
- B. Surveillance
- C. Decisional Interference
- D. Exposure

Correct Answer: A

What is the most effective first step to take to operationalize Privacy by Design principles in new product development and projects?

- A. Implementing a mandatory privacy review and legal approval process.
- B. Obtain leadership buy-in for a mandatory privacy review and approval process.
- C. Set up an online Privacy Impact Assessment tool to facilitate Privacy by Design compliance.
- D. Conduct annual Privacy by Design training and refreshers for all impacted personnel.

Correct Answer: B

Which of the following is NOT a step in the methodology of a privacy risk framework?

- A. Assessment
- B. Monitoring
- C. Response
- D. Ranking

Correct Answer: D

Which of the following occurs when an individual takes a specific observable action to indicate and confirm that they give permission for their information to be processed?

- A. Express consent
- B. Implied consent
- C. Informed notice
- D. Authorized notice

Correct Answer: A

A BaaS provider backs up the corporate data and stores it in an outsider provider under contract with the organization. A researcher notifies the organization that he found unsecured data in the cloud. The organization looked into the issue and realized one of its backups was misconfigured on the outside provider's cloud and the data fully exposed to the open internet. They quickly secured the backup. Which is the best next step the organization should take?

- A. Review the content of the data exposed
- B. Review its contract with the outside provider
- C. Investigate how the researcher discovered the unsecured data
- D. Investigate using alternate BaaS providers or on-premise backup systems

Correct Answer: A

An organization is launching a new online subscription-based publication. As the service is not aimed at children, users are asked for their date of birth as part of the of the sign-up process. The privacy technologist suggests it may be more appropriate to ask if an individual is over 18 rather than requiring they provide a date of birth. What kind of threat is the privacy technologist concerned about?

- A. Identification
- B. Insecurity
- C. Interference
- D. Minimization

Correct Answer: D

  **perryhan** 4 months, 1 week ago
Is minimization a threat? ?
upvoted 1 times

Combining multiple pieces of information about an individual to produce a whole that is greater than the sum of its parts is called?

- A. Identification
- B. Insecurity
- C. Aggregation
- D. Exclusion

Correct Answer: C

An organization is concerned that its aging IT infrastructure will lead to increased security and privacy risks. Which of the following would help mitigate these risks?

- A. Vulnerability management
- B. Data Loss Prevention
- C. Code audits
- D. Network Centricity

Correct Answer: A

An organization has recently experienced a data breach where large amounts of personal data were compromised. As part of a post-incident review, the privacy technologist wants to analyze available data to understand what vulnerabilities may have contributed to the incident occurring. He learns that a key vulnerability had been flagged by the system but that detective controls were not operating effectively. Which type of web application security risk does this finding most likely point to?

- A. Insecure Design
- B. Misconfiguration
- C. Vulnerable and Outdated Components
- D. Logging and Monitoring Failures

Correct Answer: D

- There are two groups of users in a company, where one group is allowed to see credit card numbers, while the other group is not. Both are accessing the data through the same application. The most effective and efficient way to achieve this would be?
- A. Have two copies of the data, one copy where the credit card numbers are obfuscated, while the other copy has them in the clear. Serve up from the appropriate copy depending on the user accessing it.
 - B. Have the data encrypted at rest, and selectively decrypt it for the users who have the rights to see it.
 - C. Obfuscate the credit card numbers whenever a user who does not have the right to see them accesses the data.
 - D. Drop credit card numbers altogether whenever a user who does not have the right to see them accesses the data.

Correct Answer: B

 **Stants** 4 months, 3 weeks ago

The most effective and efficient way to achieve this would be C. Obfuscate the credit card numbers whenever a user who does not have the right to see them accesses the data.

This approach ensures that all users are accessing the same single source of data, which is important for maintaining data consistency and integrity. It also avoids the need to manage multiple copies of the data (as in option A) or to manage encryption keys (as in option B).

When a user who does not have the right to see the credit card numbers accesses the data, the system can dynamically obfuscate the credit card numbers. This means replacing the numbers with symbols or other characters, making the actual numbers unreadable.

Option D, dropping credit card numbers altogether for certain users, could potentially disrupt business operations if those users need to access other parts of the data record that are linked to the credit card numbers.

upvoted 1 times

- Which of the following is NOT a valid basis for data retention?
- A. Size of the data
 - B. Type of the data
 - C. Location of the data
 - D. Last time the data was accessed

Correct Answer: A

An organization needs to be able to manipulate highly sensitive personal information without revealing the contents of the data to the users. The organization should investigate the use of?

- A. Advanced Encryption Standard (AES)
- B. Homomorphic encryption
- C. Quantum encryption
- D. Pseudonymization

Correct Answer: B

A jurisdiction requiring an organization to place a link on the website that allows a consumer to opt-out of sharing is an example of what type of requirement?

- A. Functional
- B. Operational
- C. Technical
- D. Use case

Correct Answer: A

Which of the following is the LEAST effective at meeting the Fair Information Practice Principles (FIPPs) in the Systems Development Life Cycle (SDLC)?

- A. Conducting privacy threat modeling for the use-case
- B. Following secure and privacy coding standards in the development
- C. Developing data flow modeling to help the purpose, protection and retention of sensitive data
- D. Reviewing the code against Open Web Application Security Project (OWASP) Top 10 Security Risks

Correct Answer: D

  **DrMai** 9 months, 3 weeks ago

where can you find the reference to this question?
upvoted 1 times

An organization is launching a smart watch which, in addition to alerts, will notify the wearer of incoming calls allowing them to answer on the device. This convenience also comes with privacy concerns and is an example of?

- A. Value-Sensitive Design
- B. Ubiquitous computing
- C. Anthropomorphism
- D. Coupling

Correct Answer: B

Community vote distribution

B (100%)

  **dmi_air** 1 year, 1 month ago

Selected Answer: B

B is right

upvoted 2 times

What is the main issue pertaining to data protection with the use of 'deep fakes'?

- A. Misinformation
- B. Non-conformity with the accuracy principle
- C. Issues with establishing non-repudiation
- D. Issues with confidentiality of the information

Correct Answer: B

Which of the following best describes the basic concept of "Privacy by Design?"

- A. The adoption of privacy enhancing technologies
- B. The integration of a privacy program with all lines of business
- C. The implementation of privacy protection through system architecture
- D. The introduction of business process to identify and assess privacy gaps

Correct Answer: C

Which of the following methods does NOT contribute to keeping the data confidential?

- A. Differential privacy
- B. Homomorphic encryption
- C. k-anonymity
- D. Referential integrity

Correct Answer: D

What element is most conducive to fostering a sound privacy by design culture in an organization?

- A. Ensuring all employees acknowledge and understood the privacy policy.
- B. Frequent privacy and security awareness training for employees.
- C. Monthly reviews of organizational privacy principles.
- D. Gaining advocacy from senior management.

Correct Answer: D

After stringent testing an organization has launched a new web-facing ordering system for its consumer medical products. As the medical products could provide indicators of health conditions, the organization could further strengthen its privacy controls by deploying?

- A. Run time behavior monitoring
- B. A content delivery network.
- C. Context aware computing.
- D. Differential identifiability.

Correct Answer: A

  **Stants** 4 months, 4 weeks ago
The organization could further strengthen its privacy controls by deploying Differential Identifiability. Differential identifiability is a privacy-enhancing technique that allows the organization to use and share aggregate information about user data, while minimizing the risk of identifying individual users. This is particularly important in the context of medical data, which can be sensitive and personal. It's worth noting that while the other options may have their own benefits in certain contexts, they do not directly address privacy concerns in the same way as differential identifiability.
upvoted 1 times

Machine-learning based solutions present a privacy risk because?

- A. Training data used during the training phase is compromised.
- B. The solution may contain inherent bias from the developers.
- C. The decision-making process used by the solution is not documented.
- D. Machine-learning solutions introduce more vulnerabilities than other software.

Correct Answer: C

An organization is launching a new smart speaker to the market. The device will have the capability to play music and provide news and weather updates. Which of the following would be a concern from a privacy perspective?

- A. Appropriation.
- B. Browser Fingerprinting.
- C. Context of authority.
- D. Context aware computing.

Correct Answer: C

Community vote distribution

D (100%)

PaigeH7 4 months ago

Selected Answer: D

Context aware computing
upvoted 1 times

SundusHatbi 9 months, 3 weeks ago

Is it D?
upvoted 1 times

Stants 4 months, 3 weeks ago

The main privacy concern for a smart speaker would be D. Context aware computing.

Smart speakers are typically always listening and have the ability to record and process conversations within their environment, not just the commands directed at them. This raises significant privacy concerns as they are context-aware - they can collect data about the user's behavior, preferences, routines, and even private conversations. This information could potentially be used in ways that the user did not intend or expect. Therefore, it's crucial to ensure that appropriate privacy safeguards are in place, such as clear user consent, data minimization, and strong data security measures.

upvoted 1 times

All of the following topics should be included in a workplace surveillance policy EXCEPT?

- A. Who can be tracked and when.
- B. Who can access surveillance data.
- C. What areas can be placed under surveillance.
- D. Who benefits from collecting surveillance data.

Correct Answer: D

Which of the following would be an example of an "objective" privacy harm to an individual?

- A. Receiving spam following the sale an of email address
- B. Negative feelings derived from government surveillance
- C. Social media profile views indicating unexpected interest in a person.
- D. Inaccuracies in personal data

Correct Answer: D

Which of the following is the best action to apply to personally identifiable data when the retention period ends?

- A. Hashing
- B. Pseudonymization
- C. Tagging.
- D. Deletion

Correct Answer: D

Which of the following is most important to provide to the data subject before the collection phase of the data lifecycle?

- A. Privacy Notice
- B. Disclosure Policy
- C. Consent Request
- D. Data Protection Policy

Correct Answer: C

- Stants

4 months, 3 weeks ago

The most important thing to provide to the data subject before the collection phase of the data lifecycle is C. Consent Request.

Before collecting personal data, it's crucial to obtain the data subject's consent. This ensures that the data subject is aware of and agrees to the data collection. It's a fundamental principle of data protection and privacy laws like the General Data Protection Regulation (GDPR).

That being said, it's also important to provide the data subject with a Privacy Notice (A) and a Data Protection Policy (D) so they understand how their data will be used, stored, and protected, and a Disclosure Policy (B) to inform them about any third-party sharing. However, these can often be provided as part of the consent request process, making the consent request the most critical element to provide before data collection begins.

upvoted 1 times
- SundusHatbi

9 months, 3 weeks ago

Should be A

upvoted 1 times

Which of the following is a stage in the data life cycle?

- A. Data classification
- B. Data inventory
- C. Data masking
- D. Data retention

Correct Answer: A

- fvo

6 months, 1 week ago

Answer is D

The components of the data life cycle—collection, use, disclosure, retention and destruction

upvoted 2 times
- SundusHatbi

9 months, 3 weeks ago

Should be D

upvoted 2 times
- DrMai

9 months, 3 weeks ago

I think the answer should be D

upvoted 2 times

An organization must terminate their cloud vendor agreement immediately What is the most secure way to delete the encrypted data stored in the cloud?

- A. Transfer the data to another location
- B. Invoke the appropriate deletion clause in the cloud terms and conditions.
- C. Obtain a destruction certificate from the cloud vendor
- D. Destroy all encryption keys associated with the data

Correct Answer: D

  **DrMai** 9 months, 3 weeks ago
what about B?
upvoted 1 times

When writing security policies, the most important consideration is to?

- A. Require all employees to read and acknowledge their understanding
- B. Ensure they are based on the organization's risk profile
- C. Ensure they cover enough details for common situations
- D. Follow industry best practices

Correct Answer: B

  **SundusHatbi** 9 months, 3 weeks ago
B or D
upvoted 1 times

  **SundusHatbi** 9 months, 3 weeks ago
B not D
upvoted 1 times

In terms of data extraction, which of the following should NOT be considered by a privacy technologist in relation to data portability?

- A. The size of the data
- B. The format of the data
- C. The range of the data
- D. The medium of the data

Correct Answer: D

- Stants

4 months, 3 weeks ago

The option that should NOT be considered by a privacy technologist in relation to data portability is D. The medium of the data.

Data portability, as defined by regulations like the General Data Protection Regulation (GDPR), is about providing individuals with the ability to obtain and reuse their personal data across different services. This involves securely transferring, copying, or moving data without hindrance to its usability.

While the size of the data (A), the format of the data (B), and the range of the data © are all important considerations for data portability (as they can affect the ease of transferring the data and its usability after transfer), the medium of the data (D) is not directly relevant.

upvoted 1 times
- SundusHatbi

9 months, 3 weeks ago

I think A

upvoted 1 times

Which activity should the privacy technologist undertake to reduce potential privacy risk when evaluating options to process data in a country other than where it would be collected?

- A. Review the Data Life Cycle
- B. Review data retention policies
- C. Create enterprise data flow diagrams
- D. Recommend controls for data transfers

Correct Answer: D

Information classification helps an organization protect confidential and nonpublic information primarily because?

- A. It helps identify sensitive and critical information that require very strict safeguards
- B. It falls under the security principles of confidentiality, integrity, and availability
- C. It promotes employee accountability for safeguarding confidential information
- D. It is legally required under most regulations

Correct Answer: A

When designing a new system, which of the following is a privacy threat that the privacy technologist should consider?

- A. Encryption
- B. Social distancing
- C. Social engineering
- D. Identity and Access Management

Correct Answer: D

Community vote distribution

C (100%)

-   **fvo** 6 months, 1 week ago

C

This is the only threat in the options provided

upvoted 1 times
-   **DrMai** 9 months, 3 weeks ago

Selected Answer: C

only social engineering is a privacy threat

upvoted 1 times
-   **DrMai** 9 months, 3 weeks ago

I think the answer should be C

upvoted 1 times

Ivan is a nurse for a home healthcare service provider in the US. The company has implemented a mobile application which Ivan uses to record a patient's vital statistics and access a patient's health care records during home visits. During one visit, Ivan is unable to access the health care application to record the patient's vitals. He instead records the information on his mobile phone's note-taking application to enter the data in the health care application the next time it is accessible. What would be the best course of action by the IT department to ensure the data is protected on his device?

- A. Provide all healthcare employees with mandatory annual security awareness training with a focus on the health information protection.
- B. Complete a SWOT analysis exercise on the mobile application to identify what caused the application to be inaccessible and remediate any issues.
- C. Adopt mobile platform standards to ensure that only mobile devices that support encryption capabilities are used.
- D. Implement Mobile Device Management (MDM) to enforce company security policies and configuration settings.

Correct Answer: D

Which activity best supports the principle of data quality from a privacy perspective?

- A. Ensuring the data is classified
- B. Protecting the data against unauthorized access
- C. Ensuring the data is available for use
- D. Protecting the data against unauthorized changes

Correct Answer: B

🗲️ 👤 **fvo** 6 months, 1 week ago

D
Data Quality refers to data accuracy and correctness
upvoted 3 times

🗲️ 👤 **securedBNB** 9 months ago

Without access, you can't unauthorised changes. Hence B
upvoted 1 times

🗲️ 👤 **SundusHatbi** 9 months, 3 weeks ago

Could be D?
upvoted 3 times

Which of the following is one of the fundamental principles of information security?

- A. Accountability
- B. Accessibility
- C. Confidentiality
- D. Connectivity

Correct Answer: C

An organization's customers have suffered a number of data breaches through successful social engineering attacks. One potential solution to remediate and prevent future occurrences would be to implement which of the following?

- A. Differential identifiability
- B. Multi-factor authentication
- C. Greater password complexity
- D. Attribute-based access control

Correct Answer: B

A clinical research organization is processing highly sensitive personal data including numerical attributes, from medical trial results. The organization needs to manipulate the data without revealing the contents to data users. This can be achieved by utilizing?

- A. k - anonymity
- B. Microdata sets
- C. Polymorphic encryption
- D. Homomorphic encryption

Correct Answer: D

To meet data protection and privacy legal requirements that may require personal data to be disposed of or deleted when no longer necessary for the use it was collected, what is the best privacy-enhancing solution a privacy technologist should recommend be implemented in application design to meet this requirement?

- A. Implement a process to delete personal data on demand and maintain records on deletion requests
- B. Implement automated deletion of off-site backup of personal data based on annual risk assessments
- C. Develop application logic to validate and purge personal data according to legal hold status or retention schedule
- D. Securely archive personal data not accessed or used in the last 6 months. Automate a quarterly review to delete data from archive once no longer needed

Correct Answer: C

An organization is reliant on temporary contractors for performing data analytics and they require access to personal data via software-as-a-service to perform their job. When the temporary contractor completes their work assignment, what would be the most effective way to safeguard privacy and access to personal data when they leave?

- A. Set a system-based expiry that requires management reauthorization for online access for accounts that have been active more than 6 months
- B. Establish a predetermined automatic account expiration date based on contract timescales
- C. Require temporary contractors to sign a non-disclosure agreement security acceptable use policy and online access authorizations by hiring managers
- D. Mandate hiring managers to email IT or Security team when the contractor leaves

Correct Answer: B

SCENARIO -

Please use the following to answer the next question:

Light Blue Health (LBH) is a healthcare technology company developing a new web and mobile application that collects personal health information from electronic patient health records. The application will use machine learning to recommend potential medical treatments and medications based on information collected from anonymized electronic health records. Patient users may also share health data collected from other mobile apps with the LBH app.

The application requires consent from the patient before importing electronic health records into the application and sharing it with their authorized physicians or healthcare provider. The patient can then review and share the recommended treatments with their physicians securely through the app. The patient user may also share location data and upload photos in the app. The patient user may also share location data and upload photos in the app for a healthcare provider to review along with the health record. The patient may also delegate access to the app.

LBH's privacy team meets with the Application development and Security teams, as well as key business stakeholders on a periodic basis. LBH also implements Privacy by Design (PbD) into the application development process.

The Privacy Team is conducting a Privacy Impact Assessment (PIA) to evaluate privacy risks during development of the application. The team must assess whether the application is collecting descriptive, demographic or any other user related data from the electronic health records that are not needed for the purposes of the application. The team is also reviewing whether the application may collect additional personal data for purposes for which the user did not provide consent.

What is the best way to minimize the potential harms from a data breach?

- A. Dissociate the patient health data from the personal data
- B. Employ Multi-Factor Authentication (MFA) to access the app
- C. Exclude the collection of personal information from the health record
- D. Ensure that all files collected by the app and stored on the device are password-protected

Correct Answer: B

  **fvo** 6 months, 1 week ago

A

To minimize the potential harms from a data breach, you need to reduce the attack surface. In this case, Disassociaiblity- Dissociate the patient health data from the personal data, so whoever gets the health data cannot link it to the respective owners

upvoted 2 times

Which of the following is a privacy consideration for NOT sending large-scale SPAM type emails to a database of email addresses?

- A. Poor user experience
- B. Emails are unsolicited
- C. Data breach notification
- D. Reduction in email deliverability score

Correct Answer: B

🗨️ 👤 **fvo** 6 months, 1 week ago

A

From the options, the best way to minimize the potential harms from a data breach is A

upvoted 1 times

Which of the following can be used to bypass even the best physical and logical security mechanisms to gain access to a system?

- A. Phishing emails
- B. Denial of service
- C. Brute-force attacks
- D. Social engineering

Correct Answer: D

阿泽Vx: est258258

An organization is deciding between building a solution in-house versus purchasing a solution for a new customer facing application. When security threats are taken into consideration, a key advantage of purchasing a solution would be the availability of?

- A. Outsourcing
- B. Persistent VPN
- C. Patching and updates
- D. Digital Rights Management

Correct Answer: C

Which of the following best describes a network threat model and its uses?

- A. It is used in software development to detect programming errors
- B. It is a risk-based model used to calculate the probabilities of risks identified during vulnerability tests
- C. It helps assess the probability, the potential harm, and the priority of attacks to help minimize or eradicate the threats
- D. It combines the results of vulnerability and penetration tests to provide useful insights into the network's overall threat and security posture

Correct Answer: C

Failing to update software for a system that processes human resources data with the latest security patches may create what?

- A. Privacy vulnerabilities
- B. Data integrity issues
- C. Increased threat sources
- D. Data breaches

Correct Answer: D

Data oriented strategies include which of the following?

- A. Minimize, Separate, Abstract, Hide
- B. Inform, Control, Enforce, Demonstrate
- C. Encryption, Hashing, Obfuscation, Randomization
- D. Consent, Contract, Legal Obligation, Legitimate interests

Correct Answer: D

-   **fvo** 6 months, 1 week ago
A
data-oriented strategies include: separating the data, minimizing the data, abstracting the data and hiding the data
upvoted 2 times
-   **DrMai** 9 months, 3 weeks ago
I think it should be A
upvoted 1 times
-   **frikkylanky** 1 year ago
how is D - Consent, contract, legal obligation the answer to Data oriented strategies!!
upvoted 2 times

It is important for a privacy technologist to understand dark patterns in order to reduce the risk of which of the following?

- A. Breaches of an individual's data
- B. Illicit collection of personal data
- C. Manipulation of a user's choice
- D. Discrimination from profiling

Correct Answer: C

What is the goal of technologies such as multiparty computation and differential privacy?

- A. To provide an appropriate technical and organizational level of security appropriate to the risk
- B. To standardize privacy activities across organizational groups
- C. To protect sensitive data while maintaining its utility
- D. To process the data in order to remove identifiers

Correct Answer: C

Which of the following is an example of a just-in-time notice?

- A. A browser warning that a website may be unsafe
- B. An SMS sent to authorize access to an app
- C. A credit card company using Multi-Factor Authentication (MFA) to authorize a purchase
- D. Privacy information given to a user when he attempts to comment on an online article

Correct Answer: C

 **Stants** 4 months, 3 weeks ago

An example of a just-in-time notice is D. Privacy information given to a user when he attempts to comment on an online article.

Just-in-time notices are privacy notices that are provided to the user at the moment they are about to provide personal data. In this case, the user is given privacy information exactly when they are about to comment on an online article, which likely involves providing some personal data such as their name or email address. This allows the user to make an informed decision about whether to proceed with providing their data.

The other options (A, B, and C) are security measures or notifications, but they do not necessarily provide privacy information at the point of data collection, so they are not considered just-in-time notices.

upvoted 1 times

Which of the following is NOT a mechanism to de-identify data?

- A. Aggregation
- B. Interpolation
- C. Obfuscation
- D. Truncation

Correct Answer: B

How does k-anonymity help to protect privacy in micro data sets?

- A. By ensuring that every record in a set is part of a group of “K” records having similar identifying information.
- B. By switching values between “K” records in order to preserve most statistics while still maintaining privacy
- C. By adding sufficient noise to the data in order to hide the impact of any one individual
- D. By encrypting data using value “K” to create ciphertext

Correct Answer: B

Community vote distribution

A (100%)

  **DrMai** 8 months, 4 weeks ago

Selected Answer: A

This should be A

upvoted 2 times

Which of the following techniques describes the use of encryption where encryption keys are divided into parts that can then be used to recover a full encryption key?

- A. Homomorphic encryption
- B. Asymmetric cryptography
- C. Cryptographic hashing
- D. Secret sharing

Correct Answer: D

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

What is likely to be the biggest privacy concern with the current 'Information Sharing and Consent' page?

- A. The ON or OFF default setting for each item.
- B. The navigation needed in the app to get to the consent page.
- C. The option to consent to receive potential marketing information.
- D. The information sharing with healthcare providers affiliated with the company.

Correct Answer: D

  **DrMai** 9 months, 3 weeks ago

what about A? If the default setting is OFF then D can be somehow avoided...
upvoted 2 times

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

Which of the following is likely to be the most important issue with the choices presented in the 'Information Sharing and Consent' pages?

- A. The data and recipients for medical research are not specified
- B. Insufficient information is provided on notifications and infection alerts.
- C. The sharing of information with an affiliated healthcare provider is too risky
- D. Allowing users to share risk result information, for exposure and contact tracing purposes

Correct Answer: A

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

Which of the following pieces of information collected is the LEAST likely to be justified for the purposes of the app?

- A. Relationship of family member.
- B. Phone number.
- C. Date of birth.
- D. Citizenship.

Correct Answer: D

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

The location data collected and displayed on the map should be changed for which of the following reasons?

- A. The blurriness does not allow users to know how close they are to an infected person
- B. The radius used for location data exceeds official social distancing rules
- C. The location data has not been pseudonymized
- D. The location data is too precise

Correct Answer: B

  **DrMai** 9 months, 3 weeks ago

why is B correct? What happens if the distance exceeds official social distance?
upvoted 1 times

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

Which technology is best suited for the contact tracing feature of the app?

- A. Bluetooth
- B. Deep learning
- C. Near Field Communication (NFC)
- D. Radio-Frequency Identification (RFID)

Correct Answer: A

A healthcare provider would like to data mine information for research purposes; however, the Chief Privacy Officer is concerned medical data of individuals may be disclosed. To overcome the concern, which is the preferred technique for protecting such data while still allowing for analysis?

- A. Access Control
- B. Encryption
- C. Isolation
- D. Perturbation

Correct Answer: B

Community vote distribution

D (100%)

  **perryhan** 4 months, 1 week ago

Selected Answer: D

D is correct
upvoted 1 times

A privacy technologist has been asked to aid in a forensic investigation on the darknet following the compromise of a company s personal data. This will primarily involve an understanding of which of the following privacy-preserving techniques?

- A. Encryption
- B. Do Not Track
- C. Masking
- D. Tokenization

Correct Answer: A

An organization has completed the acquisition of a smaller rival in a different but related industry. The acquisition was approved by the regulator on the condition that the personal data sets may not be combined. A way of achieving this objective is through?

- A. Ciphertext
- B. Disassociability
- C. k-anonymity
- D. Pseudonymization

Correct Answer: D

- 

 **fvo** 6 months, 1 week ago

B
Disassociability is the minimization of connections between data and individuals to the extent compatible with system operational requirements. This minimization can take many forms, from maximally disassociated data in the form of high-level aggregated data, to deidentified records pertaining to distinct individuals. Disassociability can also take the form of architectural data separation, in which identifiable personal information is kept segregated from, but still linkable to, transactional data.
upvoted 2 times
- 

 **Stants** 4 months, 4 weeks ago

A way of achieving the objective of not combining personal data sets after an acquisition is through:

B. Disassociability

Here's why:

Disassociability allows data to be used without creating a link back to the individuals the data is derived from. This can be achieved by ensuring that the processing of data does not lead to the identification of individuals.
Ciphertext (Option A) is the result of encryption applied to plaintext and doesn't inherently prevent data sets from being combined.
k-anonymity (Option C) and Pseudonymization (Option D) are techniques used to de-identify data, but they don't necessarily prevent the combination of data sets.
upvoted 1 times
- 

 **DrMai** 9 months, 3 weeks ago

why is not B - dissociability?
upvoted 1 times

Which of these is considered an ethical dark pattern on privacy?

- A. Using attractive designs to influence an individual
- B. Rewarding users for providing more personal information
- C. Giving users more privacy options in relation to their personal information.
- D. Providing clear and simple privacy notices to users.

Correct Answer: B

Which concept related to privacy choice is demonstrated by highlighting and bolding the "accept" button on a cookies notice while maintaining standard text format for other options?

- A. Illuminating
- B. Nudging
- C. Suppression
- D. Tagging

Correct Answer: B

Which of these is NOT one of four elements of a design pattern?

- A. A problem description
- B. A pattern name
- C. A set of risks
- D. A solution

Correct Answer: C

Truncating the last octet of an IP address because it is NOT needed is an example of which privacy principle?

- A. Use Limitation
- B. Data Minimization
- C. Purpose Limitation
- D. Security Safeguards

Correct Answer: B

Which privacy engineering objective proposed by the U.S. National Institute of Science and Technology (NIST) decreases privacy risk by ensuring that connections between individuals and their personal data are reduced?

- A. Disassociability
- B. Manageability
- C. Minimization
- D. Predictability

Correct Answer: C

  **Stants** 4 months, 3 weeks ago
The privacy engineering objective proposed by the U.S. National Institute of Science and Technology (NIST) that decreases privacy risk by ensuring that connections between individuals and their personal data are reduced is A. Disassociability.

Disassociability involves designing systems in a way that reduces the association between individuals and their personal data. This can help to decrease privacy risks by making it more difficult to link data back to specific individuals, thereby enhancing privacy. It's an important concept in privacy engineering and is particularly relevant in contexts where data anonymization or pseudonymization is used.
upvoted 1 times

  **fvo** 6 months, 1 week ago
A
NIST's Privacy Engineering Program has proposed three privacy engineering objectives: predictability, manageability and disassociability. • Disassociability is the minimization of connections between data and individuals to the extent compatible with system operational requirements.
upvoted 1 times

  **DrMai** 9 months, 3 weeks ago
I think it should be A
upvoted 1 times

What is the main privacy threat posed by Radio Frequency Identification (RFID)?

- A. RFID can be utilized to track people or consumer products
- B. RFID can be utilized to gain unauthorized access to an individual's device
- C. RFID can be utilized to spoof identification details
- D. RFID can be utilized to read information from a device without the user's knowledge

Correct Answer: D

  **AM019** 11 months ago
This must be A.D is a functionality, A is a threat.
upvoted 3 times

Which of the following functionalities can meet data portability requirements for social networking apps as required in some jurisdictions?

- A. Allow users to modify the data they provided the app
- B. Allow users to delete the content they provided the app
- C. Allow users to download the content they have provided the app
- D. Allow users to get a time-stamped list of what they have provided the app

Correct Answer: C

An organization is using new technologies that will target and process personal data of EU customers. In which of the following circumstances would a privacy technologist need to support a data protection impact assessment (DPIA)?

- A. If a privacy notice and opt-in consent box are not displayed to the individual
- B. If security of data processing has not been evaluated
- C. If a large amount of personal data will be collected
- D. If data processing is a high risk to an individual's rights and freedoms

Correct Answer: D

  **DrMai** 9 months, 3 weeks ago
why is not A?
upvoted 1 times

Which of the following activities would be considered the best method for an organization to achieve the privacy principle of data quality?

- A. Clash customer information with information from a data broker
- B. Build a system with user access controls and approval workflows to edit customer data
- C. Set a privacy notice covering the purpose for collection of a customer's data
- D. Provide a customer with a copy of their data in a machine-readable format

Correct Answer: B

A developer is designing a new system that allows an organization's helpdesk to remotely connect into the device of the individual to provide support. Which of the following will be a privacy technologist's primary concern?

- A. Geofencing
- B. Geo-tracking
- C. Geo-tagging
- D. Geolocation

Correct Answer: D

An organization is evaluating a number of Machine Learning (ML) solutions to help automate a customer-facing part of its business. From a privacy perspective the organization should first?

- A. Define their goals for fairness
- B. Document the distribution of bias scores
- C. Document the False Positive Rates (FPR)
- D. Define how data subjects may object to the processing

Correct Answer: D

How does browser fingerprinting compromise privacy?

- A. By creating a security vulnerability
- B. By differentiating users based upon parameters
- C. By persuading users to provide personal information
- D. By customizing advertising based on the geographic location

Correct Answer: B

A computer user navigates to a page on the Internet. The privacy notice pops up and the user clicks the box to accept cookies, then continues to scroll the page to read the information displayed. This is an example of which type of consent?

- A. Explicit
- B. Implicit
- C. Specific
- D. Valid

Correct Answer: A

  **Stants** 4 months, 3 weeks ago

Implicit consent occurs when a user's actions or behaviors imply agreement with terms or conditions, rather than explicitly stating agreement. In this case, by clicking the box to accept cookies and continuing to scroll the page, the user is implying consent to the website's privacy notice and the use of cookies. This type of consent is often used for less intrusive actions or when it's impractical to obtain explicit consent for every interaction.

Explicit consent (option A) typically requires users to actively and clearly agree to specific terms or actions, often by checking a box or clicking a button that clearly states their consent.

Specific consent (option C) refers to consent given for a specific purpose or use of data, which may or may not be relevant in this scenario depending on the details of the privacy notice.

Valid (option D) doesn't directly relate to the type of consent but rather indicates that the consent obtained is legally recognized and meets applicable requirements.

upvoted 1 times

Many modern vehicles incorporate technologies that increase the convenience of drivers, but collect information about driver behavior in order to implement this. What should vehicle manufacturers prioritize to ensure enhanced privacy protection for drivers?

- A. Share the sensitive data collected about driver behavior with the driver
- B. Derive implicit consent for the processing of sensitive data by the continued use of the vehicle
- C. Obtain affirmative consent for processing of sensitive data about the driver
- D. Provide easy to read, in-vehicle instructions about how to use the technology

Correct Answer: C

An organization is considering launching enhancements to improve security and authentication mechanisms in their products. To better identify the user and reduce friction from the authentication process, they plan to track physical attributes of an individual. A privacy technologist assessing privacy implications would be most interested in which of the following?

- A. The purpose of the data tracking
- B. That the individual is aware tracking is occurring
- C. The authentication mechanism proposed
- D. The encryption of individual physical attributes

Correct Answer: B

Stants

4 months, 3 weeks ago

A privacy technologist assessing privacy implications would be most interested in:

A. The purpose of the data tracking

Understanding the purpose of tracking physical attributes is crucial for assessing its privacy implications. Knowing why the organization wants to collect this data helps determine whether it's necessary, proportionate, and aligned with privacy principles. It also helps evaluate the potential risk to individuals' privacy and whether there are less invasive alternatives to achieve the same goal.

upvoted 2 times

What is the name of an alternative technique to counter the reduction in use of third-party cookies, where web publishers may consider utilizing data cached by a browser and returned with a subsequent request from the same resource to track unique users?

- A. Web beacon tracking
- B. Browser fingerprinting
- C. Entity tagging
- D. Canvas fingerprinting

Correct Answer: B

Stants

4 months, 3 weeks ago

The technique you're referring to is known as C. Entity tagging.

Entity tagging, also known as ETag tracking, is a method where web publishers utilize data cached by a browser and returned with a subsequent request from the same resource to track unique users. This can serve as an alternative to third-party cookies, especially as their use is being reduced due to privacy concerns and regulations.

Please note that while this method can help with user tracking for analytics or personalization purposes, it also raises privacy concerns and should be used responsibly, in compliance with relevant laws and regulations.

upvoted 1 times

Which of the following would be an example of an "objective" privacy harm to an individual, based on Calo's Harm Dimensions?

- A. Receiving spam following the sale of an email address
- B. Negative feelings derived from government surveillance
- C. Social media profile views indicating unexpected interest in a person
- D. Personal data inaccuracies present in a user's social media profile

Correct Answer: D

Which of the following is an example of an appropriation harm?

- A. A friend takes and uploads your pictures to a social media website.
- B. A hacker gains access to your email account and reads your messages.
- C. A government agency uses cameras to monitor your movements in a public area.
- D. An unauthorized individual obtains access to your personal information and uses it for medical fraud.

Correct Answer: A

Which of the following is NOT a factor to consider in FAIR analysis?

- A. The severity of the harm that might be caused by the privacy risk
- B. The capability of a threat actor to exploit the analyzed privacy risk
- C. The stage of the data life cycle in which the analyzed privacy risk occurs
- D. The probability that a threat actor's attempts to exploit a privacy risk might succeed

Correct Answer: C

What is the key idea behind the "flow" component of Nissenbaum's contextual integrity model?

- A. The flow of Information from one actor to another
- B. The integrity of information during each stage of the data lifecycle
- C. The maintenance of accuracy when personal information is transmitted
- D. The movement of personal information within a particular context or domain

Correct Answer: D

Which of the following is the most important action to take prior to collecting personal data directly from a customer?

- A. Define what data needs to be collected.
- B. Define the purpose for collecting and using the data.
- C. Identify business requirements for the data that will be collected.
- D. Provide individuals with information about how their data will be used after collection.

Correct Answer: B

Which Privacy by Design principle requires architects and operators to emphasize the interests of the individual by offering measures such as strong privacy defaults, appropriate notice, and user-friendly options?

- A. Data lifecycle protection.
- B. Embedded into design.
- C. Respect for user privacy.
- D. Proactive not reactive.

Correct Answer: C

Which of the following is the best control to apply to personally identifiable data when the retention period ends?

- A. De-identification.
- B. Anonymization.
- C. Archiving.
- D. Deletion.

Correct Answer: D

What information is included in an effective privacy notice?

- A. Methods for data collection
- B. Provisions for data subject rights.
- C. Cost breakdown of privacy actions.
- D. Specific opt-in and opt-out statements.

Correct Answer: B

Which of the following best describes the role of privacy frameworks in the context of laws and guidance?

- A. They offer a set of guidelines for collecting and processing personal data.
- B. They offer a technical solution for encrypting and securing personal data.
- C. They provide a legal standard for determining whether a privacy violation has occurred.
- D. They provide a common language and structure for discussing and managing privacy risks.

Correct Answer: D

An organization would like to quantify potential losses from its privacy and security risks. This would best be achieved by utilizing?

- A. Calo's Harms Dimensions.
- B. Factor Analysis in Information Risk (FAIR).
- C. Fair Information Practice Principles (FIPPs).
- D. Organization for Economic Cooperation and Development (OECD) Principles.

Correct Answer: B

Which of the following is a stage in the data life cycle?

- A. Data aggregation
- B. Data classification
- C. Data mapping
- D. Data retention

Correct Answer: D

Which of the following occurs when individuals take a specific observable action to indicate and confirm that they give permission for their information to be processed?

- A. Passive consent
- B. Explicit consent
- C. Privacy statement
- D. Privacy notice

Correct Answer: B

Which of the following is the primary purpose of implementing “defense in depth” as a security concept in an organization?

- A. To manage incidents through multiple nodes of escalation
- B. To create multiple layers of security controls to prevent unauthorized access
- C. To ensure compliance with privacy regulations through strong security measures
- D. To monitor and detect security incidents in real-time to minimize privacy breaches

Correct Answer: B

Which activity best supports the principle of data quality from a privacy perspective?

- A. Protecting the data against unauthorized access
- B. Protecting the data against unauthorized changes.
- C. Ensuring the data is accurate, complete, and up-to-date.
- D. Ensuring the data is adequate, relevant, and limited to what is necessary.

Correct Answer: C

A company is implementing a new online application and the privacy technologist has advised about potential privacy implications. Who would most likely have final accountability if the recommendations made by the privacy technologist are implemented?

- A. The Technology Owner.
- B. The Privacy Legal Team.
- C. The Risk (Business) Owner.
- D. The Chief Information Security Officer.

Correct Answer: C

A company is looking to adopt new technology which the privacy technologist on the project believes may be unethical from a privacy standpoint. How should the privacy technologist respond?

- A. Stop the project by exercising veto rights.
- B. Implement privacy technical measures to help mitigate the identified privacy risks.
- C. Advise the project team about legal mechanisms it could adopt to manage the ethical considerations.
- D. Perform an audit of privacy controls post implementation to show leadership how unethical the project actually was.

Correct Answer: B

When designing a new system, which of the following is a privacy threat that the privacy technologist should consider?

- A. Caching.
- B. Dark patterns.
- C. Social engineering.
- D. Identity and Access Management.

Correct Answer: B

When consulting on privacy policies, a privacy technologist should FIRST?

- A. Align with industry best practices.
- B. Consider the organization's risk profile.
- C. Engage with the relevant external stakeholders.
- D. Require senior leadership to review and provide input.

Correct Answer: B

In terms of data extraction, which of the following should NOT be considered by a privacy technologist in relation to the ease of an individual to reuse personal data across different IT environments?

- A. The size of the data.
- B. The format of the data.
- C. The medium of the data.
- D. The interoperability of the data.

Correct Answer: A

A data scientist wants to improve her customer satisfaction prediction reports and has some ideas to improve the model. This procedure will involve copying the customer database from production to a test environment. To ensure privacy protection of customer information, the data scientist asked the privacy engineers for guidance. Which of the following Privacy Enhancing Techniques (PETs) would be best suited to support her analysis but reduce privacy risks?

- A. Use sample data.
- B. Use synthetic data.
- C. Use anonymized data.
- D. Use pseudonymized data

Correct Answer: B

One difference between privacy threat modeling and information security threat modeling is?

- A. Privacy threat modeling looks at threats to the individual while security threat modeling looks at threats to the organization.
- B. Security threat modeling is required by regulations such as the HIPAA Privacy Rule, but privacy threat modeling is not.
- C. Privacy threat modeling does not consider technical defects such as software vulnerabilities.
- D. Privacy threat modeling must consider insider threats, but security threat modeling does not.

Correct Answer: A

A Back-up-as-Service (BaaS) provider backs up corporate data and stores it with an outsider provider under contract with the organization. A researcher notifies the organization that he found unsecured data in the cloud. The organization looked into the issue and realized one of its backups was misconfigured on the outside provider's cloud and the data was fully exposed to the open internet. The service provider quickly secured the backup. Which is the best next step the organization should take?

- A. Review the content of the data exposed.
- B. Investigate using alternate BaaS providers or on-premise backup systems.
- C. Disconnect from the service and request a meeting with the outside provider
- D. Notify the relevant regulatory authorities and any customers affected by this incident.

Correct Answer: D

What occurs during data distortion?

- A. False and inaccurate information about an individual is shared
- B. Data collected about an individual includes prejudicial assumptions
- C. The personal data about an individual is modified to preserve their anonymity
- D. Truthful information that negatively affects how others view an individual is revealed

Correct Answer: C

Which of the following is the primary privacy consideration with regard to the use of large-scale, unsolicited commercial emails?

- A. The source of the emails may be disguised on purpose.
- B. The email addresses may be gathered without consent.
- C. The recipients may receive fraudulent or deceptive emails.
- D. The recipients' email addresses may contain inaccuracies.

Correct Answer: B

In jurisdictions where children are legally protected online, privacy controls should be implemented in each of the following situations EXCEPT?

- A. A virtual jigsaw puzzle game marketed for ages 5-9 displays pieces of the puzzle on a handheld screen. Once the child completes a certain level, it flashes a message about new themes released that day.
- B. A child logs in to a system to use an interactive toy that copies the child's behavior through gestures and kid-friendly sounds.
- C. A math tutoring service commissioned an advertisement on a bulletin board inside a school. The service makes it simple for children to reach out to tutors by entering a through a QR-code through their school account.
- D. A note-taking application converts hard copies of kids' class notes into audio books in seconds and stores a copy in the cloud in the students' account.

Correct Answer: C

One year cybercriminals successfully infected the credit card payment systems and bypassed security controls of a United States-based retailer with malware that exfiltrated 40 million credit card numbers. Six months prior, the retailer had malware detection software installed to prevent such an attack.

Which of the following would best explain why the retailer's consumer data was still exfiltrated?

- A. The newly installed malware prevention system conflicted with the legacy malware prevention system.
- B. The detection software alerted the retailer's security operations center as designed, but the information security personnel failed to act upon the alerts in a timely manner.
- C. The IT systems and security measures utilized by the retailer's third-party vendors were in compliance with industry standards, but their credentials were stolen by advanced threat actors who then entered the retailer's system.
- D. The retailer's network that transferred personal data and customer payments was separate from the rest of the corporate network, but the malware code was disguised with the name of software that is supposed to protect this information.

Correct Answer: B

An organization is deciding between building a solution in-house versus purchasing a solution for a new customer facing application. When security threats are taken into consideration, a key advantage of purchasing a solution would be the availability of?

- A. Data Management and analytics.
- B. Digital Rights Management.
- C. Outsourcing of resources.
- D. Patching and updates.

Correct Answer: D

An organization's customers have suffered a number of data breaches through successful social engineering attacks. Which is the most effective preventative technical control to reduce the risk of future occurrences?

- A. Audit and logging.
- B. Training and awareness.
- C. Data loss prevention (DLP).
- D. Multi-factor authentication.

Correct Answer: D

- Stants

4 months, 3 weeks ago

The most effective preventative technical control to reduce the risk of future occurrences of data breaches through social engineering attacks is D Multi-factor authentication.

Multi-factor authentication adds an additional layer of security by requiring users to provide two or more verification factors to gain access to a resource such as an application, online account, or a VPN. This makes it harder for potential intruders to gain access and steal personal data or identities

upvoted 1 times
- Stants

4 months, 3 weeks ago

It should be B

upvoted 1 times
- Stants

4 months, 3 weeks ago

Training and awareness (B) is not a technical control. It's a type of administrative control that can help educate users about the risks of social engineering attacks and how to avoid them, but it does not provide a technical barrier to these attacks.

upvoted 1 times

Failing to update software for a system that processes human resources data with the latest security patches may create what?

- A. Data breaches.
- B. Discrimination risks.
- C. Privacy vulnerabilities
- D. Increased threat sources

Correct Answer: C

- Stants

4 months, 3 weeks ago

Failing to update software for a system that processes human resources data with the latest security patches may create:

A. Data breaches.

Without the latest security patches, software vulnerabilities remain open to exploitation by attackers. These vulnerabilities could be exploited to gain unauthorized access to the system, leading to data breaches where sensitive human resources data is accessed, stolen, or compromised. Keeping software up-to-date with the latest security patches is crucial for mitigating security risks and protecting sensitive data from unauthorized access or exposure.

upvoted 1 times

To maximize sales, a company establishes a website and selectively showcases favorable reviews by filtering out less positive ones. This is an example of which privacy problem?

- A. Coercion.
- B. Data spying.
- C. Data distortion.
- D. Decisional interference.

Correct Answer: C

Community vote distribution

D (100%)

  **perryhan** 4 months, 1 week ago

Selected Answer: D

the answer is d.
Decisional interference involves others inserting themselves into a decision-making process that affects the individual's personal affairs. Example: A website limits access to negative product reviews to bias a new user toward a specific product selection
upvoted 1 times

A healthcare provider would like to data mine information for research purposes; however, the Chief Privacy Officer is concerned medical data of individuals may be disclosed. To overcome the concern, which is the preferred technique for protecting such data while still allowing for analysis?

- A. Anthropomorphism.
- B. Encryption.
- C. Isolation.
- D. Perturbation.

Correct Answer: D

An organization must terminate their cloud vendor agreement immediately. What is the most secure way to make the encrypted data stored inaccessible?

- A. Extract a copy of the data into a protected environment before requesting deletion.
- B. Replace Personally Identifiable Information (PII) with tokenized data.
- C. Obtain a destruction certificate from the cloud vendor.
- D. Destroy all encryption keys associated with the data.

Correct Answer: D

Which of the following technologies presents the most challenges to organizations when obtaining and demonstrating valid consent from individuals?

- A. Chatbots.
- B. Speech recognition.
- C. Internet of Things (IoT).
- D. Robotic Process Automation (RPA).

Correct Answer: C

An organization has completed the acquisition of a smaller rival in a different but related industry. The acquisition was approved by the regulator on the condition that the personal data sets may not be combined. A way of achieving this objective is through?

- A. Encryption.
- B. Disassociation.
- C. k-anonymity.
- D. Pseudonymization.

Correct Answer: D

- Stants** 4 months, 3 weeks ago

The best way to achieve the objective of not combining personal data sets after an acquisition is through B. Disassociation.

Disassociation involves breaking the links between different data sets to prevent them from being combined. This can help ensure that the personal data sets of the two companies remain separate, thus complying with the regulator's condition.

upvoted 1 times
- Stants** 4 months, 3 weeks ago

Pseudonymization (D) is a data management strategy where personally identifiable information fields are replaced with artificial identifiers or pseudonyms, but it doesn't prevent data sets from being combined.

upvoted 1 times

A company configures its information system to have the following capabilities:

- Allow for selective disclosure of attributes to certain parties, but not to others.
- Allow for information to be altered or deleted as needed.

These capabilities help to achieve which privacy engineering objective?

- A. Anthropomorphism
- B. Confidentiality.
- C. Disassociability.
- D. Manageability.

Correct Answer: C

One-way hash functions can be used is to?

- A. Verify a password in a secure way.
- B. Recover a credit card number at refund
- C. Encrypt a document for confidentiality.
- D. Secure an end-to-end communication.

Correct Answer: A

When considering dark patterns, which of the following should the privacy technologist be concerned about?

- A. Illicit collection of personal data
- B. Manipulation of a user's choice.
- C. Discrimination stemming from user profiles.
- D. Unauthorized access to an individual's data.

Correct Answer: B

Which concept related to privacy choice is demonstrated by highlighting and bolding the "accept" button on a cookies notice while maintaining standard text format for other options?

- A. Dark patterns
- B. Illuminating
- C. Nudging
- D. Suppression

Correct Answer: A

阿泽Vx: est258258

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

- A. The ON or OFF default setting for each item.
- B. The navigation needed in the app to get to the consent page.
- C. The collection of the user's location via the phone's GPS functionality.
- D. The information-sharing with healthcare providers affiliated with the company.

Correct Answer: A

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

Which of the following is likely to be the most important issue with the choices presented in the 'Information Sharing and Consent' pages?

- A. Options for allowing location sharing are not provided
- B. Allowing users to share risk result information is not properly defined
- C. The data and recipients for medical research are not specified
- D. The sharing of information with an affiliated healthcare provider is not secure

Correct Answer: C

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

Which of the following pieces of information collected is the LEAST likely to be justified for the purposes of the app?

- A. Relationship of family member.
- B. Home address.
- C. Date of birth.
- D. Citizenship.

Correct Answer: D

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

The location data collected and displayed on the map should be changed for which of the following reasons?

- A. The information does not allow users to know how close they are to an infected person
- B. The radius used for location data exceeds official social distancing rules
- C. The location data has not been pseudonymized
- D. The location data is too precise

Correct Answer: C

SCENARIO -

Please use the following to answer the next questions:

Your company is launching a new track and trace health app during the outbreak of a virus pandemic in the US. The developers claim the app is based on privacy by design because personal data collected was considered to ensure only necessary data is captured, users are presented with a privacy notice, and they are asked to give consent before data is shared. Users can update their consent after logging into an account, through a dedicated privacy and consent hub. This is accessible through the 'Settings' icon from any app page then clicking 'My Preferences', and selecting 'Information Sharing and Consent' where the following choices are displayed:

- "I consent to receive notifications and infection alerts";
- "I consent to receive information on additional features or services and new products";
- "I consent to sharing only my risk result and location information for exposure and contact tracing purposes";
- "I consent to share my data for medical research purposes"; and
- "I consent to share my data with healthcare providers affiliated to the company".

For each choice, an 'ON' or 'OFF' tab is available. The default setting is 'ON' for all. Users purchase a virus screening service for US\$29.99 for themselves or others using the app. The virus screening service works as follows:

- Step 1: A photo of the user's face is taken
- Step 2: The user measures their temperature and adds the reading in the app
- Step 3: The user is asked to read sentences so that a voice analysis can detect symptoms
- Step 4: The user is asked to answer questions on known symptoms
- Step 5: The user can input information on family members (name, date of birth, citizenship, home address, phone number, email and relationship).

The results are displayed as one of the following risk status "Low", "Medium" or "High". If the user is deemed at "Medium" or "High" risk an alert may be sent to other users, and the user is invited to seek a medical consultation and diagnostic from a healthcare provider.

A user's risk status also feeds a world map for contact tracing purposes, where users are able to check if they have been or are in close proximity of an infected person. If a user has come in contact with another individual classified as 'medium' or 'high' risk, an instant notification also alerts the user of this. The app collects location trails of every user to monitor locations visited by an infected individual. Location is collected using the phone's GPS functionality, whether the app is in use or not however the exact location of the user is "blurred" for privacy reasons. Users can only see on the map circles with a 12-foot radius (approximately 4 meters wide), which is double the recommended distance for social distancing.

With regard to the location-tracking feature of the app, which of the following is the privacy technologist's greatest area of concern?

- A. Unfair pricing based on location.
- B. Accuracy and use of location data.
- C. Tailoring advertisements to the user's location
- D. Use of cookies and other web-tracking technologies

Correct Answer: B

Which of these is considered a dark pattern on privacy?

- A. Using attractive designs to influence an individual.
- B. Providing unobtrusive notice that tracking is occurring.
- C. Rewarding users for providing more personal information.
- D. Giving users more privacy options in relation to their personal information.

Correct Answer: C

Which of the following would be the most appropriate solution for preventing privacy violations related to information exposure through an error message?

- A. Handle exceptions internally by sending the error message to the privacy officer.
- B. Create default error pages or error messages which do not include variable data
- C. Log the session name and necessary parameters once the error occurs to enable troubleshooting
- D. Use shorter error messages that indicate more information is available by clicking the "more information" button.

Correct Answer: B

A jurisdiction requiring an organization to place a link on the website that allows a consumer to opt-out of sharing is an example of what type of requirement?

- A. Functional
- B. Procedural
- C. Operational
- D. Technical

Correct Answer: D

An organization is in the process of designing a new application. It is currently looking at processes related to data that is no longer necessary for the purpose for which it was collected, and requests for deletion of data by individuals. What kind of data-oriented strategy is the organization considering?

- A. Abstract
- B. Hide
- C. Minimize
- D. Separate

Correct Answer: C

An organization is developing a mobile app-based game with children as the target audience. What is the most important requirement when following a code of practice to protect the privacy and wellbeing of the expected users?

- A. Transparency and consent using prominent and clear language.
- B. Default settings with a primary focus on the best interests of the user.
- C. Simple tools that allow users to report concerns and exercise their rights.
- D. Parental controls that will allow monitoring of the users' activities on the app.

Correct Answer: B

The web design team incorporated asterisks (*) next to all the PII (Personally Identifiable Information) fields in a web intake form. An asterisk signifies a mandatory field. Which of the following is an essential step prior to the web intake form go-live date?

- A. Analyze intake forms for similar use-cases available on the web and the competitors.
- B. Test the form using synthetic data to ensure it works to determine privacy functionality.
- C. Check with the web-development team on how to enforce input validation for the mandatory fields.
- D. Speak with the company's intake team on the appropriate number of data elements that the intake team requires to execute the use-case.

Correct Answer: B

An organization is designing a new system that allows its helpdesk to remotely connect to the device of an individual to provide support. Which of the following will be a privacy technologist's primary concern?

- A. The amount of time before the connection terminates
- B. The type of encryption used between the end user and helpdesk.
- C. The location of the helpdesk to identify cross border data transfers.
- D. The lack of a prompt to obtain consent from the end user to access the device.

Correct Answer: D

Which of the following is the LEAST effective at meeting the Fair Information Practice Principles (FIPPs) in the Systems Development Life Cycle (SDLC)?

- A. Defining requirements to manage end user content
- B. Conducting privacy threat modeling for the use-case
- C. Developing data flow modeling to help the purpose, protection, and retention of sensitive data
- D. Reviewing the code against Open Web Application Security Project (OWASP) Top 10 Security Risks

Correct Answer: D

What risk is mitigated when routing meeting video traffic through a company's application servers, rather than sending the video traffic directly from one user to another?

- A. The user's identity is protected from the other user
- B. The user is protected against cyberstalking attacks
- C. The user's IP address is hidden from the other user
- D. The user is assured that stronger authentication methods have been used

Correct Answer: C

Value sensitive design focuses on which of the following?

- A. Quality and benefit
- B. Ethics and morality.
- C. Confidentiality and integrity.
- D. Consent and human rights.

Correct Answer: B

An organization has changed its policies to allow its employees to work remotely. However, it is concerned about employees working and processing personal data in jurisdictions outside of its own. Which of the following would allow the organization to mitigate the risk?

- A. Geofencing
- B. I-diversity
- C. Pseudonymization
- D. Multi-Factor Authentication

Correct Answer: A

An organization is developing a speech recognition solution for its consumer-based application. From a privacy perspective, which architectural concept would help the organization to decide where to process the voice data?

- A. Defense in Depth
- B. Least Privilege
- C. Network Centricity
- D. Network Encryption

Correct Answer: C

  **Stants** 4 months, 3 weeks ago

B. Least Privilege

Explanation:

Least Privilege is a security principle that states that every module (such as a process, user, or program) must be able to access only the information and resources that are necessary for its legitimate purpose.

In the context of a speech recognition solution, applying the principle of Least Privilege would involve processing the voice data in the location where it is necessary for the application's functionality while minimizing unnecessary access to sensitive data. This ensures that voice data is only processed where it is required, reducing the risk of unauthorized access or exposure.

By limiting access to voice data to only the components of the application that require it, the organization can enhance privacy protection and reduce the potential for data breaches or misuse.

upvoted 1 times

When deploying a consumer gadget that incorporates speech recognition, where is the speech generally best processed, from a privacy by design perspective?

- A. Within the subject's jurisdiction
- B. On the remote server
- C. On the local device
- D. In the cloud

Correct Answer: C

A privacy engineer advises that multifactor authentication be used to log into a system containing personal data. Which of the following would be acceptable?

- A. Fingerprint scanning and then iris scanning.
- B. Facial recognition and then entering a PIN.
- C. Plugging in a smart card and then verifying a code sent to a mobile device.
- D. Entering a password and then answering a security question tied to the person.

Correct Answer: C

The increase in remote working has resulted in greater use of videoconferencing by companies. When assessing the privacy risk from implementing and enabling recording functionality of video conferencing software, which of the following would a privacy technologist most likely require of the software?

- A. That encryption is used for storage of the video recording data.
- B. That the meeting recording can only be accessed by the attendees.
- C. That there is a noticeable indication to all attendees when recording is active.
- D. That the geographical location of the attendees is logged for compliance purposes.

Correct Answer: C